CPE334 Software Engineering — Deliverable 1

NutTiew (นัดติว) — One-to-One Tutoring Appointment System

Academic Term: Semester 1/2026

Department: Department of Computer Engineering, Faculty of Engineering

Institution: King Mongkut's University of Technology Thonburi (KMUTT)

Assigned Theme: Theme 1 — Appointment & Scheduling

Project Repository: https://github.com/Tanaboonnnnn/CPE334-NutTiew

Integration Staging Base SHA: `9d24fca` on branch `sprint1`

Tested PR HEAD SHA: `e591f72` on branch `docs/18-deliverable-1-integration` (Pull Request #43)

Target Release Branch: `main` (Pending teammate review and approval of PR #43)

Course Handout Deadline: 8 November 2026, 23:59 ICT

Document Generation Time: 10 November 2026, 01:15 ICT

Team Members & Identification

Student Full Name	Student ID	GitHub Username	Project Role & Responsibility
Tanboon Teawsawat	*(Supplied Privately via LEB2 handoff)*	@Tanaboonnnnn	Requirements Discovery Lead, System Architecture, Three-Sprint Plan, Project #6 Kanban, Peer Reviewer
Chxtamos	*(Supplied Privately via LEB2 handoff)*	@Chxtamos	Backend & Database Implementation, Concurrency Engineering, Frontend React UI, Automated Test Suites, PDF Lead

> ***Privacy Notice on Student Identification:*** *In compliance with student privacy protection and academic repository standards, full KMUTT Student ID numbers are supplied privately through the official university course submission portal (LEB2) and are redacted from public Git commit histories.*

Executive Summary & Document Navigation Guide

NutTiew (นัดติว) is an enterprise-grade appointment and scheduling web application engineered for one-to-one tutoring services under CPE334 Software Engineering. Deliverable 1 provides an exhaustive, self-contained software engineering deliverable comprising **Parts A through F**, satisfying all instructor grading requirements without requiring external repository access.

Document Navigation & Estimated Page Ranges

Document Section	Primary Content & Coverage	Relevant Requirements & Contracts
Part A: Whole-Product SRS	Problem domain, actors, complete business rules, numbered requirements	FR-001..036, BR-001..035, NFR-001..016, Q01–Q32
Part B: Feature Inventory & Traceability	Feature catalog across Sprints 1–3, complete requirement-to-feature matrix	F-S1-01..05, F-S2-01..05, F-S3-01..02, AC-S1-01..35
Part C: Whole-Product System SDS	System architecture, Express 5 + React 19, real PostgreSQL DDL & triggers	C4 Architecture, btree_gist, slot_guard_s1, booking_guard_s1
Part D: Feasible Three-Sprint Plan	Sprint 1, 2, 3 scopes, dependencies, milestones, risk management	Three-Sprint Delivery Plan, S1 Acceptance Boundary
Part E: Sprint 1 Feature Specifications	Complete specifications, data/API/UI contracts, STSs, and DoDs	F-S1-01, F-S1-02, Shared Foundation, F-S1-03, F-S1-04, F-S1-05
Part F: Implementation & Verification	Truthful 199 distinct test results, Race A/B/C proofs, excerpts, TDD, journey screenshots	Real PG 106/106, Edge 64/64, Unit 29/29, Substantive PRs #38 & #42

Part A: Whole-Product Software Requirements Specification (SRS)

0. Document control

Field	Value
Product	CPE334 NutTiew, Theme 1: Appointment and Scheduling (tutoring context)
Course	CPE334, Introduction to Software Engineering in the Age of AI Agents, semester 1/2026
Repository	Tanaboonnnnn/CPE334-NutTiew
Artifact / version	`docs/srs.md`, v0.1.0, 3 November 2026
Status	**DRAFT FOR PEER REVIEW; NOT INSTRUCTOR-APPROVED**
Requirements engineer / PR author	@Tanaboonnnnn
Required independent reviewer	@Chxtamos (review request and approval are separate actions)
Coverage	Whole-product software requirements for Sprints 1, 2 and 3
Primary readers	Stakeholder/instructor, peer reviewer, requirements/design engineers, test authors and release reviewers
Baseline	Confirmed stakeholder decisions Q01-Q32, reviewed Sprint 1 `docs/requirements.md`, available instructor handouts

Field	Value
Instructor-source status	`group_work_specs_v1.pdf` was examined; explicitly **Draft for instructor review**, issued 6 October 2026. The final `group_work_specs.docx`, amendments and Theme 1 eligibility are **UNVERIFIED**; formal sign-off is blocked (OD-011/012).
Implementation and verification status	This artifact specifies planned behavior and planned validation. It does not certify code, executed tests, a deployed release or passed acceptance tests.
Delivery boundary	Deliverable 1 **Part A only**. Parts B-F and Labs 5-7 are separate deliverables.

0.1 Reading rules and status vocabulary

- **Confirmed (Qxx):** a stakeholder decision recorded in the agreed Q01-Q32 baseline. Its product behavior is binding unless a new decision is explicitly approved.
- **Instructor-draft requirement (GW/D1):** a rule contained in the instructor-format handouts actually examined. Treat it as the available course baseline, subject to comparison with the final Master Specification.
- **Engineering interpretation:** a precise, reviewable reading of a confirmed outcome, not a new stakeholder policy (for example, transaction-safe evaluation of Q05).
- **Proposed:** a team suggestion or target that cannot be presented as approved until its owner decides.
- **Open / pending approval:** the source does not settle a policy or the necessary independent confirmation is absent.
- **Verified:** a test or source check actually performed with recorded evidence. No application verification is claimed here.

The statement `MUST` denotes a confirmed stakeholder rule or an applicable instructor-draft minimum, with its provenance in the requirement catalog. `SHOULD (PROPOSED)` is not an acceptance condition until approved. New numeric limits, schema fields, API responses, or service policies must not be disguised as existing requirements.

0.2 Navigation

1. Executive overview
2. Stakeholders, actors and glossary
3. Product scope and sprint boundaries
4. System context and user journeys
5. Functional requirements
6. Business rules
7. Non-functional requirements
8. Authorization and privacy
9. Logical domain and lifecycle
10. Time, conflicts and concurrency
11. Exception and boundary scenarios
12. Source and requirement traceability
13. Open decisions and approval gates
14. Exclusions and future compatibility
15. Verification planning

16. Risks, dependencies and change control
17. Review checklist and sign-off
18. References

0.3 Document history

Version	Date	Change	Review / approval
0.1.0	2026-11-03	Initial whole-product SRS based on Q01-Q32, the Sprint 1 baseline and identified instructor handouts	Draft; independent review and instructor Master verification outstanding

1. Executive overview

1.1 Problem, objective and value

Learners need a dependable way to reserve one-to-one lessons with a Tutor at times the Tutor has actually offered. Tutors need control of their own availability and a trustworthy view of reservations. Without a single authoritative reservation workflow, a learner may see stale availability, two learners may claim the same lesson, or one learner may inadvertently reserve overlapping lessons with different Tutors. Cancellation, rescheduling and schedule changes add further ways for the displayed calendar to disagree with the saved records.

NutTiew will let a Tutor publish individual sixty-minute offers and let a Customer reserve an eligible offer. The complete product will support tightly governed cancellation and rescheduling, private Tutor-cancellation notifications, controlled withdrawal of unused offers and a Tutor-only appointment summary. A successful operation must leave coherent persisted records; a failed operation must not change the booking/schedule outcome by accident.

Business value is a clear reservation trail and fewer schedule conflicts, with the Tutor and Customer seeing only records their roles are permitted to access. Payment collection, lesson delivery and attendance certification are not part of the confirmed service.

1.2 System boundary and principal risks

The software boundary covers authenticated web interactions, server-side role/ownership and business-rule checks, and persistent storage of Slots, Bookings, history and authorized notifications. A browser's display is never authoritative for a reservation; accepted mutations are determined by the server against current committed data.

Principal risks are simultaneous conflicting writes, ambiguous scheduling policies, disclosure of another learner's booking/cancellation reason, incorrect timezone or cutoff interpretation, loss of history on rescheduling/withdrawal, and treating proposed engineering limits as stakeholder approvals. The final instructor Master and team Theme allocation are also unverified (Section 13).

1.3 Agreed product model

One Booking reserves **one exclusive 60-minute Slot** for **one Customer and one Tutor**. The Tutor is the Staff actor; the Customer is the learner. Slots are explicitly published one at a time. Same-Tutor currently offered Slots do not overlap, and one Customer's active reservations do not overlap across Tutors. Adjacent time intervals are permitted by the conflict rules. Appointments that have ended remain `Booked` unless legitimately cancelled; their `Past` label is a time-derived presentation, not evidence that a lesson was completed.

2. Stakeholders, actors and glossary

2.1 Roles and boundaries

Actor / stakeholder	Goal and responsibility	Permitted product operations	Trust, visibility and restrictions
Customer (Learner)	Find and reserve one-to-one tutoring; maintain their own bookings	Authenticated availability, create Booking, view own Booking, cancel and reschedule their own eligible Booking, read own Tutor-cancellation notification	Cannot publish/manage Tutor Slots, view another Customer's private records, see Tutor-only summary, or cancel/reschedule another Customer's Booking
Tutor (Staff)	Offer time, serve assigned Bookings, maintain own timetable	Publish individual Slots, view own authorized schedule/Bookings, cancel assigned Booking within policy, withdraw eligible own Slot, read own Appointment Summary	No global management of another Tutor's schedule; no Customer-originated rescheduling; no arbitrary Customer private data
Anonymous visitor	Reach the entry/login experience	Access a login interface; authenticate with valid credentials	Cannot read protected identity, private availability/schedule/Booking/notification data, or mutate Slots/Bookings. Public availability is not promised by the baseline.
Application / server	Apply business policy and own data consistency	Authenticate session, authorize requests, sample server time, arbitrate conflicts, persist atomic outcomes and return role-filtered views	Client IDs, clocks, role flags and stale UI state cannot override server rules
Instructor / product owner	Confirm permitted theme, assess business baseline and approve material changes	Review the SRS, decide unresolved policy and course-source conflicts	Final Master and Theme assignment require dated evidence
Team reviewer	Independently check requirements, tests and change history	Review the Issue-linked PR and approve/request changes	Review request, review submission, approval and merge are distinct recorded states

Tutor = Staff is a role equivalence in this product. It does not introduce a separate administrator role. If a Tutor also wants to book a lesson as a learner, an explicit account/role policy would be required; staff privileges alone do not grant Customer-only actions.

2.2 Glossary

Term	Definition
Availability Slot / Slot	One Tutor-owned individual offer with a specified start and end exactly 60 minutes apart (Q03-Q04)
Currently offered Slot	A published, not-withdrawn offer; it may be unoccupied or occupied

Term	Definition
Bookable Slot	Currently offered, unoccupied, valid future Slot satisfying the new-Booking cutoff and all eligibility checks at the authoritative decision time
Withdrawn Slot	Retained historical Slot that is no longer offered; cannot itself be reactivated (Q32)
Appointment	Scheduled one-to-one Customer/Tutor interval associated with a Booking and Slot; not proof of attendance
Booking	Persistent reservation with stable identity, owner, assigned Slot/Tutor and business state
Active Booking	A `Booked` reservation that has not been cancelled; passage of the session end does not automatically release it
Cancelled Booking	Booking transitioned to `Cancelled` by an authorized cancellation workflow; retained according to unresolved data-governance policy
Reschedule	Authorized atomic reassignment of an existing Booking to a different eligible Slot while preserving Booking ID and success history
Reschedule history	Record of a **successful** change containing old/new Tutor, Slot/time and change timestamp (Q15)
In-app notification	Private persisted message for a Customer whose Booking was cancelled by their Tutor (Q21-Q25)
Appointment Summary	Tutor-only view of the authorized Tutor's Upcoming Booked, Past Booked and Cancelled counts and underlying lists (Q31)
Half-open interval	`[start, end)`; includes the start, excludes the end, permitting back-to-back adjacency without overlap
Business timezone	`Asia/Bangkok` (UTC+07:00), uniform for scheduling and display; the server clock is authoritative
T_elig	Server-derived eligibility instant sampled in the final guarded transaction check after any contention wait; adopted as the precise Sprint 1 review interpretation of Q05, subject to Feature SDS approval
FR / BR / NFR	Functional requirement / business rule / non-functional requirement
AC / STS / VAL	Acceptance criterion / software test specification / **planned** validation scenario in this SRS

3. Product scope and sprint boundaries

3.1 Confirmed whole-product capabilities

The agreed product includes Tutor-owned 60-minute slot publishing; Customer browsing and exclusive booking; persisted, role-limited Booking views; Customer cancellation with reopening; Customer-initiated one-time atomic rescheduling (including across Tutors); Tutor cancellation with mandatory reason and Slot withdrawal; private in-app notice with durable read access; controlled withdrawal/replacement of unoccupied future offers; and an authorized Tutor summary. Q01-Q32 are the behavioral baseline, not thirty-two optional enhancements.

3.2 Instructor minimum and technical constraints

The examined Group Work Specification v1 §§5-6 and Theme 1 example require a meaningful, tested UI → API/application → persistent-database journey, real login/logout/current identity in Sprint 1, Customer and Staff roles, backend authorization, protected Customer/Staff data, persistent Booking, past/invalid/occupied rejection and

concurrent single-Slot exclusivity. The instructor materials call for versioned engineering contracts, automated tests, reviewed GitHub PRs, and later Docker/GCP/CI deployment; the Sprint 1 working software and evidence are **separate Issues** from this SRS.

3.3 Sprint allocation is a planning proposal

Sprint	Proposed delivery responsibility	Requirement status
Sprint 1, Deliverable 1	Login/logout/current identity, role/ownership enforcement, manual sixty-minute Tutor Slots, own Tutor schedule, availability browsing, exclusive Booking, own Customer/Tutor reads, persistence, invalid/too-soon/overlap rejection, three concurrency invariants, Bangkok time, Booked/Past correctness	Scope aligns with reviewed `docs/requirements.md` and the available Theme 1 minimum
Sprint 2, proposed	Customer cancellation/reopening; one-time Customer reschedule across Tutors, atomic history; Tutor cancellation/reason/withdrawal; authorized unoccupied Slot withdrawal; private cancellation notifications and history	Q07-Q27 and Q32 are confirmed **product rules**; placing these in Sprint 2 is a **proposal**, not an additional stakeholder decision
Sprint 3, proposed	Tutor-only summary with three categories, counts and lists; remaining approved refinements, integration and full regression	Q31 is a confirmed product rule; timing and scope allocation require review in Issue #12

Part D's detailed three-sprint plan belongs to **Issue #12**. This table assigns responsibility so SRS verification is understandable without writing that separate plan. A later-sprint requirement is not a claim that its UI, API or code already exists.

3.4 Explicit exclusions, assumptions and unresolved policy

Payments, pricing, self-registration, email/SMS/push reminders, group sessions, lesson platform/location, external calendar synchronization, attendance verification, automatic recurring Slots, and a global administrator are **not approved product capabilities**. They are excluded from the currently agreed baseline; adding them requires a decision and change review, not implementation by inference.

Working hours, permitted days, maximum look-ahead, allowed start-minute grid, exact availability presentation, retention/deletion policy, in-progress summary classification, session/token mechanics, retry response behavior and proposed quality thresholds are **open** (Section 13). In particular, no confirmed working-hours restriction does not establish a promise of twenty-four-hour service.

4. System context and user journeys

For each journey below, `S1/S2/S3` is the **proposed verification sprint**, not proof of delivery. On any rejected mutation, previously committed records remain authoritative. API paths, database schema, error codes and UI field layouts belong to the separate design/contracts.

4.1 J-01: Tutor publishes one Slot (S1)

Preconditions: authenticated Tutor; proposed start is valid/future and does not intersect a currently offered Slot belonging to the same Tutor. **Flow:** Tutor selects one Bangkok start; server derives/checks a sixty-minute interval, confirms ownership and current-offer non-overlap, then persists one offer. **Alternatives/failures:** invalid, past, wrong-role or conflicting proposals are refused; simultaneous overlapping proposals must not both commit.

Postcondition: the Tutor can retrieve the new unoccupied Slot on their own schedule. **References:** FR-005..007, BR-002..004/006/035; VAL-003..005.

4.2 J-02: Customer finds an eligible Slot (S1)

Preconditions: authenticated Customer and one or more current offers. **Flow:** server returns permitted Tutor/time details and correct eligibility as of the lookup; Customer selects an offer. **Alternatives/failures:** occupied, too-soon and past Slots cannot be presented as guaranteed bookable; no third-party Booking or cancellation reason is disclosed. Whether ineligible offers are hidden or visibly marked is an open UI decision. **Postcondition:** a possible selection, **not** a reservation. **References:** FR-008/009, BR-005/028/029; VAL-006/036.

4.3 J-03: Customer books an exclusive session (S1)

Preconditions: authenticated Customer; unoccupied currently offered Slot; no overlapping Active Booking for that Customer; at least 60 minutes before start at authoritative eligibility check. **Flow:** server revalidates all rules under transaction/concurrency control, commits one `Booked` record with trusted Customer and Slot's Tutor, then returns success. **Alternatives/failures:** stale selection, too-soon request, duplicate claim, same-Customer overlap or persistence failure produces no conflicting/partial committed claim. **Postcondition:** Slot is occupied and the Booking is retrievable by its owner and authorized Tutor. **References:** FR-010..013/016/018, BR-001/005/028/034; VAL-007..011/014/030.

4.4 J-04: Customer retrieves their Booking (S1)

Preconditions: Customer owns a committed Booking. **Flow:** Customer requests own list/detail; server authenticates and filters by ownership, returning saved Tutor/Slot/interval and correct business state. **Alternatives/failures:** a known foreign Booking ID yields no private payload; expired session cannot recover protected content. **Postcondition:** no state change; elapsed appointment may display `Past` while retaining `Booked`. **References:** FR-014/016/017, BR-002/030; VAL-012/013.

4.5 J-05: Tutor inspects their schedule and Bookings (S1)

Preconditions: authenticated Tutor. **Flow:** server retrieves only Slots and associated Bookings on the Tutor's authorized schedule. **Alternatives/failures:** another Tutor's ID or manipulated filters cannot expand access; no global Customer data retrieval. **Postcondition:** read-only, persisted schedule/Booking view. **References:** FR-007/015, BR-002/033; VAL-002/012.

4.6 J-06: Customer cancels own Booking (S2)

Preconditions: authenticated owning Customer; active Booking starts at least 30 minutes from authoritative request decision. **Flow:** cancel the Booking as `Cancelled` and reopen its original Slot as one consistent persisted change. **Alternatives/failures:** nonowner, already cancelled or less-than-30-minute attempt is rejected with unchanged records. **Postcondition:** the reopened offer may still be **unbookable** under the independent 60-minute new-Booking rule. **References:** FR-020/021, BR-007/008; VAL-015/016.

4.7 J-07: Customer reschedules once (S2)

Preconditions: owning Customer; current `Booked` appointment and desired unoccupied Slot; original and destination each start at least 60 minutes after the authoritative decision; no earlier successful reschedule. **Flow:** atomically move the same Booking ID to the destination (possibly a different Tutor), reopen the old Slot, record old/new Tutor/Slot/interval and change time, and increment successful-reschedule count once. **Alternatives/failures:** late original/destination, occupied destination, unauthorized owner, quota exhausted, conflict

or persistence failure leaves original Booking, old Slot, destination and history unchanged; failed attempt does **not** consume allowance. **Postcondition:** one live reservation with retained identity and audit history. **References:** FR-022..027, BR-009..016; VAL-017..020.

4.8 J-08: Tutor cancels their assigned Booking (S2)

Preconditions: authenticated currently assigned Tutor, active Booking at least 60 minutes away, meaningful nonblank reason. **Flow:** server atomically cancels the Booking, withdraws its Slot instead of reopening it, preserves the reason for the owning Customer and creates their private in-app notification. **Alternatives/failures:** wrong Tutor, too-late request, blank/meaningless reason or failed persistence gives no partial cancellation/withdrawal/notification. **Postcondition:** Booking is `Cancelled`, original Slot withdrawn and the Customer informed through the application. **References:** FR-028..031, BR-017..023/026; VAL-021..023.

4.9 J-09: Customer reads and rereads a private notice (S2)

Preconditions: successful Tutor cancellation created a notice addressed to Customer. **Flow:** Customer reads notice and reason, marks it read if supported, and later opens it again; cancelled Booking detail also shows the authorized reason. **Alternatives/failures:** different Customer, Tutor without applicable authorization or anonymous request gets no notice/reason. **Postcondition:** read state must not erase the message, and no timer automatically expires it. A separate retention/deletion policy remains open. **References:** FR-031/032, BR-021..025; VAL-023/024.

4.10 J-10: Tutor withdraws an unoccupied future Slot (S2)

Preconditions: authenticated owning Tutor; unoccupied future currently offered Slot. **Flow:** Tutor withdraws that Slot, preserves it as history, then may independently create a **new Slot ID** at a permitted time, even if it overlaps the withdrawn interval. **Alternatives/failures:** direct edit/delete/withdraw while an Active Booking exists is forbidden; withdrawn Slot cannot be reactivated under the same identity. **Postcondition:** old Slot remains historical and no longer blocks current-offer overlap checks. **References:** FR-033/034, BR-026/027/032; VAL-025..027.

4.11 J-11: Tutor views Appointment Summary (S3)

Preconditions: authenticated Tutor with authorized scheduling records. **Flow:** server provides counts and corresponding lists for Upcoming Booked, Past Booked and Cancelled, restricted to that Tutor's authorized scope; summary rows may lead to permitted details. **Alternatives/failures:** Customer/anonymous/foreign Tutor access is denied; an appointment in progress has no approved bucket until OD-006 is resolved. **Postcondition:** report read changes no Booking business state and does not imply attendance. **References:** FR-035/036, BR-030/031; VAL-028/029.

5. Functional requirements

Every `FR-xxx` is a stable **whole-product** identifier. `FR-S1-01..19` remain unchanged in the reviewed Sprint 1 source; the explicit crosswalk is in §12.4. `M` means Must for the stated **product baseline**, not an assertion that a later-sprint feature is due in Sprint 1. Sprint allocation is proposed in §3.3. Each `VAL-xxx` identifies a **planned** way to inspect the requirement, never a passed test. Every mutating FR implicitly requires the backend identity, ownership, timing and transaction rules in §§6, 8 and 10.

5.1 Identity and access

ID	Actor and testable requirement, including safe failure	Source	Priority / sprint	Planned proof; dependency
FR-001	**Customer/Tutor:** With existing valid credentials, authenticate and establish only that principal's effective role; reject invalid credentials without authenticated access.	GW §5.2; Sprint 1 baseline	M / S1	VAL-001; identity contract
FR-002	**Authenticated Customer/Tutor:** Return the current principal's own identity and role without accepting a client-supplied impersonation; anonymous requests reveal no protected identity.	GW §5.2	M / S1	VAL-001/002; FR-001
FR-003	**Authenticated Customer/Tutor:** Log out and render the prior session/access unusable for protected operations; the exact invalidation/expiry method must be decided in the auth contract.	GW §5.2	M / S1	VAL-001/002; OD-005
FR-004	**Application/server:** Authenticate and enforce role and record ownership on every protected Slot, Booking, notification and summary action, including crafted requests and URL/ID access; reject unauthorized access without private payload.	GW §5.2/Theme 1; Q02	M / S1, extended S2/S3	VAL-002/036; FR-001/002

5.2 Tutor availability, discovery and new Booking

ID	Actor and testable requirement, including safe failure	Source	Priority / sprint	Planned proof; dependency
FR-005	**Tutor:** Given authorization to their own schedule and a valid future start, publish exactly one explicit sixty-minute Slot; persist it under the authenticated Tutor, without recurrence or auto-generated bulk offers.	Q02-Q04; Theme 1	M / S1	VAL-003; FR-004, OD-001..003
FR-006	**Server on Tutor creation:** Reject malformed/past Slots and overlaps between currently offered Slots of the same Tutor; permit adjacent intervals and independent same-time offers by another Tutor when otherwise valid; leave existing offers unchanged on rejection.	Q03/Q06/Q29; Theme 1	M / S1	VAL-004/005; FR-005
FR-007	**Tutor:** Retrieve own offered Slots and authorized occupied/unoccupied schedule view from committed data; reject another Tutor's protected schedule lookup.	Q02; Theme 1	M / S1	VAL-002/012; FR-004/005
FR-008	**Customer:** Browse Tutor/Slot/time information sufficient to choose a specific offer, without disclosure of another Customer's private reservation; the concrete field allowlist remains an API-contract choice.	Q01/Q02; Theme 1	M / S1	VAL-006/036; FR-004/005
FR-009	**Server/availability view:** Mark an offer bookable only when current, unoccupied, eligible and not too close to its start; an earlier view must not guarantee later acceptance. Hide-versus-disabled presentation is unresolved.	Q05/Q06; Theme 1	M / S1	VAL-006/009; OD-004

ID	Actor and testable requirement, including safe failure	Source	Priority / sprint	Planned proof; dependency
FR-010	**Customer:** Given an eligible Slot and no overlapping Active Booking, request one exclusive reservation for their authenticated identity; commit one `Booked` Booking referencing the actual Slot and Tutor before acknowledging success.	Q01/Q05; Theme 1	M / S1	VAL-007; FR-001/004/005
FR-011	**Server on Booking:** Revalidate offered/unoccupied state, user ownership, cutoff and overlaps immediately before a guarded Booking write; reject stale, invalid, past, too-soon or occupied choices with no partial reservation.	Q05/Q06/Q28; Theme 1; engineering interpretation of T_elig	M / S1	VAL-008/009/014; FR-010
FR-012	**Server on competing Bookings:** Under simultaneous attempts by different Customers for the same exclusive Slot, allow at most one committed Active Booking and never return two successful claims.	Q01; Theme 1	M / S1	VAL-010; FR-010/011
FR-013	**Server on Customer Booking:** Reject the same Customer's overlapping Active reservation, including requests for two different Tutors; accept adjacency under this specific rule, with at most one conflicting success under concurrency.	Q28	M / S1	VAL-004/011; FR-010/011
FR-014	**Customer:** Retrieve a persisted list and detail of **own** Bookings with Booking identity, Tutor/Slot/interval and business status; foreign IDs must not disclose Booking data.	Q02/Q30; Theme 1	M / S1	VAL-012/036; FR-004/010
FR-015	**Tutor:** Retrieve Bookings attached to the Tutor's authorized schedule only; requesting another Tutor's records must not disclose them.	Q02; Theme 1	M / S1	VAL-002/012; FR-004/010
FR-016	**Application:** Authorized reopened/refresh/restart views must reflect successfully committed Slots/Bookings and correct ownership; a failed transaction must not produce a persisted or reported phantom Booking.	GW §5.1; Theme 1	M / S1	VAL-007/014; FR-005/010
FR-017	**Application views:** Display `Booked` accurately and, when a Booking's end is past, optionally derive `Past`; never assert `Completed`, attendance or auto-release solely from elapsed time.	Q30	M / S1	VAL-013; FR-014/015
FR-018	**Application/server:** Return an observable, non-success rejection for forbidden, invalid, stale, conflicting or failed mutations, without leaking protected records or leaving partial state. Specific HTTP status/payload formats remain contract decisions.	Q02/Q05/Q06/Q28; Theme 1	M / S1, extended S2	VAL-002/014/030; OD-005/013
FR-019	**System:** Support the Tutor offer → Customer browse → committed Booking → authorized retrieval journey through a real UI, application/API and durable database, surviving refresh and application restart.	GW §5.1; D1 §2	M / S1	VAL-007/031; engineering contracts outside Issue #9

5.3 Customer cancellation and rescheduling

ID	Actor and testable requirement, including safe failure	Source	Priority / sprint	Planned proof; dependency
FR-020	**Owning Customer:** Cancel their current Booking when the Appointment starts **at least 30 minutes** after the server's authoritative decision; at the exact boundary allow, below it deny; foreign or nonactive Booking cannot be cancelled.	Q07	M / proposed S2	VAL-015; FR-004/014
FR-021	**Server on successful Customer cancellation:** Change Booking to `Cancelled` and reopen its **same** original Slot atomically; keep it unbookable for any later new request failing the independent Q05 cutoff.	Q08/Q05	M / proposed S2	VAL-015/016; FR-020
FR-022	**Owning Customer:** Initiate rescheduling of an existing `Booked` Booking; reject nonowners and disallowed Booking state.	Q09	M / proposed S2	VAL-017; FR-004/014
FR-023	**Server on reschedule:** Require both original Appointment start **and destination Slot start** to be at least 60 minutes away at authoritative decision; reject either too-late side including the just-below-boundary case.	Q10/Q11	M / proposed S2	VAL-018; FR-022
FR-024	**Owning Customer:** Select a valid destination with a different Tutor if desired; do not restrict rescheduling to the original Tutor, while still enforcing destination occupancy and same-Customer overlap.	Q12/Q28	M / proposed S2	VAL-019; FR-023
FR-025	**Server on reschedule:** Atomically update Booking assignment, occupy destination, release/reopen original Slot and record history; any validation, conflict or persistence failure leaves all related records at their pre-attempt state.	Q13/Q14	M / proposed S2	VAL-020; FR-022..024
FR-026	**Server:** Preserve the Booking ID across a successful reschedule and append a successful-change record with former/new Tutor, Slot/interval and timestamp; rejected attempts do not create successful history.	Q15	M / proposed S2	VAL-020; FR-025
FR-027	**Server:** Permit **at most one successful** reschedule per Booking; a failed attempt leaves the allowance available, while a second successful-change request is rejected.	Q16	M / proposed S2	VAL-017/020; FR-025/026

5.4 Tutor cancellation, Slot withdrawal and notice

ID	Actor and testable requirement, including safe failure	Source	Priority / sprint	Planned proof; dependency
FR-028	**Currently assigned Tutor:** Cancel an Active Booking belonging to the Tutor's authorized schedule only when its start is at least 60 minutes away; exact boundary passes and wrong-Tutor/too-late attempts fail.	Q17/Q18	M / proposed S2	VAL-021; FR-004/015
FR-029	**Tutor/server:** Require a meaningful nonblank reason before accepting Tutor cancellation; reject absent, whitespace-only or semantically empty reason without changing Booking or Slot. Length/format details need approved design.	Q20	M / proposed S2	VAL-021; FR-028, OD-014

ID	Actor and testable requirement, including safe failure	Source	Priority / sprint	Planned proof; dependency
FR-030	**Server on successful Tutor cancellation:** Mark Booking `Cancelled` and **withdraw** its original Slot instead of reopening it; preserve trace/history and ensure no partial outcome.	Q19	M / proposed S2	VAL-022; FR-028/029
FR-031	**Server:** On successful Tutor cancellation create one private in-app notice for that Booking's owning Customer, including the authorized reason; the reason also appears in that Customer's cancelled Booking details, never in third-party views.	Q21-Q23	M / proposed S2	VAL-023/036; FR-028..030
FR-032	**Owning Customer:** Retrieve and reread Tutor-cancellation notices after marking them read; absence of automatic time-based expiry must hold, while deletion/retention governance remains undecided.	Q24/Q25	M / proposed S2	VAL-024; FR-031, OD-008
FR-033	**Server/Tutor:** Forbid direct edit, deletion or withdrawal of a Slot while it carries an Active Booking; require the separate authorized cancellation workflow first.	Q26	M / proposed S2	VAL-025; FR-004/028
FR-034	**Owning Tutor:** Withdraw an **unoccupied future** currently offered Slot while retaining its history; permit later creation of a distinct new Slot with a new ID that may overlap the withdrawn interval; reject reopening/reactivating the withdrawn historical Slot.	Q27/Q32	M / proposed S2	VAL-026/027; FR-005/033

5.5 Tutor-only reporting

ID	Actor and testable requirement, including safe failure	Source	Priority / sprint	Planned proof; dependency
FR-035	**Tutor:** Retrieve an Appointment Summary with **counts and corresponding lists** for Upcoming Booked, Past Booked and Cancelled on the Tutor's authorized schedule, calculated from stored Booking state and server time; in-progress classification remains OD-006.	Q31/Q30	M / proposed S3	VAL-028/029; FR-015/017/028
FR-036	**Server:** Deny Customers, anonymous callers and unrelated Tutors access to the Tutor-only summary and its linked Booking details; counts/lists must share the same visibility and classification criteria.	Q31/Q02	M / proposed S3	VAL-029/036; FR-004/035

6. Business rules

Each rule below is a normative **business outcome** sourced to a Q decision or an explicitly identified instructor minimum. The `VAL` column gives a planned check. Rule numbers follow **Q01-Q32** deliberately, making omitted stakeholder decisions detectable; BR-033..035 capture additional instructor/security and integrity constraints. These IDs are **new product IDs**, not replacements for the existing `BR-S1-*` IDs.

ID	Normative rule and boundary	Authority	Verification sprint / anchor
BR-001	One Slot reserves one exclusive **one-to-one** Customer/Tutor session; at most one Active Booking may claim it.	Q01	S1 / VAL-007/010

ID	Normative rule and boundary	Authority	Verification sprint / anchor
BR-002	Tutor = Staff and may manage or inspect **their own** authorized schedule; Customer = learner and may inspect only own private Booking data.	Q02	S1 / VAL-002/012
BR-003	Every Availability Slot has a duration of **exactly 60 minutes**.	Q03	S1 / VAL-003/004
BR-004	Tutor creates **individual explicit** Slots; no automatic recurrence or bulk Slot generation is authorized.	Q04	S1 / VAL-003
BR-005	For a new Booking, `SlotStart - authoritative server eligibility time >= 60 minutes`; equality is eligible, even if later commit succeeds after the check. A 59:59 remaining interval fails.	Q05; reviewed T_elig interpretation	S1 / VAL-008/009
BR-006	Two **currently offered** Slots of the **same Tutor** cannot overlap. Adjacent half-open intervals are permitted; different Tutors may independently offer the same time.	Q06	S1 / VAL-004/005
BR-007	Only the owning Customer may cancel an Active Booking at least **30 minutes** before Appointment start, including equality.	Q07	proposed S2 / VAL-015
BR-008	Successful Customer cancellation reopens the **original** Slot, but a future new Booking still independently requires BR-005.	Q08	proposed S2 / VAL-016
BR-009	Only the Booking-owning Customer may initiate its reschedule.	Q09	proposed S2 / VAL-017
BR-010	Reschedule's **original** Appointment must start at least 60 minutes after the authoritative decision; equality passes.	Q10	proposed S2 / VAL-018
BR-011	Reschedule's **destination** Slot must start at least 60 minutes after the authoritative decision; equality passes.	Q11	proposed S2 / VAL-018
BR-012	A valid Customer reschedule may move to another Tutor; original-Tutor-only restrictions are forbidden.	Q12	proposed S2 / VAL-019
BR-013	Reschedule is **all-or-nothing** across assignment, both Slot states and successful history. Failure leaves the previous Booking intact.	Q13	proposed S2 / VAL-020
BR-014	Successful reschedule reopens the original Slot, subject to independent new-Booking eligibility.	Q14	proposed S2 / VAL-020/016
BR-015	Successful reschedule keeps the **same Booking ID** and records old/new Tutor, Slot/time and change timestamp.	Q15	proposed S2 / VAL-020
BR-016	At most **one successful** reschedule per Booking; failures do **not** use that allowance.	Q16	proposed S2 / VAL-017/020
BR-017	Only the **currently authorized Tutor assigned to the Booking** may cancel it as Tutor.	Q17	proposed S2 / VAL-021
BR-018	Tutor cancellation requires Appointment start at least **60 minutes** after the authoritative decision, equality included.	Q18	proposed S2 / VAL-021

ID	Normative rule and boundary	Authority	Verification sprint / anchor
BR-019	Successful Tutor cancellation **withdraws** the original Slot; it must not reopen it.	Q19	proposed S2 / VAL-022
BR-020	Tutor cancellation requires a **meaningful nonblank reason**; an empty/whitespace-only input is invalid. Further textual-validation details require approval.	Q20	proposed S2 / VAL-021
BR-021	Each successful Tutor cancellation creates an in-app notice for the **affected owning Customer only**.	Q21	proposed S2 / VAL-023
BR-022	Tutor-cancellation reason is visible only to the **owning Customer**, not to other Customers or unrelated Tutors in accessible results.	Q22	proposed S2 / VAL-023/036
BR-023	That Customer sees the cancellation reason in both the **in-app notice** and **cancelled Booking detail**.	Q23	proposed S2 / VAL-023
BR-024	Reading a notification does not make it inaccessible; it remains available to reread.	Q24	proposed S2 / VAL-024
BR-025	Notifications do **not** expire automatically with elapsed time. This does not settle user/admin deletion, retention or privacy governance.	Q25	proposed S2 / VAL-024
BR-026	Tutor cannot directly edit, delete or withdraw a Slot with an **Active Booking**; the authorized Booking cancellation must occur first.	Q26	proposed S2 / VAL-025
BR-027	Tutor may withdraw an **own, unoccupied future Slot** and create a **separate new** Slot while preserving withdrawal history.	Q27	proposed S2 / VAL-026
BR-028	One Customer cannot have overlapping **Active Bookings** across any Tutors; **adjacent** appointments do not overlap.	Q28	S1 / VAL-004/011
BR-029	`Asia/Bangkok` (UTC+07:00) is the business timezone; authoritative time comes from the server, not a browser or user-supplied timestamp.	Q29	S1 / VAL-008/013
BR-030	Booking business states are `Booked` and `Cancelled`; `Past` is **derived from time**, not a third state or evidence of `Completed` /attendance.	Q30	S1 (Booked/Past), S2 (Cancelled) / VAL-013/015
BR-031	Only authorized Tutor gets Appointment Summary **counts and lists** for Upcoming Booked, Past Booked and Cancelled. Customer gets no Tutor-only summary.	Q31	proposed S3 / VAL-028/029
BR-032	Historical **withdrawn** Slots do not block a new separate overlapping offer; they are **not reactivated under the same historical Slot ID**.	Q32	proposed S2 / VAL-027
BR-033	Protected actions require server-enforced authenticated role/ownership checks; anonymous, foreign-record and cross-role operations cannot gain private data or mutation rights.	GW §5.2; Theme 1	S1 and extensions / VAL-001/002/036
BR-034	Accepted Booking/Slot mutations commit an internally consistent outcome; rejected validations, contention and persistence failures cannot leave partially claimed Slots, duplicate active reservations or false success. The precise locking/constraint scheme is not selected here.	GW §5.1/Theme 1; Q01/Q06/Q28 outcome	S1 and extensions / VAL-005/010/011/014/020

ID	Normative rule and boundary	Authority	Verification sprint / anchor
BR-035	Invalid or nonfuture Slot proposals and attempts to book past, occupied or ineligible offers are rejected without changing committed records; rules beyond confirmed time policies cannot be fabricated.	GW Theme 1; Q03/Q05/Q29	S1 / VAL-004/006/014

Interval rule: `[startA, endA)` overlaps `[startB, endB)` exactly when `startA < endB && startB < endA`. If A ends at 14:00 and B begins at 14:00, then `startB < endA` is false. Consequently, the appointment intervals are adjacent rather than conflicting. This comparison governs BR-006 and BR-028; other validity and cutoff rules still apply.

Rule interactions that need separate checks: A Slot reopened 30 minutes before a session by Customer cancellation is offered again under BR-008, yet BR-005 prevents a new Booking inside its 60-minute cutoff. Tutor cancellation takes the opposite path: BR-019 withdraws the Slot and BR-032 allows a later **separate** overlapping offer. A successful reschedule releases only its original Slot, claims the destination and preserves its Booking identity in **one** transaction; a failed reschedule consumes neither the destination nor the one-success allowance.

7. Non-functional requirements

The following targets separate **required outcomes** from **proposed quantification**. Where a metric is unapproved, the measurement describes a candidate acceptance gate, not a claim that the system already meets it. A quality attribute without an invented availability or performance promise can still have a concrete correctness inspection.

ID	Attribute and requirement / measured target	Source and approval status	Planned check; sprint / approval owner
NFR-001	**Authorization:** every enumerated anonymous, forbidden-role, foreign-Customer and foreign-Tutor protected API path must reject or filter without private payload disclosure. Measure zero unauthorized record disclosure in seeded negative cases.	**Required outcome**, GW §5.2/Q02	VAL-002/036; S1-S3; backend/peer review
NFR-002	**Credential security:** with locally managed passwords, store adaptive salted hashes, not plaintext; tracked repository content contains no real credentials. Verify using test DB inspection and secret/config review.	**Required**, GW §5.2	VAL-034; S1; auth contract
NFR-003	**Durability:** an accepted Slot/Booking and its authorized view must persist after browser refresh and application-process restart against the same data store; no in-memory-only persistence.	**Required**, GW §5.1/D1 §2	VAL-007/031; S1, regression S2/S3
NFR-004	**Concurrent conflict integrity:** all three real-DB races must preserve BR-001/006/028, regardless of interleaving; a 20-attempt same-Slot stress burst and a 10-attempt same-Customer burst are **proposed test sizes**, not approved business capacity limits.	Outcome **required**; run sizes **PROPOSED**, baseline NFR-S1-04/05	VAL-005/010/011; S1; size via OD-010

ID	Attribute and requirement / measured target	Source and approval status	Planned check; sprint / approval owner
NFR-005	**Atomic consistency:** accepted cancellation/reschedule/Booking/withdrawal changes all required records together; deliberate persistence failures leave the prior committed state and no false confirmation.	**Required outcome**, Q13/Q19 and Theme 1 integrity	VAL-014/020/022; S1/S2
NFR-006	**Time correctness:** cutoff checks use server-authoritative instants; accept exact 60:00 or 30:00 boundaries as applicable, reject just-below; Bangkok calendar/hour remains stable for a non-Bangkok browser.	**Required**, Q05/Q07/Q10/Q11/Q18/Q29	VAL-008/009/013/015/018/021; S1/S2
NFR-007	**Data minimization:** protected Booking, reason, notification and report responses do not expose third-party identity, cancellation reason, credentials or arbitrary private schedule fields. Review response bodies and negative payloads, not UI controls only.	**Required**, Q02/Q21-Q23/Q31, GW §5.2	VAL-023/029/036; S1-S3
NFR-008	**Retry safety:** repeated/uncertain-response requests cannot violate exclusivity, successful reschedule quota or atomic history. Whether retries return the original success response and any token format/retention are open.	Invariant **required**; protocol **OPEN**	VAL-030/020; S1/S2; OD-013
NFR-009	**Keyboard usability (PROPOSED):** complete login, availability, Booking and own-detail flows by keyboard with visible focus on primary controls; record manual checklist, browser and failures.	**PROPOSED**, baseline NFR-S1-09, not stakeholder-approved	VAL-033; candidate S1/S3; OD-010, @Tanaboonnnnn/@Chxtamos
NFR-010	**Local response time (PROPOSED):** p95 availability and own-Booking-detail requests at or below **2.0 s**, each measured over at least **50** warm-up-excluded requests with documented hardware, fixture size and database.	**PROPOSED**, baseline NFR-S1-10, not instructor-approved	VAL-032; candidate S1/S3; OD-010, team review
NFR-011	**Change traceability:** each implemented requirement must identify source Q/GW/D1, accountable feature/Issue, reviewed contract, planned verification and release evidence; changes to Q rules need recorded stakeholder approval.	**Required process**, D1 Parts A-E / AGENTS.md	VAL-031, document/PR inspection; S1-S3
NFR-012	**Reproducibility:** engineering evidence must identify code version, environment/setup, DB/seed preparation, test commands and real pass/fail/skip results; mere presence of tests is not a pass.	**Required process**, GW §5.3, D1	VAL-031; S1-S3
NFR-013	**Deployment readiness:** the selected architecture must support container packaging and durable GCP deployment, with build/tests on relevant PRs and repeatable accepted release from `main` after Lab 5. No cloud success is asserted at D1.	**Required later**, GW §§5.1/5.3; Lab 5	VAL-035; Lab 5 and later; separate Issues

ID	Attribute and requirement / measured target	Source and approval status	Planned check; sprint / approval owner
NFR-014	**Notice durability:** a Tutor-cancellation notice remains retrievable after being read and is not removed solely by age; additional retention/deletion rights await owner decision.	**Required**, Q24/Q25	VAL-024; proposed S2, OD-008
NFR-015	**Safe diagnostics:** response errors expose no credentials, session tokens, protected reason or internal stack traces; operational logs must avoid secrets and preserve enough non-sensitive context to investigate failed mutations. Exact logging fields/retention are engineering decisions.	Security outcome **required** by GW §5.2; logging structure **PROPOSED**	VAL-034/036; S1-S3; OD-005/008
NFR-016	**Reporting correctness:** for every defined Tutor Summary category, count must equal its corresponding accessible row set under the same time/state predicates; no completion is inferred from elapsed time. Treatment of in-progress sessions remains open.	**Required**, Q30/Q31	VAL-028/029; proposed S3, OD-006/009

Approval rule: Do not copy `NFR-009` or `NFR-010` into a feature's final acceptance contract as a mandatory threshold until the product decision owner and peer reviewer approve it, including environment and workload. No uptime SLA, password complexity number, request-rate limit, backup frequency, pagination size or retention period has been approved by Q01-Q32.

8. Authorization and privacy

Server authorization is authoritative. The role in an authenticated principal, the actual Booking owner and the Tutor assigned to the relevant Slot/Booking determine access. URL parameters, browser state, hidden buttons or a submitted `customerId` / `tutorId` are not an authorization grant.

Legend: **Own** means only records owned/assigned under the stated condition; **Deny** means protected access is forbidden; **N/A** means no product-level action is assigned to that role. Login at the anonymous boundary requires valid credentials, not a public session. S2/S3 actions are **planned**, not present in Sprint 1.

Operation / protected view	Anonymous	Customer	Tutor (Staff)	Planned sprint
Open login / submit valid credentials	Login only	Login	Login	S1
View current authenticated identity	Deny	Own	Own	S1
Logout current session	N/A	Own	Own	S1
Create explicit Slot	Deny	Deny	**Own schedule**	S1
Inspect offered/occupied Tutor schedule	Deny	Deny	**Own schedule**	S1
Discover customer-facing availability	No public policy approved	Authenticated offers, privacy-filtered	N/A as Customer workflow	S1

Operation / protected view	Anonymous	Customer	Tutor (Staff)	Planned sprint
Create new Booking	Deny	**Own identity**, eligible Slot	Deny under Tutor authority	S1
Retrieve Customer Booking list/detail	Deny	**Owned Bookings only**	No global Customer query	S1
Retrieve Tutor Booking schedule	Deny	Deny	**Currently authorized Tutor schedule only**	S1
Cancel a Customer Booking	Deny	**Owning Customer**, Q07 cutoff	Deny via Customer route	S2
Reschedule Booking	Deny	**Owning Customer**, quota and both cutoffs	Deny	S2
Cancel a Booking as Tutor	Deny	Deny	**Currently assigned Tutor**, cutoff + reason	S2
Direct edit/delete/withdraw occupied Slot	Deny	Deny	**Deny while Active Booking exists**	S2
Withdraw unoccupied future offered Slot	Deny	Deny	**Own Slot**	S2
Read Tutor-cancellation notification	Deny	**Notice addressee only**	Deny	S2
Read Tutor-cancellation reason in notice/detail	Deny	**Owning Customer only**	No read authority inferred from Tutor role	S2
View Appointment Summary counts/lists	Deny	Deny	**Own authorized Tutor summary only**	S3
Read another Customer's or another Tutor's restricted records	Deny	Deny	Deny	All

8.1 Protected response and mutation boundaries

- **Customer availability:** sufficient non-sensitive Tutor label/identifier and Slot start/end to make a selection; do not include another Customer's Booking, contact information, cancellation reason or restricted schedule data. Exact field names, availability visibility and sorting are pending OD-004.
- **Customer's own Booking:** stable Booking ID, relevant Tutor and current appointment interval, business status, plus authorized history and reason only when applicable. Do not expose another learner's Booking through direct IDs, searches, pagination or error responses.
- **Tutor's schedule:** current Tutor's permitted Slot/Booking facts. The precise Customer identity representation shown to a Tutor is an unapproved minimum-field decision; it must be justified and bounded in the API/UI contracts. Reschedule-history visibility for prior Tutors, if any, is unresolved and cannot create global access.
- **Cancellation notice:** only the targeted Customer sees its contents; the reason is present in that Customer's cancelled Booking detail. Read state is separate from deletion or automatic expiry. No consent is implied to broadcast reasons to other Tutors or Customers.
- **Write authorization:** Booking owner comes from the authenticated Customer, Tutor ownership from the actual Slot and currently assigned Booking, and cancellation/reschedule eligibility from server state. Any failed

authentication or ownership check must precede protected detail disclosure.

- **Error safety:** choose precise 401/403/404 behavior, conflict codes and error fields in separate feature API contracts; whatever the choice, rejected access must disclose no protected information. Never use a success response for an uncommitted write.

9. Logical domain and lifecycle

The following is a **logical requirements model**, not a relational schema, migration design or API DTO. Detailed entity fields, keys, constraints, indexing, locking and storage implementation are assigned to Issue #11 and subsequent Feature SDS.

Concept	Required logical information and relationships	Invariants / lifecycle
Authenticated user	Stable identity, effective role Customer or Tutor; session lifecycle	Identity is server-trusted; a principal cannot gain another role through submitted IDs
Tutor schedule	Association of one Tutor with their own Slots and associated authorized Bookings	Cross-Tutor reads/writes restricted; current offer list differs from withdrawal history
Availability Slot	Stable Slot identity, Tutor owner, scheduled start/end, currently offered or withdrawn historical meaning, occupancy relationship	Exactly 60 minutes; one Tutor per Slot; currently offered same-Tutor Slots cannot overlap; withdrawn ID not reactivated
Booking	Stable Booking identity, owning Customer, **current** Slot/Tutor assignment, scheduled interval and `Booked` or `Cancelled` status	At most one Active Booking per Slot; one Customer cannot hold overlapping Active Bookings; identity survives reschedule
Successful reschedule history	One record per successful change, including Booking ID, old/new Tutor and Slot/interval, server change timestamp	At most one successful entry per Booking under Q16; a rejected attempt does not produce a successful entry
Cancellation reason	Meaningful nonblank reason supplied on Tutor cancellation and associated with its Booking	Owning Customer sees it in notice and cancelled Booking detail; unauthorized callers never see it
In-app notification	Owner Customer, related Tutor-cancelled Booking, private message/reason and read-state meaning	Remains accessible when read; no automatic age expiry; deletion/retention rules open
Historical withdrawn Slot	Former Slot identity, Tutor, original interval and withdrawn status/history	Not a current offer; does not block new separate overlapping offers; never reactivated under same Slot ID
Tutor Appointment Summary	Authorized Tutor scope and derived categories: Upcoming Booked, Past Booked, Cancelled	Counts equal corresponding lists; no global Customer view; in-progress category pending

9.1 Booking state and Slot lifecycle

The only agreed **Booking business states** are `Booked` and `Cancelled` (Q30).

1. **New Booking success:** eligible Slot becomes occupied and a Booking is created in `Booked`. Failure creates no Booking or occupied change.
2. **Customer cancellation:** `Booked → Cancelled` for an authorized owner at the 30-minute cutoff; original Slot becomes a currently offered unoccupied Slot (Q07-Q08).

3. **Customer reschedule:** Booking **remains** `Booked` and retains its ID; the assignment moves atomically to the destination; original Slot reopens and successful history is appended (Q09-Q16).
4. **Tutor cancellation:** `Booked → Cancelled` for the currently assigned authorized Tutor at the 60-minute cutoff, requiring reason; original Slot is **withdrawn**, and the private notification is created (Q17-Q25).
5. **Tutor withdrawal without Booking:** offered unoccupied future Slot becomes historical withdrawn; a **new Slot**, with a distinct ID, may subsequently be offered (Q26-Q27/Q32).
6. **Elapsed time:** past the appointment **end**, the display may derive `Past`; `Booked` remains `Booked`. There is no `Completed`, `Attended`, `No-show`, auto-cancel or implied auto-release transition.

An active Booking is one still in `Booked`, **even if the lesson's end is past**. This protects historical consistency and prevents inappropriate automatic release. State transition details at time boundaries and unsupported repeated cancellation attempts require explicit negative validation. Which cancellation actor performed a `Cancelled` transition and the historical detail available to each role must be represented without assuming an additional business state.

9.2 Cardinality and conservation obligations

- One Slot has one owning Tutor and is attached to **at most one Active Booking** at a given time; one Customer may have multiple Bookings only when none of the Active intervals overlap.
- A successful reschedule conserves **one Booking ID** while moving its *current* appointment link. Old/new links remain in history rather than becoming two live Bookings.
- Customer cancellation preserves the Slot as a potentially available offer. Tutor cancellation preserves the Slot **as withdrawn history**. These outcomes are intentionally different.
- Failed cancellation, reschedule, creation or Booking cannot leave part of the change committed, including premature notification creation, wrong successful-reschedule count or incorrect occupancy.
- Reports are projections of the authoritative logical entities; a report count cannot independently redefine Booking state, ownership or elapsed-time semantics.

10. Time, conflicts and concurrency

10.1 One timezone and explicit inequalities

All user-visible appointment times use `Asia/Bangkok` (UTC+07:00). The server controls the clock used for acceptance checks. Persisted instants and transport representation are engineering choices, but must preserve this business meaning independent of the client's timezone, locale and clock skew.

Let `S` be the relevant appointment or Slot start instant and `T` the authoritative server instant at the applicable guarded decision point. Equality at each confirmed cutoff **passes**, if all other rules pass.

Action	Confirmed eligibility formula	Example for 15:00 start (Bangkok)	Primary source
New Booking	`S - T_elig >= 60 min`	`14:00:00` eligible; `14:00:01` too late	Q05; BR-005
Customer cancellation	`S - T >= 30 min`	`14:30:00` eligible; `14:30:01` too late	Q07; BR-007
Reschedule old Appointment	`OldStart - T >= 60 min`	Old `15:00`; `14:00:00` eligible	Q10; BR-010

Action	Confirmed eligibility formula	Example for 15:00 start (Bangkok)	Primary source
Reschedule destination	`NewStart - T >= 60 min`	Destination `15:00`; `14:00:01` too late	Q11; BR-011
Tutor cancellation	`S - T >= 60 min`	`14:00:00` eligible; `14:00:01` too late	Q18; BR-018
Tutor Slot creation	Start must be valid and in future; **no Q05 new-Booking cutoff imposed**	Future valid start; further scheduling grid/hours/horizon open	Q03/Q04; Theme 1; OD-001..003

New-Booking precision (`T_elig`): The reviewed Sprint 1 baseline defines a single server-authoritative time sampled **inside the transaction after contention waits and immediately before final guarded validation/write**. An HTTP request for a 15:00 Slot may arrive at 13:59:59 yet wait until `T_elig=14:00:01`; it must be denied. If `T_elig=14:00:00`, a later commit timestamp alone does not invalidate the previously valid guarded check. This is an **engineering interpretation** for review, not permission to weaken Q05 or ignore other checks. The Feature SDS must confirm the actual transaction/time-control design and tests (AC-S1-35, VC/TEST-S1-39).

For **later** cancellation/rescheduling cutoffs, Q07/Q10/Q11/Q18 settle the numerical boundary and server-clock authority through Q29; the exact transactional sampling order, lock behavior and retry handling must still be set in their Feature SDS. Using the same final-guard pattern as `T_elig` is a **proposal** for consistent implementation, not an independently confirmed stakeholder Q decision.

10.2 Half-open overlap and Current versus Historical

Two intervals intersect iff `a.start < b.end && b.start < a.end`. Exact adjacency (`a.end = b.start`) is allowed under BR-006 and BR-028. Partial overlap by even one positive-duration instant is prohibited for same-Tutor currently offered Slots and the same Customer's Active Bookings.

A **withdrawn historical** Slot must be excluded from the set of current offers checked against new Slot creation. This does **not** exempt a current occupied offer from same-Tutor overlap rules, and it does not mean an old historical Slot may be reactivated. Different Tutors' offered intervals may coincide; **one Customer** still cannot reserve overlapping intervals across them.

10.3 Three mandatory race proofs

Hazard	Simultaneous operation	Required final committed state	Planned contract/test
Race A: Tutor current offers	Same Tutor creates two partially overlapping 60-minute offered Slots	At most one of the conflicting offers remains current; loser has no partial Slot. If different Tutors create same time, both can be valid.	Slot contract, VAL-005; baseline AC-S1-13 / VC-S1-37
Race B: exclusive Slot	Two distinct Customers attempt the same eligible Slot	At most one Active Booking occupies that Slot. No second success or orphan occupancy.	Booking contract, VAL-010; baseline AC-S1-25 / VC-S1-25
Race C: Customer across Tutors	One Customer simultaneously requests two distinct overlapping offers from different Tutors	At most one conflicting Active Booking commits for that Customer, despite each Slot being individually free.	Booking contract, VAL-011; baseline AC-S1-26 / VC-S1-26

For all three, controlled concurrency tests must start requests under actual overlap/interleaving and inspect **committed database state**, not only returned HTTP codes or disabled frontend controls. The System/Feature SDS

must choose an isolation/locking/constraint strategy that enforces these outcomes for every write path. No particular SQL lock, ORM, idempotency key or isolation level is approved by this SRS.

10.4 Atomic change, stale reads and uncertain responses

- A stale availability view cannot reserve or grandfather an occupied/withdrawn/too-soon Slot. The server checks current state at the final write guard, and a rejected request changes no Booking or Slot relationship.
- A duplicate click, network retry or unknown response after a possible commit must preserve the invariants. Returning an existing success versus a conflict is an **unresolved transport/idempotency decision** (OD-013).
- A failed Customer cancellation leaves `Booked` and occupancy unchanged; a successful cancellation reopens the same Slot. A failed Tutor cancellation must not leave the Slot withdrawn or a false private notice.
- A failed reschedule leaves the original Booking assignment and its Slot occupied, destination unoccupied, no success history and the one-success quota unconsumed. This also holds when destination is taken concurrently.
- Under a lost database write or rollback, no client may be told a reservation/change succeeded unless the corresponding complete state committed. Exact error vocabulary and reconciliation behavior belong to the later design contracts.

11. Exception and boundary scenarios

This is a requirements-level outcome matrix. `VAL` cases are **planned**, and actual fixtures, HTTP status codes and test files are owned by later STS/implementation Issues.

Scenario	Trigger / precondition	Observable required outcome	Governing rules; planned check
Invalid Slot start/duration	Missing, malformed, past or non-sixty-minute proposed offer	No invalid Slot, no changed existing offer	BR-003/035; VAL-003/004
Same Tutor overlap	Existing 13:00-14:00 current offer; proposed 13:30-14:30	Reject proposed Slot; original preserved	BR-006; VAL-004
Slot adjacency	Existing 13:00-14:00; proposed 14:00-15:00	Adjacency itself does not reject otherwise-valid offer	BR-006; VAL-004
Cross-Tutor offers	Tutors A/B each create 13:00-14:00	Both current offers allowed if each independently valid	BR-006; VAL-004
Unauthorized Slot write	Customer or Tutor B targets Tutor A's schedule	No change to Tutor A's offers; no protected disclosure	BR-002/033; VAL-002
Anonymous Booking	Caller lacks session	No Booking or protected data	BR-033; VAL-002
Foreign Customer Booking	Customer B guesses A's Booking ID	No private details or related notification/reason exposed	BR-002/022/033; VAL-002/036
Foreign Tutor schedule	Tutor B guesses Tutor A's schedule/Booking ID	No foreign schedule or private Booking disclosed	BR-002/033; VAL-002
Too-soon new Booking	Slot at 15:00; `T_elig=14:00:01`	Reject without occupation	BR-005; VAL-008
Exact new-Booking boundary	Slot at 15:00; `T_elig=14:00:00`	Lead-time rule passes, subject to all other guards	BR-005; VAL-008

Scenario	Trigger / precondition	Observable required outcome	Governing rules; planned check
Cutoff crossed while waiting	HTTP arrives 13:59:59; final `T_elig=14:00:01`	Reject, regardless of early HTTP arrival	BR-005/034; VAL-009
Occupied Slot/stale list	Availability was earlier displayed, but now occupied/withdrawn	No duplicate or false Booking; view reconciles	BR-001/034; VAL-006/014
Same Customer across Tutors	Active 13:00-14:00, candidate 13:30-14:30	Reject overlapping Booking	BR-028; VAL-011
Adjacent Customer appointment	Active ends 14:00; proposed begins 14:00	Overlap rule permits; independent lead-time applies	BR-028/005; VAL-004/011
Race A	Concurrent same-Tutor overlapping Slot creation	At most one conflicting offer committed	BR-006/034; VAL-005
Race B	Two Customers, one Slot concurrently	At most one Active claim committed	BR-001/034; VAL-010
Race C	One Customer, overlapping Tutor Slots concurrently	No two overlapping Active bookings commit	BR-028/034; VAL-011
Fault during Booking persistence	Failure before transaction completion	No phantom success, partial Booking or inconsistent occupation	BR-034; VAL-014
Customer cancellation at cutoff	At `start - 30:00` versus just after	Equality eligible; just-after denied, no partial state	BR-007; VAL-015
Reopened Slot inside booking cutoff	Customer cancels 30 minutes before start	Original Slot reopened, but new Booking at fewer than 60 minutes rejected	BR-008/005; VAL-016
Reschedule wrong owner / quota	Foreign Customer or already one success	Reject, old Booking and history unchanged	BR-009/016; VAL-017
Reschedule original/destination cutoffs	Old or destination starts at `T + 59:59`	Reject even if other start qualifies; exact `T + 60:00` eligible	BR-010/011; VAL-018
Reschedule across Tutors	Valid new Tutor offered Slot	Accept; same Booking ID, new Tutor/Slot, old Slot reopened	BR-012..015; VAL-019/020
Reschedule failure/rollback	Destination occupied, transaction fault, collision or late boundary	No partial move, lost reservation, false history or consumed quota	BR-013/016; VAL-020
Tutor cancellation cutoff/ownership	Wrong assigned Tutor, `start - 59:59`, or exact 60:00	Wrong/late denied; exact boundary eligible with valid reason	BR-017/018; VAL-021
Missing Tutor cancellation reason	Empty, whitespace-only or meaninglessly empty reason	No cancellation/withdrawal/notice	BR-020; VAL-021
Tutor cancellation state	Valid cancellation reason and cutoff	Booking Cancelled, original Slot withdrawn **not reopened**, private notice created	BR-019/021; VAL-022/023
Notification privacy/re-read	Wrong Customer reads; owner reads twice	Wrong reader denied; owner sees reason and may reopen read notice	BR-021..025; VAL-023/024

Scenario	Trigger / precondition	Observable required outcome	Governing rules; planned check
Direct occupied Slot change	Tutor edits/deletes/withdraws own Slot with Active Booking	Deny direct change until authorized Booking cancellation	BR-026; VAL-025
Historical withdrawn overlap	Tutor withdraws unoccupied future 13:00-14:00 then creates new 13:00-14:00 offer	New distinct ID allowed; old history preserved; old ID not reactivated	BR-027/032; VAL-026/027
Summary and protected counts	Tutor requests own categories; Customer or foreign Tutor requests same	Authorized counts equal lists; unauthorized gets no report	BR-030/031; VAL-028/029
Browser outside Bangkok	UTC/other-zone device displays Slot and sends operation	Same intended Bangkok hour and cutoff evaluation; server time wins	BR-029; VAL-013
Booking ended	Now after appointment end; no cancellation	`Past` may appear, `Booked` persists; no Completed/attendance or auto-release	BR-030; VAL-013

12. Source and requirement traceability

12.1 Provenance and audit rules

The tables below are **self-contained Part A coverage evidence**; they are **not** the separate Deliverable 1 Part B feature inventory or `docs/traceability.md` assigned to Issue #10.

- **SRC-Q:** stakeholder discovery decisions Q01-Q32 as recorded in the already reviewed/merged Sprint 1 requirements source; each row below is marked **Confirmed stakeholder baseline**, not independently instructor-approved.
- **SRC-GW-v1:** `group_work_specs_v1.pdf`, issued 6 October 2026, explicitly **Draft for instructor review**. Requirements drawn from it may need delta review against the missing final Master.
- **SRC-D1-v1:** `project_deliverable_1_v1.pdf`, due 8 November 2026; inspected from the supplied project archive.
- **SRC-S1:** `docs/requirements.md` as present on the `sprint1` baseline after merged PR #7; retains the original FR/BR/NFR/AC/VC naming.
- **SRC-AGENT:** repository root `AGENTS.md` merged through PR #20; this governs workflow, not new product behavior.

Coverage criterion: every Q decision has a product rule, an appropriate FR or NFR, a planned verification and proposed delivery sprint. An unapproved additional policy is listed in Section 13, not silently inserted into a Q row. At the requirements-writing stage, `VAL` is a test **plan**, not executed validation.

12.2 Stakeholder Q01-Q32 decision coverage audit

Every decision in this table has approval state **Confirmed in stakeholder discovery baseline**. The current document, final instructor source and engineering contract have **not** yet received their own approval. Some decisions were confirmed for the **product** but are scheduled in a **proposed** future sprint.

Q	Confirmed meaning (condensed without changing boundary)	Product FR / BR / applicable NFR	Target verification sprint	Planned evidence
Q01	Exclusive one-Customer/one-Tutor session	FR-010/012; BR-001; NFR-004	S1	VAL-007/010
Q02	Tutor = Staff, Customer = learner, schedule/Booking ownership	FR-004/007/014/015; BR-002; NFR-001	S1	VAL-002/012
Q03	Slot lasts exactly 60 minutes	FR-005/006; BR-003	S1	VAL-003/004
Q04	Tutor creates Slots individually, without bulk/recurrence	FR-005; BR-004	S1	VAL-003
Q05	New Booking at least 60 minutes ahead; equality eligible	FR-009/011; BR-005; NFR-006	S1	VAL-008/009
Q06	Same-Tutor current offered Slot non-overlap, adjacency valid	FR-006; BR-006; NFR-004	S1	VAL-004/005
Q07	Only owner Customer cancels at least 30 minutes ahead	FR-020; BR-007; NFR-006	proposed S2	VAL-015
Q08	Customer cancellation reopens original Slot, Q05 still applies	FR-021; BR-008	proposed S2	VAL-016
Q09	Only owning Customer initiates reschedule	FR-022; BR-009	proposed S2	VAL-017
Q10	Original appointment at least 60 minutes ahead to reschedule	FR-023; BR-010; NFR-006	proposed S2	VAL-018
Q11	Destination Slot at least 60 minutes ahead	FR-023; BR-011; NFR-006	proposed S2	VAL-018
Q12	Cross-Tutor reschedule allowed	FR-024; BR-012	proposed S2	VAL-019
Q13	Reschedule atomic/all-or-nothing	FR-025; BR-013; NFR-005	proposed S2	VAL-020
Q14	Reschedule reopens old Slot	FR-025; BR-014	proposed S2	VAL-020
Q15	Same Booking ID; successful old/new Tutor, Slot/time, timestamp history	FR-026; BR-015	proposed S2	VAL-020
Q16	One successful reschedule max; failures do not consume quota	FR-027; BR-016; NFR-008	proposed S2	VAL-017/020
Q17	Only currently assigned authorized Tutor cancels	FR-028; BR-017; NFR-001	proposed S2	VAL-021
Q18	Tutor cancellation at least 60 minutes ahead	FR-028; BR-018; NFR-006	proposed S2	VAL-021
Q19	Tutor cancellation withdraws original Slot, does not reopen	FR-030; BR-019; NFR-005	proposed S2	VAL-022
Q20	Tutor cancellation reason meaningful and nonblank	FR-029; BR-020	proposed S2	VAL-021
Q21	Tutor cancellation creates in-app notice only for owning Customer	FR-031; BR-021; NFR-007	proposed S2	VAL-023

Q	Confirmed meaning (condensed without changing boundary)	Product FR / BR / applicable NFR	Target verification sprint	Planned evidence
Q22	Reason visible only to affected owning Customer	FR-031; BR-022; NFR-007	proposed S2	VAL-023/036
Q23	Reason in both private notice and cancelled Booking detail	FR-031; BR-023; NFR-007	proposed S2	VAL-023
Q24	Read notice remains accessible	FR-032; BR-024; NFR-014	proposed S2	VAL-024
Q25	No automatic time-based notice expiry; other retention open	FR-032; BR-025; NFR-014	proposed S2	VAL-024
Q26	Active Booking blocks direct Slot edit/delete/withdrawal	FR-033; BR-026	proposed S2	VAL-025
Q27	Tutor withdraws own unoccupied future Slot, recreates separate Slot; history retained	FR-034; BR-027	proposed S2	VAL-026
Q28	One Customer's Active Bookings never overlap across Tutors; adjacency allowed	FR-013; BR-028; NFR-004	S1	VAL-004/011
Q29	Bangkok timezone, server-authoritative clock	FR-011/017; BR-029; NFR-006	S1	VAL-008/013
Q30	States Booked/Cancelled; Past derived and not Completed	FR-017/035; BR-030; NFR-016	S1 (Booked/Past), S2 (Cancelled), S3 (report)	VAL-013/015/028
Q31	Tutor-only summary with Upcoming Booked/Past Booked/Cancelled counts and lists	FR-035/036; BR-031; NFR-016	proposed S3	VAL-028/029
Q32	Withdrawn history does not block separate overlap or permit same-ID reactivation	FR-034; BR-032	proposed S2	VAL-027

Audit result at drafting: Q01-Q32 are each accounted for in a distinct row, with an authorized meaning and planned validation. No Q decision is excluded from the whole-product baseline. Formal source approval and code/test completion remain separate gates.

12.3 Available instructor requirements to SRS mapping

Instructor-draft source	Requirement actually stated in examined handout	Whole-product mapping	Earliest planned verification	Source status
GW v1 §5.1	Working UI → application/API → persistent DB, meaningful domain transaction, restart durability	FR-016/019; NFR-003; BR-034	S1: VAL-007/031	**Draft; final master not checked**
GW v1 §5.2	Real login, logout, current identity, session lifecycle, two roles	FR-001..004; NFR-002	S1: VAL-001/034	**Draft; final master not checked**
GW v1 §5.2 / Theme 1	Customer own Booking only, Tutor authorized schedule, backend role checks	FR-004/007/014/015; BR-002/033; NFR-001/007	S1: VAL-002/012/036	**Draft; final master not checked**

Instructor-draft source	Requirement actually stated in examined handout	Whole-product mapping	Earliest planned verification	Source status
GW v1 §6 Theme 1	Staff creates Slot, Customer views/Books/retrieves; reject occupied/past/invalid; competing single-Slot claims	FR-005..016; BR-001/035; NFR-004/005	S1: VAL-003..014	**Draft; eligibility not checked**
GW v1 §6 Theme 1	Complete product cancellation/rescheduling, schedule administration, appointment reporting	FR-020..036; BR-007..027/031/032	proposed S2/S3: VAL-015..029	**Draft; combined with Q decisions**
GW v1 §5.3	Reviewed GitHub workflow, automated PR build/test and later Docker/GCP delivery	NFR-011/012/013	S1 contract/review VAL-031; Lab 5 VAL-035	**Draft; separate engineering Issues**
D1 v1 §§3.1-3.4	Whole-product SRS with FR/BR/NFR, measurable verification and 3-sprint allocation	Document §§0-18; NFR-011/012	Part A document inspection; later Parts B-D	**Version examined; master cross-check pending**

No line in the available handouts prescribes a tutoring price, service modality, weekday hours, maximum scheduling horizon, minute increment, performance p95 or automatic attendance state. Adding such a constraint would require an explicit source or approved decision.

12.4 Sprint 1 baseline ID crosswalk and consistency

The original `docs/requirements.md` is a **Sprint 1 document** and retains all its IDs. The product-level IDs in this SRS are new identifiers and do not rewrite or renumber the source. The old file's header documents its initial draft stage; GitHub PR #7 is now **merged**, as verified from PR history. The single approved surgical correction in Issue #9 updates its §16.1 AC range to `AC-S1-01..35`; `AC-S1-35` itself already exists in that file and maps to `VC/TEST-S1-39`.

FR crosswalk: the meanings of `FR-S1-01..19` correspond **in order** to `FR-001..019`. Specifically:

Sprint 1 IDs	Whole-product IDs	Requirement group
FR-S1-01..04	FR-001..004	Login, identity, logout, backend authorization
FR-S1-05..07	FR-005..007	Tutor Slot creation, validity/overlap, own schedule
FR-S1-08..09	FR-008..009	Customer availability and bookability
FR-S1-10..13	FR-010..013	Booking, cutoff, exclusive claim, Customer overlap
FR-S1-14..17	FR-014..017	Private reads, persistence and Booked/Past
FR-S1-18..19	FR-018..019	Failure handling and full-stack vertical slice

BR crosswalk: the Sprint 1 source sometimes separates one Q rule into several narrower guards. These remain distinct IDs in that document.

Baseline BR-S1	Product BR	Baseline BR-S1	Product BR
01	BR-001	12	BR-029
02	BR-003	13	BR-005/034 (T_elig interpretation)

Baseline BR-S1	Product BR	Baseline BR-S1	Product BR
03	BR-004	14	BR-030
04	BR-002	15	BR-002
05	BR-006	16	BR-002
06	BR-006	17	BR-033
07	BR-005	18	BR-034
08	BR-001	19	BR-001/028/034
09	BR-028	20	BR-002/033
10	BR-028	21	BR-005/034
11	BR-035	22	BR-030

NFR crosswalk: the first number below is the original Sprint 1 suffix; proposed versus required status must carry forward unchanged.

Baseline NFR-S1	Product NFR	Baseline NFR-S1	Product NFR
01	NFR-001/007	07	NFR-012
02	NFR-002	08	NFR-007/015
03	NFR-003	09	NFR-009 (**PROPOSED**)
04	NFR-004 (stress size proposed)	10	NFR-010 (**PROPOSED**)
05	NFR-004 (stress size proposed)	11	NFR-005
06	NFR-006	12	NFR-011

Existing AC and validation anchors (not duplicated as a Part E STS):

Existing Sprint 1 evidence anchor	Product verification and meaning
AC-S1-01..07; VC/TEST-S1-01..07	VAL-001/002; login, identity, logout, authorization
AC-S1-08..14; VC/TEST-S1-08..14, 37	VAL-003..005/013; Slot duration, ownership, overlap and Race A
AC-S1-15..18; VC/TEST-S1-13/15/22	VAL-006/013; availability, privacy, stale view
AC-S1-19..24; VC/TEST-S1-16..24	VAL-007/008/011; Booking, lead-time and overlap
AC-S1-25; VC/TEST-S1-25	VAL-010; Race B
AC-S1-26; VC/TEST-S1-26	VAL-011; Race C
AC-S1-27..29; VC/TEST-S1-22/27/33/38	VAL-014/030; rollback, conflict, duplicates
AC-S1-30..34; VC/TEST-S1-28..32	VAL-012/013; owned reads, Tutor visibility and Past
AC-S1-35; VC/TEST-S1-39	**VAL-009; booking request crossing cutoff while waiting**

Existing Sprint 1 evidence anchor	Product verification and meaning
VC/TEST-S1-34..36	VAL-031/032/033/034; planned reproducibility, security, UX and performance checks

All `AC-S1-01..35` and `VC-S1-01..39` / `TEST-S1-01..39` remain owned by the original baseline; references here are cross-references, not redefinitions or claims that test code exists.

13. Open decisions and approval gates

This register is the **explicit home for uncertainty**. A proposed choice below is not approved simply because the SRS names it. Existing confirmed Q01-Q32 behavior must remain intact while decisions are obtained. `OD` IDs are SRS decision-register identifiers, not requirements or new stakeholder Q numbers.

ID	Question and existing evidence	Affected scope / reasonable options	Decision owner and required stage	Status / risk
OD-001	Which Tutor working days, opening hours, holidays and calendar boundaries apply? Q03 fixes duration, not operating hours; baseline TBD-S1-01 is open.	FR-005/006, BR-035; explicitly approve a restriction or document why none is imposed.	@Tanaboonnnnn proposes; @Chxtamos reviews **before Slot Feature SDS**; stakeholder approval for any new business constraint	**OPEN.** An invented workweek could reject valid requests.
OD-002	Is there a maximum advance scheduling/booking horizon? Q05 provides only a **minimum** lead time; baseline TBD-S1-02 is open.	FR-005/009/011; choose approved upper bound or explicitly decide none, without assuming 7/14/30 days.	Stakeholder decision documented by team and reviewed **before Slot/Booking contracts**	**OPEN.** Inconsistent form and server validation risk.
OD-003	What start-minute increments are permitted? Exactly 60-minute duration does not imply starts at :00 or :30; baseline TBD-S1-03.	FR-005/006; approve a grid or leave all otherwise-valid minute instants available as a documented decision.	Stakeholder/team + peer **before Slot SDS/STS**	**OPEN.** Hidden UI grid could alter business scope.
OD-004	Should Customer availability show only bookable Slots or all offers with unavailable markers? Which Tutor labels, sort/filter/page and sensitive fields? Baseline TBD-S1-04 and PR #7 review.	FR-008/009, FR-014/015, NFR-007. Bookable-only is **proposed**, not approved; either presentation must avoid false availability and private data.	Team API/UI contract, @Chxtamos **before S1 feature implementation**	**OPEN PROPOSAL.** UX/privacy ambiguity.
OD-005	What are session/token invalidation, expiry, refresh and replay safeguards, safe error schemas and exact transactional/time-control mechanisms? Baseline TBD-S1-05.	FR-001..004/011/018, NFR-001/002/015; evaluate technologies in System/Feature SDS without changing the business outcomes.	Engineering design by @Tanaboonnnnn; peer review **before code**	**OPEN DESIGN.** Security and cutoff implementation risk.
OD-006	Where does an appointment **in progress** fall in Upcoming Booked versus Past Booked? Q30 says Past is derived; the S1 glossary derives it after **end**. Q31 names only the three summary categories.	FR-035, BR-030/031, NFR-016; options include a separately disclosed in-progress subgroup or a specifically approved treatment, without inventing a third Booking **state**.	Stakeholder clarifies; peer review **before S3 Summary SDS/STS**	**OPEN.** Counts could silently omit or misclassify a current lesson.

ID	Question and existing evidence	Affected scope / reasonable options	Decision owner and required stage	Status / risk
OD-007	May the same withdrawn historical Slot be reactivated? **No**: Q32 explicitly prohibits reactivation. Only whether any special restoration request needs a **new separately approved** workflow remains undecided.	FR-034, BR-032. Normal design uses **new Slot ID**; no override is authorized by current baseline.	Q32 already governs; any proposed exception needs **new stakeholder approval before scope change**	**REACTIVATION PROHIBITED; hypothetical exception UNSPECIFIED.** Do not treat prohibition as an open permission.
OD-008	How long may private reasons/notifications/history be retained or deleted, and by whom? Q24/Q25 require rereadability and no automatic time expiry, but do not resolve user deletion or formal retention governance.	FR-031/032, NFR-007/014/015; no auto-expiry, pending deletion/export/access policy.	Stakeholder/data owner and security reviewer **before notice design/sign-off**	**OPEN.** Privacy and durability tradeoff.
OD-009	Which filtering, ordering, pagination, category counting snapshots and historical associations apply to Tutor Summary? Q31 gives categories/counts/lists, not query shape or page size.	FR-035/036, NFR-016, OD-006; approve lists and counts against same filters and visibility.	Team + @Chxtamos **before S3 Summary SDS/STS**	**OPEN DESIGN.** Count/list disagreement.
OD-010	Are keyboard-only flow and p95 <= 2.0 s acceptable product NFR targets? What machines, fixtures, concurrency sample size and exact workloads are approved? PR #7 keeps thresholds proposed.	NFR-004 run sizes, NFR-009/010 targets; accept, revise or defer explicit criteria with recorded methodology.	@Tanaboonnnnn and @Chxtamos, stakeholder/instructor if required **before affected STS approval**	**OPEN PROPOSAL.** No measured performance/UX result yet.
OD-011	Is the examined `group_work_specs_v1.pdf` the latest final Master? The available copy states **Draft for instructor review, issued 6 Oct 2026**; D1 references `group_work_specs.docx` as master. Searches in the locally approved repository and connected Drive did not locate a newer authoritative master.	All source-derived GW/Theme 1 entries. Obtain current instructor-issued `group_work_specs.docx` or dated official amendment; compare every Part A/Theme rule, record version/date and differences.	Instructor/TA source; @Tanaboonnnnn verifies and @Chxtamos reviews **before formal SRS/Deliverable sign-off**	**UNVERIFIED; FORMAL SIGN-OFF BLOCKED.** PR may proceed as a labeled draft.
OD-012	Is Theme 1 officially assigned to this two-student team? GW v1 §6 allocates themes from students' final ID digits; no dated assignment/ID evidence is present in reviewed materials.	Entire tutoring context. Obtain instructor/TA theme confirmation or verifiable eligibility record.	Instructor/TA; @Tanaboonnnnn supplies; @Chxtamos checks **before formal sign-off**	**UNVERIFIED; FORMAL SIGN-OFF BLOCKED.** Do not claim eligibility proved.

ID	Question and existing evidence	Affected scope / reasonable options	Decision owner and required stage	Status / risk
OD-013	What result, idempotency key and replay window should repeated Booking/reschedule/cancel submissions use after network uncertainty? Q invariants constrain outcomes but not response protocol.	FR-018/025/027, NFR-008; choose recoverable reconciliation and duplicate policies with real-DB validation.	Engineering + @Chxtamos **before related Feature SDS/STS**	**OPEN DESIGN.** Duplicate effects and misleading response risk.
OD-014	What exactly qualifies as a `meaningful` Tutor cancellation reason beyond nonblank? Q20 rules out empty/meaningless text but sets no byte count or prohibited vocabulary.	FR-029, BR-020; propose a reviewable validation policy; do not invent a word/minimum-length requirement as confirmed.	Stakeholder/team review **before S2 Tutor cancellation SDS/STS**	**OPEN DETAIL.** Overly weak or arbitrary rejection risk.
OD-015	Which historical Booking/reschedule fields may a **previous Tutor** see after cross-Tutor reassignment? Q12/Q15 require history; Q02 restricts protected Tutor scope.	FR-015/024/026, NFR-007; evaluate authorized history without granting foreign schedule lookup.	Stakeholder/team privacy and peer **before S2 reschedule SDS/STS**	**OPEN PRIVACY DESIGN.** History must exist without broadening unrelated Tutor access.

13.1 Source-verification record and required delta procedure

Item checked	Evidence actually available	Finding	Approval consequence
Group Work Specification	`group_work_specs_v1.pdf` in user-supplied `group_project_spec_files.zip`; 15 pages; title page states "Semester 1/2026; Draft for instructor review; Issued: 6 October 2026"	Contains GW §§5.1-5.3 and Theme 1 §6, including full-stack, authentication, team workflow and appointment example	**Draft verified as draft; final master unverified**
Deliverable 1 instructions	`project_deliverable_1_v1.pdf` in same archive; 8 pages; due 8 Nov 2026 at 23:59	Part A requires whole-product FR/BR/NFR and reviewable assumptions; Parts B-D cover product, E-F Sprint 1	Applied as available D1 instruction; check against later amendments
Current repo baseline	`docs/requirements.md` on remote `sprint1`, merged PR #7; root `AGENTS.md`, merged PR #20	Stable S1 identifiers and Q01-Q32 applicability, peer review/dispositions and repo rules are available	Source verified for this document, **not** instructor-approved by that fact
Final master file	Instructor's referenced `group_work_specs.docx` and dated amendments	Not present in the examined supplied archive, current repo or relevant connected Drive search results	**Cannot compute a final-vs-draft difference**; OD-011 blocks sign-off
Formal Theme 1 allocation	Student ID digit/official theme decision or instructor/TA confirmation	Not present in the examined evidence	**Cannot certify eligibility**; OD-012 blocks sign-off

When the final master becomes available, record **filename, issue date, version, source URL/location, reviewer, comparison date, changed requirements and affected FR/BR/NFR/AC/VAL IDs**. If a clause contradicts Q01-Q32, record the conflict and ask the correct decision owner before amending the baseline. Do not overwrite confirmed stakeholder rules silently.

14. Exclusions and future compatibility

The project uses three distinct categories, with different approval consequences:

Category	Example	Consequence
Not approved for this product	Payments, lesson mode/video link, group tutoring, course catalogs, email/SMS reminders, external calendar, attendance, new admin role	No requirement or implementation follows from the current baseline; stakeholder and instructor scope approval would be needed to add one.
Agreed for product, deferred from Sprint 1	Customer cancellation/reopening (Q07-Q08), reschedule/history (Q09-Q16), Tutor cancellation/reason/notice/withdrawal (Q17-Q27/Q32), Tutor-only summary (Q31)	Must be covered in the whole-product SRS now, but remains **proposed S2/S3 allocation** with future reviewed contracts and code.
Engineering solution not yet selected	API paths/schema, transaction lock strategy, session/token design, presentation/filtering, idempotency, logging details, measured UX/performance targets	Must preserve business outcomes; propose and approve in SDS/STS, with no invented stakeholder policy.

Forward compatibility from S1: the Booking model must later support `Cancelled` without inventing `Completed`; reschedule must retain the Booking ID/history and update Tutor association; withdrawn Slots must remain historical without blocking current offers; reasons/notifications need ownership boundaries; Tutor summary must use the same authoritative state and time semantics. These constraints are requirements for future design, not authorization to implement S2 features in S1.

15. Verification planning

Each `VAL-xxx` is an **unexecuted requirements-level verification plan**, not an executable STS or a report of passing tests. The test author must later specify fixtures, exact inputs, controlled server clock, synchronized race barriers where relevant, database assertions, expected API/UI behavior, and concrete result/version. Below, `negative` means a forbidden or failed case; `boundary` means exact equality and just below/above as appropriate.

15.1 Planned validation catalog

Anchor	Scope and planned method	Required observable evidence	Linked requirements	Target
VAL-001	API/UI: valid and invalid Customer/Tutor login, identity query, logout and old-session reuse	Correct own role, bad credentials denied, no usable access after logout	FR-001/002/003; BR-033; NFR-001	S1
VAL-002	API integration: anonymous, forged role, foreign Slot/Booking IDs and wrong Tutor requests	All protected actions denied/filtered, payload contains no foreign private data	FR-004/007/014/015/018; BR-002/033; NFR-001	S1 and regression

Anchor	Scope and planned method	Required observable evidence	Linked requirements	Target
VAL-003	UI/API/DB: Tutor creates one future offer; invalid duration/automatic recurrence attempt	Exactly one owned 60-minute offer saved; no automatic repeating Slots	FR-005; BR-003/004; NFR-003	S1
VAL-004	Boundary/API/DB: past/invalid, same-Tutor overlap, adjacency, different-Tutor same-time, Customer adjacency	Invalid/overlapping offer denied; adjacency/cross-Tutor allowed when other checks pass	FR-006/013; BR-003/006/028/035	S1
VAL-005	Real-DB synchronized Race A: concurrent same-Tutor overlapping offer creation	At most one conflicting current Slot committed; losing attempt no partial Slot	FR-006; BR-006/034; NFR-004	S1
VAL-006	Availability API/UI: eligible, past, occupied, too-soon and stale offers	No false selectable booking; no private third-party data; server rechecks stale result	FR-008/009; BR-005/035; NFR-007	S1
VAL-007	E2E/API/DB: authorized offer → availability → Booking → reload/restart → own retrieval	Exactly one Booked reservation saved and readable from persistent DB by authorized actors	FR-010/016/019; BR-001; NFR-003	S1
VAL-008	Controlled backend clock: exact 60:00 vs 59:59 cutoff and wrong browser timezone	Exact boundary eligible, below rejected; correct Bangkok scheduling meaning	FR-011; BR-005/029; NFR-006	S1
VAL-009	Controlled transaction waiting at Q05 cutoff, including prior HTTP arrival	Reject when final guarded `T_elig` is too late; no false success or occupied Slot	FR-009/011; BR-005/034; NFR-006	S1
VAL-010	Real-DB synchronized Race B: two Customers, one Slot	At most one committed Active Booking and one occupied Slot	FR-012; BR-001/034; NFR-004	S1
VAL-011	API/DB sequential plus synchronized Race C: same Customer, overlapping Tutors	No overlapping Active Bookings committed; adjacency allowed by overlap rule	FR-013; BR-028/034; NFR-004	S1
VAL-012	API/UI: own Customer list/detail; Tutor schedule; foreign IDs, refresh	Authorized records visible and persisted, foreign data absent	FR-007/014/015; BR-002; NFR-001/007	S1
VAL-013	Time/UI/API: past end, non-Bangkok device and Booking status check	Past display may be derived; status remains Booked; no Completed or time shift	FR-017; BR-029/030; NFR-006	S1, report regression S3
VAL-014	DB fault injection and stale selection/invalid input for Slot or Booking	No partial claim, false confirmation or mutation after rejection	FR-011/016/018; BR-034/035; NFR-005	S1
VAL-015	S2 API/DB: owning/nonowning Customer cancel; exact 30:00 and just below	Valid owner cancels to Cancelled with Slot re-open; invalid leaves original untouched	FR-020/021; BR-007; NFR-006	proposed S2

Anchor	Scope and planned method	Required observable evidence	Linked requirements	Target
VAL-016	S2 boundary/DB: newly reopened original Slot inside new-Booking cutoff	Slot exists as offered/unoccupied but new Booking under 60 minutes denied	FR-021; BR-005/008/014	proposed S2
VAL-017	S2 API/DB: foreign Customer reschedule, one previous success, unsuccessful attempt	Foreign/second-success rejected; failed attempt leaves quota available	FR-022/027; BR-009/016; NFR-008	proposed S2
VAL-018	S2 controlled clock: old and destination starts at exactly 60:00 vs just below	Both boundaries enforced independently; no partial move	FR-023; BR-010/011; NFR-006	proposed S2
VAL-019	S2 API/DB: valid cross-Tutor destination	New Tutor assignment allowed, independent conflicts still enforced	FR-024; BR-012/028	proposed S2
VAL-020	S2 real-DB: successful and rejected reschedule, destination collision, forced rollback	Same Booking ID; old/new history on success only; old Slot reopened, destination claimed, failed attempt restores prior state/quota	FR-025/026/027; BR-013..016; NFR-005/008	proposed S2
VAL-021	S2 API: current versus wrong Tutor; exact 60:00, 59:59; blank/meaningless reason	Only valid owner/cutoff/reason permits action; otherwise no state changes	FR-028/029; BR-017/018/020; NFR-006	proposed S2
VAL-022	S2 API/DB: Tutor cancellation with committed Booking/Slot relation	Booking Cancelled; original Slot withdrawn, not reoffered; no partial result on fault	FR-030; BR-019; NFR-005	proposed S2
VAL-023	S2 API/UI: successful Tutor cancellation; owning vs foreign Customer, reason fields	Exactly intended owner gets notice and reason in both notice and Booking detail; no leak	FR-031; BR-021..023; NFR-007	proposed S2
VAL-024	S2 persistence/UI: mark notice read, reenter later, simulate age passage	Same owner can reread; no automatic time expiry; deletion policy remains unresolved	FR-032; BR-024/025; NFR-014	proposed S2
VAL-025	S2 API/DB: attempt direct edit/delete/withdraw with Active Booking	All such direct operations denied without modifying occupied Slot	FR-033; BR-026	proposed S2
VAL-026	S2 API/DB: own unoccupied future withdraw and separate new Slot creation	Old historical record retained; new distinct ID accepted if otherwise valid	FR-034; BR-027	proposed S2
VAL-027	S2 API/DB: new offer overlapping withdrawn history and attempted historical reactivation	New offer not blocked by withdrawn Slot; original ID not reactivated	FR-034; BR-032	proposed S2
VAL-028	S3 API/UI/DB: known Booked-upcoming, Booked-past and Cancelled fixtures	Counts and accessible lists match exact categories and state/time without Completed	FR-035; BR-030/031; NFR-016	proposed S3

Anchor	Scope and planned method	Required observable evidence	Linked requirements	Target
VAL-029	S3 API: Customer/anonymous/foreign Tutor summary; in-progress fixture	No foreign summary; in-progress category follows **approved future decision**, not guessed default	FR-035/036; BR-031; NFR-001/016	proposed S3
VAL-030	API/DB: repeated/uncertain Booking or reschedule calls	Invariants/quota/history unchanged by unsafe duplicates; concrete retry response to be specified	FR-018/025/027; BR-001/034; NFR-008	S1/S2
VAL-031	Documentation/release evidence review and reproducible local start	Documented SHA, setup, persistent data checks, actual command outputs, peer-reviewed PR chain	FR-019; NFR-003/011/012	S1-S3
VAL-032	Candidate p95 benchmark over 50+ warm-up-excluded GETs per operation with recorded environment	Record raw data/p95 and compare only after threshold approval; **no execution here**	NFR-010	proposed S1/S3
VAL-033	Candidate manual keyboard walk-through with recorded browser/focus checklist	Record accessibility findings; compare only after target approval	NFR-009	proposed S1/S3
VAL-034	Security review of stored test passwords, secrets/configuration and error/log traces	No plaintext secrets and no protected fields; approved hashing method demonstrated when implemented	NFR-002/015; FR-001	S1 and regression
VAL-035	Lab 5+ pipeline/packaging/deploy check, linked release/version	Docker/GCP persistence, required PR build/test gate and repeatable main release with actual outputs	NFR-013	Lab 5+, outside Issue #9
VAL-036	Negative API payload inspection for availability, Booking, notification, summary and error paths	No foreign owner data, cancellation reason or restricted Tutor records in serialized results	FR-004/008/014/015/031/036; BR-022/033; NFR-001/007/015	S1-S3

15.2 Coverage and test-readiness boundaries

At the **requirements** stage, VAL-001..036 give a planned validation path for each FR-001..036, BR-001..035 and NFR-001..016. Crosswalk §12.4 preserves the planned Sprint 1 anchors `AC-S1-01..35` and `VC/TEST-S1-01..39`. The true implementation later needs tests that fail for the right reason before code (TDD), seeded role fixtures, a controlled server clock, a real transactional database for the three races, injected rollback failures and exact recorded outcomes. Final Test Specification IDs, test source files and pass/fail counts belong to Parts E/F, not this SRS.

Validation is not approval: a structural ID check validates document consistency, a teammate review evaluates the requirements, a formal stakeholder decision authorizes disputed behavior, and an executed test validates implemented behavior. These evidence types must not be substituted for one another.

16. Risks, dependencies and change control

Risk / dependency	Exposure	Control and required evidence	Owner / gate
Final instructor specification and Theme unverified	Wrong scope or unapproved team topic	Locate dated final Master + Theme decision; record exact version and differences; revise via reviewed PR	Instructor/TA, @Tanaboonnnnn; OD-011/012 before formal sign-off
New working-hours/horizon/start grid invented in design	Unapproved rejection of valid scheduling	Keep OD-001..003 open, seek specific policy approval, update FR/BR/AC/VAL before implementation	Product decision owner; Slot/Booking contracts
Concurrent Slot/Booking collisions	Double offers, double claims, cross-Tutor overlap	Synchronized real-DB Race A/B/C tests and reviewable transaction guarantees	Engineering + @Chxtamos; S1 contracts
Cutoff evaluated at client or early request time	Incorrect exact-boundary outcomes	Preserve Q05 and reviewed `T_elig` interpretation, test contention crossing; define S2 mutation decision points	Feature contract reviewers
Partial reschedule/cancellation/notification writes	Lost reservation, wrong Slot state or private false notice	Atomic transaction and fault-injection evidence, exact history/quota assertions	S2 Feature SDS/STS
Privacy and reschedule history	Other Customer/Tutor sees reason, past association or summary	Role/record matrix plus full response allowlist review and negative API tests; OD-015	Security/data owner + peer
Summary in-progress classification	Incorrect count/list or dropped current session	Decide OD-006 and OD-009 before S3 contract; compare counts to underlying authorized row sets	Stakeholder and peer
Unapproved NFR target silently treated as pass gate	Unsupported performance or UX claims	Record approval status and environment/method before adopting; preserve measured results	OD-010; team/stakeholder
Feature-order dependency	Later sprints assume unavailable S1 identity/transaction model	S1 auth/Slots/Booking first; S2 cancel/reschedule/notice/withdraw; S3 reports/hardening; revalidate after review	Issue #12 planning, separate implementation Issues
Scope or document drift	Q decisions contradicted, undocumented changes enter app	Versioned SRS and explicit change record with source/decision owner, affected IDs, planned tests and peer review	All future PRs

Change-control procedure: A proposal changing Q01-Q32 must identify the decision ID, present its source and impact, obtain explicit stakeholder approval, then revise affected product FR/BR/NFR, open decisions, acceptance/validation mappings and the later design/test contracts in reviewable commits. An instructor-final discrepancy requires a recorded source comparison and decision owner. A formatting or technical design choice must not silently relax a confirmed cutoff, role boundary, one-to-one exclusivity, transaction integrity or notification privacy rule.

17. Review checklist and sign-off

These checkboxes are review tasks, **not claims of completion**. Human reviewer should inspect the entire document against the linked evidence.

17.1 Reviewer checklist for @Chxtamos

- [ ] Whole-product scope is distinct from the Sprint 1-only source; S2/S3 capabilities are present without inventing implementation.
- [ ] Every Q01-Q32 appears once in §12.2 and the mapped FR/BR describes the same approved decision, with no unsupported extra business policy.
- [ ] All FR-001..036, BR-001..035 and NFR-001..016 have unique meanings, sources, proposed target sprints and usable validation anchors.
- [ ] Theme 1/Deliverable 1 instructor minimum is accurately identified as an **examined draft** where appropriate, not falsely claimed final.
- [ ] Exactly sixty-minute manual offers, Q05 equality, Q07 30-minute equality, Q10/Q11/Q18 60-minute equalities and Bangkok server time agree across catalogs and scenarios.
- [ ] Same-Tutor current offers, exclusive Slot and same-Customer cross-Tutor races are three **separate** committed-DB obligations; adjacency and withdrawn-history exceptions are correct.
- [ ] Customer cancellation reopens old Slot, but Tutor cancellation withdraws old Slot; failed reschedule preserves old Booking and quota; one success preserves Booking ID/history.
- [ ] Privacy matrix denies foreign Customer/Tutor reads, notice/reason leaks and Customer access to the Tutor-only summary.
- [ ] Booked/Cancelled are the only Booking business states; Past is derived; no Completed/attendance assumption appears.
- [ ] Open policies OD-001..015, especially final Master/Theme and proposed NFR performance/UX targets, are not written as approvals.
- [ ] Existing Sprint 1 `FR-S1`, `BR-S1`, `NFR-S1`, `AC-S1` and `VC/TEST-S1` identifiers are not redefined; §16.1 in `requirements.md` includes `AC-S1-35`.
- [ ] Full-document Markdown, relative links, table consistency, ID references, source accuracy, scope and Git file allowlist are checked.
- [ ] No application code, Feature SDS, test implementation or release/deployment claims are part of Issue #9.
- [ ] A real GitHub **Review Request** was issued to @Chxtamos, and their subsequent review is separately recorded before any merge.

17.2 Sign-off record

Review gate	Responsible party	Current evidence and status
Author's requirements drafting/structural validation	@Tanaboonnnnn	Document submitted as draft for Issue #9; structural/semantic review results belong in PR verification report
Independent peer review	@Chxtamos	**PENDING**; no approval recorded in this SRS
Material open policy/NFR decisions	Stakeholder/product owner and team	**PENDING** OD-001..006, OD-008..010, OD-013..015

Review gate	Responsible party	Current evidence and status
Final instructor Master version and Theme 1 eligibility	Instructor/TA, verified by team	**UNVERIFIED** OD-011/012; formal approval **BLOCKED**
Whole-product SRS approval	Authorized decision owner following independent review	**NOT APPROVED**
Application implementation, automated tests, release and deployment	Separate engineering Issues	**NOT VERIFIED BY THIS DOCUMENT**

The SRS can be reviewed and improved through an Issue-linked PR while these external gates are open. Peer approval alone must not be represented as the instructor's final requirements approval. No merge is authorized by this document.

18. References

Only materials actually inspected or explicitly provided as the agreed baseline are listed as evidence. Titles and versions are reproduced from sources, without fabricated approval dates or inaccessible references.

Key	Source and location	Purpose / limitation
SRC-Q, SRC-S1	Sprint 1 Requirements Specification, `docs/requirements.md` on sprint1; stakeholder decisions Q01-Q32 and numbered Sprint 1 catalog	Verified repository baseline from merged PR #7. This is **not** the whole-product SRS or proof of final instructor approval.
SRC-GW-v1	`group_work_specs_v1.pdf`, CPE 334 Group Work Specification, **Draft for instructor review**, issued **6 October 2026**, 15 pages; user-supplied `group_project_spec_files.zip`	Actual available theme/technical/course handout. Its final `group_work_specs.docx` replacement was **not verified**.
SRC-D1-v1	`project_deliverable_1_v1.pdf`, CPE 334 Project Deliverable 1, due 8 November 2026 at 23:59, 8 pages; same supplied archive	Whole-product Part A requirements and downstream Parts B-F boundaries.
SRC-AGENT	Repository AGENTS.md, incorporated by PR #20	Repository workflow, scope, verification and no-self-merge obligations, **not new stakeholder rules**.
SRC-ISSUE	Issue #9: D1-01 Part A Whole-product SRS	Assigned deliverable, allowed files and acceptance criteria.
SRC-REVIEW	PR #7 review history	Peer feedback and final correction request that §16.1 include `AC-S1-35`; independently reviewed S1 baseline.
Structural reference only	SE-Project-God-of-Merchandise-Store	Repository root listing was accessible, but no SRS file was available to inspect there. **No Store business rule, quotation or claimed SRS content is used**.

End of v0.1.0 draft. This document can support independent engineering review. Formal sign-off remains subject to the final instructor Master/Theme confirmation, resolution of material open decisions and an actual reviewer

decision.

Part B: Feature Inventory & Requirements Traceability Matrix

Draft for teammate review. SRS is authoritative. Sprint 2/3 allocations are proposed, not approved.

Stable ID	Feature and required outcome	Actor	Sprint	Dependency	Linked FR/BR/NFR	Planned verification
F-S1-01	Customer/Tutor can log in, retrieve trusted identity, and log out; backend rejects unauthorized roles and records	Customer/Tutor	S1	none	FR-001, FR-002, FR-003, FR-004, BR-002, BR-033, NFR-001, NFR-002	VAL-001/002 (planned)
F-S1-02	Tutor creates and retrieves own 60-minute Slots; concurrent overlap is rejected and adjacent offers allowed	Tutor	S1	F-S1-01	FR-005, FR-006, FR-007, BR-003, BR-004, BR-006, BR-035	VAL-003/004/005 (planned)
F-S1-03	Customer discovers eligible Tutor/time offers without third-party Booking data	Customer	S1	F-S1-02	FR-008, FR-009	VAL-006 (planned)
F-S1-04	Customer books one eligible Slot persistently; concurrent same-Slot claims and overlapping Customer bookings are rejected	Customer	S1	F-S1-01/02/03	FR-010, FR-011, FR-012, FR-013, BR-001, BR-005, BR-028, NFR-008 (S1 Booking retry safety)	VAL-007..011/014/030 (planned)

Stable ID	Feature and required outcome	Actor	Sprint	Dependency	Linked FR/BR/NFR	Planned verification
F-S1-05	Customer reads only own persisted Bookings and Tutor reads only own schedule after refresh; Past is not Completed	Customer/Tutor	S1	F-S1-01/04	FR-014, FR-015, FR-016, FR-017, BR-030	VAL-012/013 (planned)
F-S2-01	Customer cancels own eligible Booking and atomically reopens original Slot (proposed)	Customer	S2 proposed	F-S1-04	FR-020, FR-021, BR-007, BR-008	VAL-015/016 (planned)
F-S2-02	Customer reschedules at most once, even across Tutors, retaining ID and atomic history (proposed)	Customer	S2 proposed	F-S1-04/05	FR-022, FR-023, FR-024, FR-025, FR-026, FR-027, BR-009, BR-010, BR-011, BR-012, BR-013, BR-014, BR-015, BR-016, NFR-008	VAL-017..020 (planned)
F-S2-03	Authorized Tutor cancels with a reason and atomically withdraws the Slot (proposed)	Tutor	S2 proposed	F-S1-02/04	FR-028, FR-029, FR-030, BR-017, BR-018, BR-019, BR-020	VAL-021/022 (planned)
F-S2-04	Owning Customer privately reads and rereads durable cancellation notice (proposed)	Customer	S2 proposed	F-S2-03	FR-031, FR-032, BR-021, BR-022, BR-023, BR-024, BR-025, NFR-014	VAL-023/024 (planned)

Stable ID	Feature and required outcome	Actor	Sprint	Dependency	Linked FR/BR/NFR	Planned verification
F-S2-05	Tutor withdraws unoccupied future Slot, preserving history and allowing distinct replacement (proposed)	Tutor	S2 proposed	F-S1-02	FR-033, FR-034, BR-026, BR-027, BR-032	VAL-025..027 (planned)
F-S3-01	Tutor views authorized counts and matching lists for Upcoming, Past and Cancelled (proposed)	Tutor	S3 proposed	F-S1-05	FR-035, FR-036, BR-031, NFR-016	VAL-028/029 (planned)
SYS-01	System preserves atomic/durable changes, authorization, reproducible evidence and a proposed deployment design	System	S1-S3/Lab5+	all	FR-018, FR-019, BR-029, BR-034, NFR-003, NFR-004, NFR-005, NFR-006, NFR-007, NFR-009, NFR-010, NFR-011, NFR-012, NFR-013, NFR-015	VAL-005/006/010/011/012/014/020/022/023 (planned across S1/S2/S3)

Baseline and invariants

F-S1-01..05 retain the five accepted Sprint 1 identities (Auth, Tutor Slots, Availability, Booking, Protected Read) from requirements.md. SYS-01 owns cross-cutting engineering obligations, while all features still enforce role and record authorization. NFR-004 is shared by F-S1-02 (Race A) and F-S1-04 (Races B/C), while NFR-007 privacy applies to F-S1-03/F-S1-05 in S1, F-S2-04 in proposed S2, and F-S3-01 in proposed S3. These shared applications do not create duplicate primary owners; see traceability.md.

Race A: F-S1-02 / Q06 / FR-006 / BR-006/034 / VAL-005 — same-Tutor overlapping offered Slots.

Race B: F-S1-04 / Q01 / FR-012 / BR-001/034 / VAL-010 — two Customers, one Slot.

Race C: F-S1-04 / Q28 / FR-013 / BR-028/034 / VAL-011 — one Customer, overlapping Tutors.

All three require actual committed database checks. S2 cancellation, rescheduling, withdrawal and notices and S3 summary are planned only. See traceability.md for coverage and SRS §13 for OD-001..015.

Acceptance and review

Each feature must preserve its listed requirement outcomes and planned VAL evidence; Feature SDS/STS must be peer reviewed before implementation. Owner @Chxtamos; independent reviewer @Tanaboonnnnn. Issue #10 requires a PR into sprint1.

DRAFT. Source: SRS, features, Sprint 1 requirements. All validation is PLANNED, NOT EXECUTED.

Product requirement	Complete SRS intent (linked source)	Accountable feature / responsibility	Target sprint	Planned validation
FR-001	Customer/Tutor: With existing valid credentials, authenticate and establish only that principal's effective role; reject invalid credentials without authenticated access. (full FR-001)	F-S1-01	S1	VAL-001 (planned)
FR-002	Authenticated Customer/Tutor: Return the current principal's own identity and role without accepting a client-supplied impersonation; anonymous requests reveal no protected identity. (full FR-002)	F-S1-01	S1	VAL-001, VAL-002 (planned)
FR-003	Authenticated Customer/Tutor: Log out and render the prior session/access unusable for protected operations; the exact invalidation/expiry method must be decided in the auth contract. (full FR-003)	F-S1-01	S1	VAL-001, VAL-002 (planned)
FR-004	Application/server: Authenticate and enforce role and record ownership on every protected Slot, Booking, notification and summary action, including crafted requests and URL/ID access; reject unauthorized access without private payload. (full FR-004)	F-S1-01	S1 / S2 proposed / S3 proposed	VAL-002, VAL-036 (planned)
FR-005	Tutor: Given authorization to their own schedule and a valid future start, publish exactly one explicit sixty-minute Slot; persist it under the authenticated Tutor, without recurrence or auto-generated bulk offers. (full FR-005)	F-S1-02	S1	VAL-003 (planned)
FR-006	Server on Tutor creation: Reject malformed/past Slots and overlaps between currently offered Slots of the same Tutor; permit adjacent intervals and independent same-time offers by another Tutor when otherwise valid; leave existing offers unchanged on rejection. (full FR-006)	F-S1-02	S1	VAL-004, VAL-005 (planned)
FR-007	Tutor: Retrieve own offered Slots and authorized occupied/unoccupied schedule view from committed data; reject another Tutor's protected schedule lookup. (full FR-007)	F-S1-02	S1	VAL-002, VAL-012 (planned)

Product requirement	Complete SRS intent (linked source)	Accountable feature / responsibility	Target sprint	Planned validation
FR-008	Customer: Browse Tutor/Slot/time information sufficient to choose a specific offer, without disclosure of another Customer's private reservation; the concrete field allowlist remains an API-contract choice. (full FR-008)	F-S1-03	S1	VAL-006, VAL-036 (planned)
FR-009	Server/availability view: Mark an offer bookable only when current, unoccupied, eligible and not too close to its start; an earlier view must not guarantee later acceptance. Hide-versus-disabled presentation is unresolved. (full FR-009)	F-S1-03	S1	VAL-006, VAL-009 (planned)
FR-010	Customer: Given an eligible Slot and no overlapping Active Booking, request one exclusive reservation for their authenticated identity; commit one `Booked` Booking referencing the actual Slot and Tutor before acknowledging success. (full FR-010)	F-S1-04	S1	VAL-007 (planned)
FR-011	Server on Booking: Revalidate offered/unoccupied state, user ownership, cutoff and overlaps immediately before a guarded Booking write; reject stale, invalid, past, too-soon or occupied choices with no partial reservation. (full FR-011)	F-S1-04	S1	VAL-008, VAL-009, VAL-014 (planned)
FR-012	Server on competing Bookings: Under simultaneous attempts by different Customers for the same exclusive Slot, allow at most one committed Active Booking and never return two successful claims. (full FR-012)	F-S1-04	S1	VAL-010 (planned)
FR-013	Server on Customer Booking: Reject the same Customer's overlapping Active reservation, including requests for two different Tutors; accept adjacency under this specific rule, with at most one conflicting success under concurrency. (full FR-013)	F-S1-04	S1	VAL-004, VAL-011 (planned)
FR-014	Customer: Retrieve a persisted list and detail of own Bookings with Booking identity, Tutor/Slot/interval and business status; foreign IDs must not disclose Booking data. (full FR-014)	F-S1-05	S1	VAL-012, VAL-036 (planned)
FR-015	Tutor: Retrieve Bookings attached to the Tutor's authorized schedule only; requesting another Tutor's records must not disclose them. (full FR-015)	F-S1-05	S1	VAL-002, VAL-012 (planned)
FR-016	Application: Authorized reopened/refresh/restart views must reflect successfully committed Slots/Bookings and correct ownership; a failed transaction must not produce a persisted or reported phantom Booking. (full FR-016)	F-S1-05	S1	VAL-007, VAL-014 (planned)
FR-017	Application views: Display `Booked` accurately and, when a Booking's end is past, optionally derive `Past`; never assert `Completed`, attendance or auto-release solely from elapsed time. (full FR-017)	F-S1-05	S1	VAL-013 (planned)

Product requirement	Complete SRS intent (linked source)	Accountable feature / responsibility	Target sprint	Planned validation
FR-018	Application/server: Return an observable, non-success rejection for forbidden, invalid, stale, conflicting or failed mutations, without leaking protected records or leaving partial state. Specific HTTP status/payload formats remain contract decisions. (full FR-018)	SYS-01	S1-S3/Lab5+	VAL-002, VAL-014, VAL-030 (planned)
FR-019	System: Support the Tutor offer → Customer browse → committed Booking → authorized retrieval journey through a real UI, application/API and durable database, surviving refresh and application restart. (full FR-019)	SYS-01	S1-S3/Lab5+	VAL-007, VAL-031 (planned)
FR-020	Owning Customer: Cancel their current Booking when the Appointment starts at least 30 minutes after the server's authoritative decision; at the exact boundary allow, below it deny; foreign or nonactive Booking cannot be cancelled. (full FR-020)	F-S2-01	S2 proposed	VAL-015 (planned)
FR-021	Server on successful Customer cancellation: Change Booking to `Cancelled` and reopen its same original Slot atomically; keep it unbookable for any later new request failing the independent Q05 cutoff. (full FR-021)	F-S2-01	S2 proposed	VAL-015, VAL-016 (planned)
FR-022	Owning Customer: Initiate rescheduling of an existing `Booked` Booking; reject nonowners and disallowed Booking state. (full FR-022)	F-S2-02	S2 proposed	VAL-017 (planned)
FR-023	Server on reschedule: Require both original Appointment start and destination Slot start to be at least 60 minutes away at authoritative decision; reject either too-late side including the just-below-boundary case. (full FR-023)	F-S2-02	S2 proposed	VAL-018 (planned)
FR-024	Owning Customer: Select a valid destination with a different Tutor if desired; do not restrict rescheduling to the original Tutor, while still enforcing destination occupancy and same-Customer overlap. (full FR-024)	F-S2-02	S2 proposed	VAL-019 (planned)
FR-025	Server on reschedule: Atomically update Booking assignment, occupy destination, release/reopen original Slot and record history; any validation, conflict or persistence failure leaves all related records at their pre-attempt state. (full FR-025)	F-S2-02	S2 proposed	VAL-020 (planned)
FR-026	Server: Preserve the Booking ID across a successful reschedule and append a successful-change record with former/new Tutor, Slot/interval and timestamp; rejected attempts do not create successful history. (full FR-026)	F-S2-02	S2 proposed	VAL-020 (planned)
FR-027	Server: Permit at most one successful reschedule per Booking; a failed attempt leaves the allowance available, while a second successful-change request is rejected. (full FR-027)	F-S2-02	S2 proposed	VAL-017, VAL-020 (planned)

Product requirement	Complete SRS intent (linked source)	Accountable feature / responsibility	Target sprint	Planned validation
FR-028	Currently assigned Tutor: Cancel an Active Booking belonging to the Tutor's authorized schedule only when its start is at least 60 minutes away; exact boundary passes and wrong-Tutor/too-late attempts fail. (full FR-028)	F-S2-03	S2 proposed	VAL-021 (planned)
FR-029	Tutor/server: Require a meaningful nonblank reason before accepting Tutor cancellation; reject absent, whitespace-only or semantically empty reason without changing Booking or Slot. Length/format details need approved design. (full FR-029)	F-S2-03	S2 proposed	VAL-021 (planned)
FR-030	Server on successful Tutor cancellation: Mark Booking `Cancelled` and withdraw its original Slot instead of reopening it; preserve trace/history and ensure no partial outcome. (full FR-030)	F-S2-03	S2 proposed	VAL-022 (planned)
FR-031	Server: On successful Tutor cancellation create one private in-app notice for that Booking's owning Customer, including the authorized reason; the reason also appears in that Customer's cancelled Booking details, never in third-party views. (full FR-031)	F-S2-04	S2 proposed	VAL-023, VAL-036 (planned)
FR-032	Owning Customer: Retrieve and reread Tutor-cancellation notices after marking them read; absence of automatic time-based expiry must hold, while deletion/retention governance remains undecided. (full FR-032)	F-S2-04	S2 proposed	VAL-024 (planned)
FR-033	Server/Tutor: Forbid direct edit, deletion or withdrawal of a Slot while it carries an Active Booking; require the separate authorized cancellation workflow first. (full FR-033)	F-S2-05	S2 proposed	VAL-025 (planned)
FR-034	Owning Tutor: Withdraw an unoccupied future currently offered Slot while retaining its history; permit later creation of a distinct new Slot with a new ID that may overlap the withdrawn interval; reject reopening/reactivating the withdrawn historical Slot. (full FR-034)	F-S2-05	S2 proposed	VAL-026, VAL-027 (planned)
FR-035	Tutor: Retrieve an Appointment Summary with counts and corresponding lists for Upcoming Booked, Past Booked and Cancelled on the Tutor's authorized schedule, calculated from stored Booking state and server time; in-progress classification remains OD-006. (full FR-035)	F-S3-01	S3 proposed	VAL-028, VAL-029 (planned)
FR-036	Server: Deny Customers, anonymous callers and unrelated Tutors access to the Tutor-only summary and its linked Booking details; counts/lists must share the same visibility and classification criteria. (full FR-036)	F-S3-01	S3 proposed	VAL-029, VAL-036 (planned)

Product requirement	Complete SRS intent (linked source)	Accountable feature / responsibility	Target sprint	Planned validation
BR-001	One Slot reserves one exclusive one-to-one Customer/Tutor session; at most one Active Booking may claim it. (full BR-001)	F-S1-04	S1	VAL-007, VAL-010 (planned)
BR-002	Tutor = Staff and may manage or inspect their own authorized schedule; Customer = learner and may inspect only own private Booking data. (full BR-002)	F-S1-01	S1	VAL-002, VAL-012 (planned)
BR-003	Every Availability Slot has a duration of exactly 60 minutes. (full BR-003)	F-S1-02	S1	VAL-003, VAL-004 (planned)
BR-004	Tutor creates individual explicit Slots; no automatic recurrence or bulk Slot generation is authorized. (full BR-004)	F-S1-02	S1	VAL-003 (planned)
BR-005	For a new Booking, `SlotStart - authoritative server eligibility time >= 60 minutes`; equality is eligible, even if later commit succeeds after the check. A 59:59 remaining interval fails. (full BR-005)	F-S1-04	S1	VAL-008, VAL-009 (planned)
BR-006	Two currently offered Slots of the same Tutor cannot overlap. Adjacent half-open intervals are permitted; different Tutors may independently offer the same time. (full BR-006)	F-S1-02	S1	VAL-004, VAL-005 (planned)
BR-007	Only the owning Customer may cancel an Active Booking at least 30 minutes before Appointment start, including equality. (full BR-007)	F-S2-01	S2 proposed	VAL-015 (planned)
BR-008	Successful Customer cancellation reopens the original Slot, but a future new Booking still independently requires BR-005. (full BR-008)	F-S2-01	S2 proposed	VAL-016 (planned)
BR-009	Only the Booking-owning Customer may initiate its reschedule. (full BR-009)	F-S2-02	S2 proposed	VAL-017 (planned)
BR-010	Reschedule's original Appointment must start at least 60 minutes after the authoritative decision; equality passes. (full BR-010)	F-S2-02	S2 proposed	VAL-018 (planned)
BR-011	Reschedule's destination Slot must start at least 60 minutes after the authoritative decision; equality passes. (full BR-011)	F-S2-02	S2 proposed	VAL-018 (planned)
BR-012	A valid Customer reschedule may move to another Tutor; original-Tutor-only restrictions are forbidden. (full BR-012)	F-S2-02	S2 proposed	VAL-019 (planned)
BR-013	Reschedule is all-or-nothing across assignment, both Slot states and successful history. Failure leaves the previous Booking intact. (full BR-013)	F-S2-02	S2 proposed	VAL-020 (planned)

Product requirement	Complete SRS intent (linked source)	Accountable feature / responsibility	Target sprint	Planned validation
BR-014	Successful reschedule reopens the original Slot, subject to independent new-Booking eligibility. (full BR-014)	F-S2-02	S2 proposed	VAL-016, VAL-020 (planned)
BR-015	Successful reschedule keeps the same Booking ID and records old/new Tutor, Slot/time and change timestamp. (full BR-015)	F-S2-02	S2 proposed	VAL-020 (planned)
BR-016	At most one successful reschedule per Booking; failures do not use that allowance. (full BR-016)	F-S2-02	S2 proposed	VAL-017, VAL-020 (planned)
BR-017	Only the currently authorized Tutor assigned to the Booking may cancel it as Tutor. (full BR-017)	F-S2-03	S2 proposed	VAL-021 (planned)
BR-018	Tutor cancellation requires Appointment start at least 60 minutes after the authoritative decision, equality included. (full BR-018)	F-S2-03	S2 proposed	VAL-021 (planned)
BR-019	Successful Tutor cancellation withdraws the original Slot; it must not reopen it. (full BR-019)	F-S2-03	S2 proposed	VAL-022 (planned)
BR-020	Tutor cancellation requires a meaningful nonblank reason; an empty/whitespace-only input is invalid. Further textual-validation details require approval. (full BR-020)	F-S2-03	S2 proposed	VAL-021 (planned)
BR-021	Each successful Tutor cancellation creates an in-app notice for the affected owning Customer only. (full BR-021)	F-S2-04	S2 proposed	VAL-023 (planned)
BR-022	Tutor-cancellation reason is visible only to the owning Customer, not to other Customers or unrelated Tutors in accessible results. (full BR-022)	F-S2-04	S2 proposed	VAL-023, VAL-036 (planned)
BR-023	That Customer sees the cancellation reason in both the in-app notice and cancelled Booking detail. (full BR-023)	F-S2-04	S2 proposed	VAL-023 (planned)
BR-024	Reading a notification does not make it inaccessible; it remains available to reread. (full BR-024)	F-S2-04	S2 proposed	VAL-024 (planned)
BR-025	Notifications do not expire automatically with elapsed time. This does not settle user/admin deletion, retention or privacy governance. (full BR-025)	F-S2-04	S2 proposed	VAL-024 (planned)
BR-026	Tutor cannot directly edit, delete or withdraw a Slot with an Active Booking; the authorized Booking cancellation must occur first. (full BR-026)	F-S2-05	S2 proposed	VAL-025 (planned)
BR-027	Tutor may withdraw an own, unoccupied future Slot and create a separate new Slot while preserving withdrawal history. (full BR-027)	F-S2-05	S2 proposed	VAL-026 (planned)
BR-028	One Customer cannot have overlapping Active Bookings across any Tutors; adjacent appointments do not overlap. (full BR-028)	F-S1-04	S1	VAL-004, VAL-011 (planned)

Product requirement	Complete SRS intent (linked source)	Accountable feature / responsibility	Target sprint	Planned validation
BR-029	`Asia/Bangkok` (UTC+07:00) is the business timezone; authoritative time comes from the server, not a browser or user-supplied timestamp. (full BR-029)	SYS-01	S1-S3/Lab5+	VAL-008, VAL-013 (planned)
BR-030	Booking business states are `Booked` and `Cancelled`; `Past` is derived from time, not a third state or evidence of `Completed` /attendance. (full BR-030)	F-S1-05 (shared: F-S2-01/03, F-S3-01)	S1 / S2 proposed / S3 proposed	VAL-013, VAL-015 (planned)
BR-031	Only authorized Tutor gets Appointment Summary counts and lists for Upcoming Booked, Past Booked and Cancelled. Customer gets no Tutor-only summary. (full BR-031)	F-S3-01	S3 proposed	VAL-028, VAL-029 (planned)
BR-032	Historical withdrawn Slots do not block a new separate overlapping offer; they are not reactivated under the same historical Slot ID. (full BR-032)	F-S2-05	S2 proposed	VAL-027 (planned)
BR-033	Protected actions require server-enforced authenticated role/ownership checks; anonymous, foreign-record and cross-role operations cannot gain private data or mutation rights. (full BR-033)	F-S1-01	S1 / S2 proposed / S3 proposed	VAL-001, VAL-002, VAL-036 (planned)
BR-034	Accepted Booking/Slot mutations commit an internally consistent outcome; rejected validations, contention and persistence failures cannot leave partially claimed Slots, duplicate active reservations or false success. The precise locking/constraint scheme is not selected here. (full BR-034)	SYS-01 (shared: F-S1-02/04, F-S2-02/03)	S1 / S2 proposed	VAL-005, VAL-010, VAL-011, VAL-014, VAL-020, VAL-022 (planned)
BR-035	Invalid or nonfuture Slot proposals and attempts to book past, occupied or ineligible offers are rejected without changing committed records; rules beyond confirmed time policies cannot be fabricated. (full BR-035)	F-S1-02	S1	VAL-004, VAL-006, VAL-014 (planned)
NFR-001	Authorization: every enumerated anonymous, forbidden-role, foreign-Customer and foreign-Tutor protected API path must reject or filter without private payload disclosure. Measure zero unauthorized record disclosure in seeded negative cases. (full NFR-001)	F-S1-01 (auth foundation; role/ownership regression for each new S2/S3 endpoint)	S1 / S2 proposed / S3 proposed	VAL-002, VAL-036 (planned; repeat authorization regression as endpoints expand)
NFR-002	Credential security: with locally managed passwords, store adaptive salted hashes, not plaintext; tracked repository content contains no real credentials. Verify using test DB inspection and secret/config review. (full NFR-002)	F-S1-01	S1	VAL-034 (planned)
NFR-003	Durability: an accepted Slot/Booking and its authorized view must persist after browser refresh and application-process restart against the same data store; no in-memory-only persistence. (full NFR-003)	SYS-01	S1 / S2 proposed / S3 proposed	VAL-007, VAL-031 (planned)

Product requirement	Complete SRS intent (linked source)	Accountable feature / responsibility	Target sprint	Planned validation
NFR-004	Concurrent conflict integrity: all three real-DB races must preserve BR-001/006/028, regardless of interleaving; a 20-attempt same-Slot stress burst and a 10-attempt same-Customer burst are proposed test sizes, not approved business capacity limits. (full NFR-004)	SYS-01 (shared: F-S1-02, F-S1-04)	S1	VAL-005, VAL-010, VAL-011 (planned)
NFR-005	Atomic consistency: accepted cancellation/reschedule/Booking/withdrawal changes all required records together; deliberate persistence failures leave the prior committed state and no false confirmation. (full NFR-005)	SYS-01	S1 / S2 proposed / S3 proposed	VAL-014, VAL-020, VAL-022 (planned)
NFR-006	Time correctness: cutoff checks use server-authoritative instants; accept exact 60:00 or 30:00 boundaries as applicable, reject just-below; Bangkok calendar/hour remains stable for a non-Bangkok browser. (full NFR-006)	SYS-01	S1 / S2 proposed / S3 proposed	VAL-008, VAL-009, VAL-013, VAL-015, VAL-018, VAL-021 (planned)
NFR-007	Data minimization: protected Booking, reason, notification and report responses do not expose third-party identity, cancellation reason, credentials or arbitrary private schedule fields. Review response bodies and negative payloads, not UI controls only. (full NFR-007)	SYS-01 (shared: F-S1-03/05, F-S2-04, F-S3-01)	S1 / S2 proposed / S3 proposed	VAL-006, VAL-012, VAL-023, VAL-029, VAL-036 (planned)
NFR-008	Retry safety: repeated/uncertain-response requests cannot violate exclusivity, successful reschedule quota or atomic history. Whether retries return the original success response and any token format/retention are open. (full NFR-008)	F-S1-04 (S1 Booking retry; AC-S1-29 / VC/TEST-S1-38); F-S2-02 (S2 proposed Reschedule retry)	S1 / S2 proposed	VAL-030 (S1), VAL-020 (S2 proposed; planned)
NFR-009	Keyboard usability (PROPOSED): complete login, availability, Booking and own-detail flows by keyboard with visible focus on primary controls; record manual checklist, browser and failures. (full NFR-009)	SYS-01	S1-S3/Lab5+	VAL-033 (planned)
NFR-010	Local response time (PROPOSED): p95 availability and own-Booking-detail requests at or below 2.0 s, each measured over at least 50 warm-up-excluded requests with documented hardware, fixture size and database. (full NFR-010)	SYS-01	S1-S3/Lab5+	VAL-032 (planned)
NFR-011	Change traceability: each implemented requirement must identify source Q/GW/D1, accountable feature/Issue, reviewed contract, planned verification and release evidence; changes to Q rules need recorded stakeholder approval. (full NFR-011)	SYS-01	S1-S3/Lab5+	VAL-031 (planned)
NFR-012	Reproducibility: engineering evidence must identify code version, environment/setup, DB/seed preparation, test commands and real pass/fail/skip results; mere presence of tests is not a pass. (full NFR-012)	SYS-01	S1-S3/Lab5+	VAL-031 (planned)

Product requirement	Complete SRS intent (linked source)	Accountable feature / responsibility	Target sprint	Planned validation
NFR-013	Deployment readiness: the selected architecture must support container packaging and durable GCP deployment, with build/tests on relevant PRs and repeatable accepted release from `main` after Lab 5. No cloud success is asserted at D1. (full NFR-013)	SYS-01	S1-S3/Lab5+	VAL-035 (planned)
NFR-014	Notice durability: a Tutor-cancellation notice remains retrievable after being read and is not removed solely by age; additional retention/deletion rights await owner decision. (full NFR-014)	F-S2-04	S2 proposed	VAL-024 (planned)
NFR-015	Safe diagnostics: response errors expose no credentials, session tokens, protected reason or internal stack traces; operational logs must avoid secrets and preserve enough non-sensitive context to investigate failed mutations. Exact logging fields/retention are engineering decisions. (full NFR-015)	SYS-01	S1 / S2 proposed / S3 proposed	VAL-034, VAL-036 (planned)
NFR-016	Reporting correctness: for every defined Tutor Summary category, count must equal its corresponding accessible row set under the same time/state predicates; no completion is inferred from elapsed time. Treatment of in-progress sessions remains open. (full NFR-016)	F-S3-01	S3 proposed	VAL-028, VAL-029 (planned)

Q01–Q32 accountability

Confirmed meanings and full Q-to-FR/BR/VAL crosswalk remain in SRS §12.2.

Decision	Owner	Sprint
Q01	F-S1-04	S1
Q02	F-S1-01	S1
Q03	F-S1-02	S1
Q04	F-S1-02	S1
Q05	F-S1-04	S1
Q06	F-S1-02	S1
Q07	F-S2-01	S2 proposed
Q08	F-S2-01	S2 proposed
Q09	F-S2-02	S2 proposed
Q10	F-S2-02	S2 proposed
Q11	F-S2-02	S2 proposed

Decision	Owner	Sprint
Q12	F-S2-02	S2 proposed
Q13	F-S2-02	S2 proposed
Q14	F-S2-02	S2 proposed
Q15	F-S2-02	S2 proposed
Q16	F-S2-02	S2 proposed
Q17	F-S2-03	S2 proposed
Q18	F-S2-03	S2 proposed
Q19	F-S2-03	S2 proposed
Q20	F-S2-03	S2 proposed
Q21	F-S2-04	S2 proposed
Q22	F-S2-04	S2 proposed
Q23	F-S2-04	S2 proposed
Q24	F-S2-04	S2 proposed
Q25	F-S2-04	S2 proposed
Q26	F-S2-05	S2 proposed
Q27	F-S2-05	S2 proposed
Q28	F-S1-04	S1
Q29	SYS-01	S1-S3/Lab5+
Q30	F-S1-05 (Booked/Past); F-S2-01 and F-S2-03 (Cancelled); F-S3-01 (summary/report)	S1 / S2 proposed / S3 proposed
Q31	F-S3-01	S3 proposed
Q32	F-S2-05	S2 proposed

Sprint 1 acceptance and test mapping

All 35 AC and all 39 VC/TEST identifiers below are **planned evidence anchors, not executed results**. IDs, scenarios and expected outcomes are taken from requirements.md §9 and §13; this document only assigns feature ownership. Shared entries do not dilute primary accountability.

Acceptance criteria: AC-S1-01..35

AC ID	Primary owner	Other impacted owner	Baseline scenario and expected result	Planned VC reference
AC-S1-01	F-S1-01	—	Existing valid Customer credentials — Authenticated principal is Customer; user sees correct own identity/role	VC-01/03 (planned)
AC-S1-02	F-S1-01	—	Existing valid Tutor credentials — Authenticated principal is Tutor; own-schedule operations are available	VC-01/03 (planned)
AC-S1-03	F-S1-01	—	Invalid password or unknown credentials — Access denied; no protected identity/session returned	VC-02 (planned)
AC-S1-04	F-S1-01	—	Authenticated user — Protected action rejected according to documented session lifecycle	VC-04 (planned)
AC-S1-05	F-S1-01	—	Unauthenticated browser or caller — No operation granted and no private payload disclosed	VC-05 (planned)
AC-S1-06	F-S1-01	—	Authenticated Customer — Backend denies request; Tutor schedule unchanged	VC-06 (planned)
AC-S1-07	F-S1-01	F-S1-05	Tutor A and B have different schedules — No protected records or writes under B's identity	VC-07/31 (planned)
AC-S1-08	F-S1-02	—	Own authorized Tutor schedule; valid future Bangkok start — Exactly one 60-minute offered Slot is persisted and available on schedule refresh	VC-08/14 (planned)
AC-S1-09	F-S1-02	—	Same Tutor offers 13:00–14:00 — New Slot rejected, existing Slot unchanged	VC-09 (planned)
AC-S1-10	F-S1-02	—	Same Tutor offers 13:00–14:00 — Adjacent Slot allowed by non-overlap rule, subject to independent validity	VC-10 (planned)
AC-S1-11	F-S1-02	—	Tutor A offers 13:00–14:00 — Different Tutor offer permitted	VC-11 (planned)
AC-S1-12	F-S1-02	—	Invalid or past date/start — No invalid Slot persisted, no collateral mutation	VC-12 (planned)
AC-S1-13	F-S1-02	—	Same Tutor proposes two overlapping Slot writes concurrently — Database never contains two overlapping currently offered Slots for that Tutor	VC-37 (planned)

AC ID	Primary owner	Other impacted owner	Baseline scenario and expected result	Planned VC reference
AC-S1-14	F-S1-02	F-S1-03	Browser timezone is not Bangkok — Same intended Bangkok appointment date and hour displayed	VC-13 (planned)
AC-S1-15	F-S1-03	—	Customer logged in; eligible offered Slot exists — Selectable Tutor and Bangkok appointment times shown without private other-Customer details	VC-15 (planned)
AC-S1-16	F-S1-03	—	Offered Slot occupied or inside Q05 cutoff — Slot is not selectable as bookable and never reveals its Customer; proposed default: show only currently bookable offers, pending the reviewed UI contract in TBD-S1-04	VC-15/22 (planned)
AC-S1-17	F-S1-03	—	Displayed offer becomes ineligible before submission — Backend rechecks and rejects; UI does not report a successful Booking	VC-22 (planned)
AC-S1-18	F-S1-03	—	Device locale is another timezone — Bangkok time meaning does not drift with device timezone	VC-13/15 (planned)
AC-S1-19	F-S1-04	—	Eligible unoccupied Slot, Customer logged in without overlapping Booking — One Booked record is committed with correct Customer, Tutor and Slot identifiers	VC-16 (planned)
AC-S1-20	F-S1-04	—	Slot begins 15:00; backend `T_elig` is exactly 14:00:00 — Exact 60-minute cutoff accepted if all other checks pass and transaction subsequently commits	VC-17 (planned)
AC-S1-21	F-S1-04	—	Slot begins 15:00; backend `T_elig` is 14:00:01 — Less-than-60-minute cutoff rejected, no Booking or occupation	VC-18 (planned)
AC-S1-22	F-S1-04	—	Customer A owns active Booking on Slot X — Second request rejected, first Booking preserved	VC-19 (planned)
AC-S1-23	F-S1-04	—	Customer holds Tutor A 13:00–14:00 — Reject overlapping appointment even across Tutors	VC-20 (planned)
AC-S1-24	F-S1-04	—	Customer holds an interval ending 14:00 — Adjacency itself not blocked; other checks still apply	VC-21 (planned)
AC-S1-25	F-S1-04	—	Two Customers simultaneously request one eligible Slot — At most one committed Active Booking; no false second success	VC-25 (planned)
AC-S1-26	F-S1-04	—	Same Customer concurrently requests distinct overlapping Tutor Slots — No two overlapping Active Bookings committed for Customer	VC-26 (planned)

AC ID	Primary owner	Other impacted owner	Baseline scenario and expected result	Planned VC reference
AC-S1-27	F-S1-04	F-S1-02	Previously eligible Slot becomes invalid/occupied or persistence fails — No phantom success, partial Booking or inconsistent occupied state	VC-22/27/33 (planned)
AC-S1-28	F-S1-04	F-S1-01	Customer alters request body to impersonate other identity/Tutor — Owner derived from trusted session; Tutor from actual Slot, not supplied roles	VC-24 (planned)
AC-S1-29	F-S1-04	—	Customer repeats request while first outcome might be unknown — Exclusivity and Customer-overlap invariants hold; exact retry response remains contract TBD	VC-38 (planned)
AC-S1-30	F-S1-05	—	Customer already has a committed Booking — Correct Booking identity, Tutor, Bangkok interval and Booked status	VC-28 (planned)
AC-S1-31	F-S1-05	—	Customer A has Booking; Customer B knows its ID — No protected Booking information disclosed	VC-29 (planned)
AC-S1-32	F-S1-05	—	Tutor owns current Booking schedule — Authorized Booking visible on own schedule only	VC-30 (planned)
AC-S1-33	F-S1-05	—	Tutor B knows Tutor A schedule ID — No protected foreign Tutor Booking disclosed	VC-31 (planned)
AC-S1-34	F-S1-05	—	Booked 13:00–14:00 appointment now ended — Booking still Booked; may show Past; no Completed/attendance assertion	VC-32 (planned)
AC-S1-35	F-S1-04	—	Slot starts 15:00; Booking HTTP request reaches server at 13:59:59 but waits for contention until final transactional `T_elig` is 14:00:01 — Reject as less than 60 minutes remaining, preserve Slot and all previously committed Bookings, and do not report success merely because HTTP arrival preceded the cutoff	VC-39 (planned)

Verification cases: VC/TEST-S1-01..39

VC / TEST ID	Primary owner	Other impacted owner	Baseline scenario and expected result	Status
VC-S1-01/TEST-S1-01	F-S1-01	—	Existing Customer and Tutor demo credentials → each logs in — Correct own identity/role; no cross-role grant	Planned, not run
VC-S1-02/TEST-S1-02	F-S1-01	—	Invalid password → login attempt — Authentication refused; no valid session/identity exposed	Planned, not run

VC / TEST ID	Primary owner	Other impacted owner	Baseline scenario and expected result	Status
VC-S1-03/TEST-S1-03	F-S1-01	—	Logged-in user → current identity query — Authenticated user's own ID and role, not arbitrary submitted identity	Planned, not run
VC-S1-04/TEST-S1-04	F-S1-01	—	Logged-in user → logout → reuse prior access — Protected access rejected according to chosen session lifecycle	Planned, not run
VC-S1-05/TEST-S1-05	F-S1-01	—	Anonymous caller → private Booking / create Slot / book — All protected actions denied without protected data	Planned, not run
VC-S1-06/TEST-S1-06	F-S1-01	—	Customer → attempts Tutor-only create action — Rejected by backend, even when request is crafted manually	Planned, not run
VC-S1-07/TEST-S1-07	F-S1-01	—	Tutor A → attempts to create/view private schedule of Tutor B — Access rejected or B's records absent; A's own schedule unaffected	Planned, not run
VC-S1-08/TEST-S1-08	F-S1-02	—	Authorized Tutor; future date → create one Slot — Exactly one offered 60-minute Slot persisted under that Tutor	Planned, not run
VC-S1-09/TEST-S1-09	F-S1-02	—	Tutor's offered Slot 13:00–14:00 → create 13:30–14:30 — Reject overlap; old Slot unchanged, no duplicate offer	Planned, not run
VC-S1-10/TEST-S1-10	F-S1-02	—	Tutor's offered Slot 13:00–14:00 → create 14:00–15:00 — Overlap rule permits adjacency; other validity checks remain	Planned, not run
VC-S1-11/TEST-S1-11	F-S1-02	—	Tutor A offers 13:00–14:00 → Tutor B creates same time — Allowed as distinct Tutor offer if valid	Planned, not run
VC-S1-12/TEST-S1-12	F-S1-02	—	Proposed Slot starts in the past/invalid → Tutor submits — Reject with no stored Slot or collateral mutation	Planned, not run
VC-S1-13/TEST-S1-13	F-S1-02	F-S1-03	Time shown by browser in another timezone → create/check Bangkok Slot — Tutor and Customer see same intended Bangkok appointment time	Planned, not run
VC-S1-14/TEST-S1-14	F-S1-02	—	Tutor owns offered Slot → opens schedule after refresh — Exact Slot and correct offered/occupied state still visible	Planned, not run
VC-S1-15/TEST-S1-15	F-S1-03	—	Customer logged in; eligible future offered Slot → browse — Tutor and time identifiable; no other Customer's private details exposed	Planned, not run

VC / TEST ID	Primary owner	Other impacted owner	Baseline scenario and expected result	Status
VC-S1-16/TEST-S1-16	F-S1-04	—	Eligible unoccupied Slot → Customer requests Booking — One persisted Booking, state Booked, own Customer and selected Tutor/Slot	Planned, not run
VC-S1-17/TEST-S1-17	F-S1-04	—	Slot at 15:00, backend `T_elig` is 14:00:00 — Exactly 60-minute Q05 lead time passes if otherwise valid; later commit does not retroactively invalidate a passing checked write	Planned, not run
VC-S1-18/TEST-S1-18	F-S1-04	—	Slot at 15:00, backend `T_elig` is 14:00:01 — Q05 lead time fails; no Booking/occupation	Planned, not run
VC-S1-19/TEST-S1-19	F-S1-04	—	Offered Slot already occupied → another Customer books it — Reject; previous Booking preserved and only one active claim remains	Planned, not run
VC-S1-20/TEST-S1-20	F-S1-04	—	Customer holds 13:00–14:00 Tutor A → books 13:30–14:30 Tutor B — Reject cross-Tutor Customer overlap with no second Booking	Planned, not run
VC-S1-21/TEST-S1-21	F-S1-04	—	Customer holds 13:00–14:00 → requests 14:00–15:00 — Customer-overlap check permits adjacent interval, subject to lead time	Planned, not run
VC-S1-22/TEST-S1-22	F-S1-04	F-S1-03	Selected Slot was eligible at browse but is taken/too soon by submission — Backend rejects stale selection; no false success	Planned, not run
VC-S1-23/TEST-S1-23	F-S1-04	F-S1-01	Invalid/missing/past Slot or unauthorized actor → booking attempt — Reject without claimed Slot or private data disclosure	Planned, not run
VC-S1-24/TEST-S1-24	F-S1-04	F-S1-01	Customer alters client-supplied user/Tutor ownership IDs — Persist Booking only for authenticated Customer and actual Slot Tutor, or reject	Planned, not run
VC-S1-25/TEST-S1-25	F-S1-04	—	Two distinct Customers submit concurrently for same eligible exclusive Slot — At most one committed Active Booking; other gets non-success; DB invariant holds	Planned, not run
VC-S1-26/TEST-S1-26	F-S1-04	—	One Customer submits concurrently for distinct overlapping eligible Slots of two Tutors — No two overlapping Active Bookings commit; no partial losing claim	Planned, not run
VC-S1-27/TEST-S1-27	F-S1-04	—	Persistence failure injected before Booking transaction finishes — No false success, no committed Booking or partial occupied Slot	Planned, not run
VC-S1-28/TEST-S1-28	F-S1-05	—	Customer creates successful Booking → refresh/restart app with same DB — Own Booking and identity/time/state retrievable unchanged	Planned, not run

VC / TEST ID	Primary owner	Other impacted owner	Baseline scenario and expected result	Status
VC-S1-29/TEST-S1-29	F-S1-05	—	Customer B knows Customer A's Booking ID → tries detail/list — Private Booking content not revealed	Planned, not run
VC-S1-30/TEST-S1-30	F-S1-05	—	Tutor A → inspect own schedule with Booking — Correct assigned Booking visible without exposing another Tutor's protected records	Planned, not run
VC-S1-31/TEST-S1-31	F-S1-05	—	Tutor B knows Tutor A's schedule/Booking identifiers → read attempt — Access denied/filtered; Tutor A records remain private	Planned, not run
VC-S1-32/TEST-S1-32	F-S1-05	—	Booking interval fully elapsed, no cancellation → open Booking — Business state remains Booked; may show Past; never Completed or assumed attended	Planned, not run
VC-S1-33/TEST-S1-33	F-S1-04	—	User submits failed/invalid request → reopen respective views — No new phantom Booking, no changed Slot occupancy from failed attempt	Planned, not run
VC-S1-34/TEST-S1-34	SYS-01	F-S1-01/02/03/04/05	Real app boot and seed setup → complete J-S1-01 then J-S1-02 through UI and DB — Full verified workflow, repeatable commands and actual test results recorded later	Planned, not run
VC-S1-35/TEST-S1-35	SYS-01	F-S1-01	Test invalid access and inspect tracked env/config — No plaintext stored passwords/secrets and no private-data leaks	Planned, not run
VC-S1-36/TEST-S1-36	SYS-01	F-S1-03/05	Benchmark local availability/details and keyboard-only walk-through — Record measurements/checklist; compare with proposed, not approved, UX/performance targets	Planned, not run
VC-S1-37/TEST-S1-37	F-S1-02	—	Two requests concurrently create overlapping future offered Slots for same Tutor — At most one overlapping offer commits; no partial side effects	Planned, not run
VC-S1-38/TEST-S1-38	F-S1-04	—	Customer duplicates Booking submission while first outcome is in flight or unknown — At most one Active Booking for a Slot; Customer overlap invariant preserved, response semantics defined later	Planned, not run
VC-S1-39/TEST-S1-39	F-S1-04	—	For 15:00 Slot, request arrives at 13:59:59 but transaction waits until `T_elig = 14:00:01` before final guarded write — Refuse too-late Booking with no partial occupancy, despite pre-cutoff arrival; use controlled server clock/transaction synchronization, not client timestamps	Planned, not run

Three separate real-database race obligations

Race	Owner	AC and VC/TEST evidence	Must prove
A: same Tutor creates overlapping offered Slots	F-S1-02	AC-S1-13; VC/TEST-S1-37	At most one conflicting current offer commits

Race	Owner	AC and VC/TEST evidence	Must prove
B: two Customers compete for one exclusive Slot	F-S1-04	AC-S1-25; VC/TEST-S1-25	At most one active claim commits, no false success
C: one Customer books overlapping Slots with different Tutors	F-S1-04	AC-S1-26; VC/TEST-S1-26	No overlapping active Bookings commit for that Customer

Changes to future-sprint validation or policy proposals require the SRS §13 approval gates. There is no claim that any of the above tests has been run.

Audit and approval gates

FR: 36/36 assigned; BR: 35/35 assigned; NFR: 16/16 assigned; Q: 32/32 assigned. No silent orphans. SYS-01 owns cross-cutting requirements while relevant features must still satisfy them.

S2/S3 assignments are proposals pending team approval in Issue #12. OD-001..015 remain open or conditional per SRS §13; OD-011/012 instructor Master/Theme unverified, so final sign-off is blocked. Proposed NFR-009/010 are not mandatory thresholds until approved.

Issue #10 PR into sprint1 requires @Tanaboonnnnn peer review; this document neither proves test passes nor grants stakeholder approval.

Part C: Whole-Product System Software Design Specification (SDS)

0. Document control and design authority

Field	Value
Deliverable	CPE334 Deliverable 1, Part C; GitHub Issue #11
Artifact	docs/system-sds.md, design draft v0.1.0, 3 November 2026
Product	One-to-one Tutoring Appointment System (Theme 1: Appointment & Scheduling)
Coverage	Whole-product architecture for Sprints 1–3; detailed implementation contracts remain feature-scoped
Author / required peer reviewer	@Tanaboonnnnn / @Chxtamos
Status	**PROPOSED ENGINEERING DESIGN — pending substantive peer review; NOT instructor-approved or implemented**
Intended integration	Issue branch -> reviewed PR into sprint1 -> later separately reviewed sprint1 -> main
Repo state inspected	Remote sprint1 at ba577db79ccee6c0f0861b761fb361bbb252b027 (3 Nov 2026); tracked files are AGENTS.md, README.md and docs/*.md; no application scaffold, package manifest, Prisma schema or CI was present

Field	Value
Source gates	Final instructor Master and official team Theme 1 allocation remain unverified (SRS OD-011/OD-012); do not infer formal sign-off

Order of authority. An instructor-issued *final* Master/change notice outranks the available draft handout. Until verified, use the reviewed stakeholder decisions Q01–Q32, whole-product SRS, Sprint 1 requirements, feature inventory, traceability, Issue #11 and root AGENTS.md. The documents describe different levels: business rules are normative outcomes; technology choices in this SDS are **engineering proposals awaiting peer approval**, not new stakeholder rules. Preserve all existing IDs and report conflicts before modifying them.

Boundary. This file selects a feasible architecture and explains verifiable invariants. It does **not** add app code, create a working API, run database tests, deploy to GCP, or finalize individual endpoint/field validation contracts. Part E Feature SDS/STS must be versioned and peer-reviewed **before** each corresponding feature's code. Sprint 2/3 placement remains proposed until Issue #12 is accepted.

1. Design objectives and decisions

The Sprint 1 minimum is a working **browser UI -> authenticated API/service -> durable relational database** slice: login/logout/current user, Tutor publishing individual 60-minute offered Slots, Customer availability discovery and exclusive Booking, authorized Customer/Tutor reads, and the three concurrency invariants. Records survive refresh and restart. Sprint 2 adds cancellation, one-time cross-Tutor rescheduling, withdrawn Slot history and durable private notices; Sprint 3 adds a Tutor-only summary. Payments, attendance confirmation, recurring/bulk Slots, automatic SLA or notifications by email/SMS are **not authorized** by the product baseline.

1.1 Engineering decision register

Decision	Selected design / reason	Trade-off and current approval
SD-01	A TypeScript modular monolith, not microservices: a single Express API exposes bounded identity, scheduling, Booking and future notice/report modules.	Smaller operational and review burden for two students; **proposed for peer approval**.
SD-02	React 19 + Vite 8, client-side navigation, accessible shared form/list/status components.	No SSR complexity for the accepted workflows; **proposed**.
SD-03	Node.js 24 LTS + npm 11 workspaces with one root lockfile; Express 5, TypeScript 5.9.	Matches the inspected development runtime and supports reproducible builds; **proposed**.
SD-04	PostgreSQL 18, Prisma 7 with PostgreSQL adapter, versioned SQL migrations; native PostgreSQL range/exclusion constraints supplement ORM checks.	Relational integrity is essential for races A/B/C; raw SQL constraints require review and DB-specific tests; **proposed**.
SD-05	Keep one immutable 60-minute time interval per Slot. Derive Tutor schedule from owned Slots and Bookings, not a separate writable schedule table.	Avoids drift and unnecessary entity state; a Tutor schedule is a **logical read projection**.
SD-06	Derive occupancy from an active Booking; do not independently toggle a fragile Slot.isBooked flag. Maintain Slot lifecycle Offered/Withdrawn for later history.	Simplifies atomic cancellation/reschedule and protects historical records; **proposed**.

Decision	Selected design / reason	Trade-off and current approval
SD-07	PostgreSQL unique/exclusion constraints + SERIALIZABLE transactions + deterministic row locks + bounded retries for genuine transaction aborts.	More careful migrations and error handling; selected to prove all three real-DB races.
SD-08	Use DB clock_timestamp() *after lock contention* at the final guarded eligibility decision, and UTC instants in storage/transport with Asia/Bangkok presentation.	Prevents the Q05 request-arrival-time bug; clock/rounding tests are mandatory.
SD-09	Local Argon2id password hashes and opaque, server-revocable, cookie-based sessions; roles and record ownership checked by API/service.	Simpler reliable logout than stateless unrevocable tokens; cookie and CSRF safeguards are mandatory.
SD-10	A single-origin production web/API deployment (API can serve built web assets), durable managed PostgreSQL and managed secrets on GCP later.	Avoids cross-origin cookie/CORS complexity; **planning only** for Lab 5.
SD-11	Structured JSON errors and response allowlists; generated request IDs, no secrets, stack traces or third-party record details.	Feature SDS specifies exact endpoints/DTOs, not this whole-system overview.
SD-12	No invented Tutor work hours, look-ahead maximum, start-minute grid, private data visibility or retry-key retention policy.	Unresolved stakeholder choices remain gates OD-001..015, not implicit defaults.

All SD-01..12 require review in Issue #11's PR. These selections are *decisions proposed for approval*, not evidence of running packages, applied SQL or instructor authorization.

1.2 Technology baseline (design pins, not installed app dependencies)

Layer / tool	Version target	Basis / implementation note
Node.js / npm	Node 24.x LTS; npm 11.x	Actual inspected machine: v24.14.0 / 11.18.0; choose Node 24 rather than introducing new Node 26 to this project.
Frontend	React 19.3.1, Vite 8.3.5, React Router 7.x	Candidate current registry versions checked 3 Nov; Router exact patch determined when installed.
API and validation	Express 5.3.0, TypeScript 5.9.3, Zod 4.6.7	End-to-end TypeScript, validated boundaries; deliberately choose mature TS 5.9 rather than a new major.
DB/ORM	PostgreSQL 18.x; prisma, @prisma/client and @prisma/adapter-pg **7.10.1** plus pg	Prisma 7 requires its supported driver-adapter/config path; maintain SQL migrations for exclusions/partial indexes.
Credential/session	argon2 0.45.2; Node crypto secure random and SHA-256 for session-token digests	Password hashes use Argon2id with distinct salts; token digests are **not** password hashes.
Tests	Vitest 5.1.0, Supertest 7.3.1, Playwright 1.64.1; real PostgreSQL	Versions were read from npm registry; no project test suite currently exists.
Local tooling	Git, Docker, PostgreSQL service/container, optional psql	Docker CLI detected (29.9.2); psql CLI was **not found on PATH**. No DB container or running DB was verified.

Version discipline: Record these as *proposed baseline pins*. During the scoped Part E implementation, check real peer-dependency compatibility, resolve patches using npm install, commit package-lock.json, use npm ci thereafter, and update this table only through an explained reviewed change. Do not claim that a package is installed merely

because npm registry reports it. The PostgreSQL 18 target must also be checked against the GCP managed offering and required extensions before Lab 5.

2. System architecture and component boundaries

~~~mermaid

flowchart LR

B["Browser (Customer / Tutor)"] --> W["React + Vite UI"]

W -->|same-origin HTTPS / JSON| A["Express 5 API"]

A --> I["Identity + sessions"]

A --> S["Tutor scheduling service"]

A --> K["Booking and transaction service"]

A --> N["Future notification / summary services"]

I --> D[("PostgreSQL (durable)")]

S --> D

K --> D

N --> D

~~~

- **UI:** renders navigation and the permitted controls, converts UTC instants for display in Asia/Bangkok, preserves form state on errors. UI checks are usability feedback **not authorization**.
- **Transport/API boundary:** authenticates the session, validates and normalizes input, imposes request/body limits, assigns a correlation ID, calls one application use case, and serializes an explicit data allowlist.
- **Domain/services:** keep time and Booking rules, role/record ownership, mutation transaction boundaries and feature-specific outcomes in one place. A controller must not implement a second inconsistent cutoff check.
- **Persistence:** Prisma Client manages typed access, migration provenance and transactions; reviewed parameterized SQL handles PostgreSQL row locking, constraints and DB-time sampling where required. No in-memory array acts as the source of truth.
- **Future capabilities:** Customer cancellation/reschedule and Tutor withdrawal/notice reuse the Booking service and Slot/Booking constraints. Tutor summary derives count and list from the same authorized query predicates; no independent source of state.

Boundaries: anonymous browser -> session-checked API is the primary trust boundary; API -> database uses a least-privileged account. A client-provided customerId, tutorId, user role, Booking owner, current status or cutoff timestamp is **never trusted**. Public Customer availability is a deliberately narrow projection, not the Tutor's restricted full schedule. API and web may be separately built in development but share one origin through the Vite proxy; production can serve prebuilt web assets through the API image.

Suggested future repository layout (none of these folders are created by Issue #11):

~~~text

package.json # private npm workspaces, pinned Node/npm; scripts
~~~

package-lock.json # committed after first install

apps/web/ # React/Vite, routes, page components, API client

apps/api/src/ # Express controllers, auth, services, DB adapter

apps/api/prisma/ # Prisma schema, versioned migrations, seed

apps/api/prisma.config.ts # Prisma 7 connection/migration/seed configuration

apps/api/test/ # API, DB-integrity and concurrency tests

docs/ # product SRS, traceability, System SDS, Feature SDS/STS

~~~

No separate payment, background-queue, cache, notification-provider or microservice infrastructure is required by Sprint 1.

3. Relational domain, ownership and evolution

3.1 Entity relationship view

~~~mermaid

erDiagram

USER ||--o{ SESSION : authenticates

USER ||--o{ SLOT : "tutor owns"

USER ||--o{ BOOKING : "customer owns"

SLOT ||--o{ BOOKING : "used by over history"

BOOKING ||--o| RESCHEDULE_HISTORY : "one successful change max"

BOOKING ||--o| NOTIFICATION : "optional tutor-cancel notice"

USER ||--o{ NOTIFICATION : "customer recipient"

~~~

A **Tutor Schedule** is the filtered projection of one Tutor's Slots and the currently assigned Bookings. It is **not** a second mutable appointment record. This keeps Q02 ownership, Q06 overlap and Q31 counts attached to authoritative relations.

3.2 Proposed entities and keys

Entity (stage)	Essential columns / relationships	Validation and persistence invariant
User (S1)	id UUID PK; email with normalized unique index; passwordHash; role Customer/Tutor; isActive; timestamps	Exactly one effective role per account; active account for authentication; role/ownership verified server-side, never from a client body. No self-registration is in scope.
~~~

Entity (stage)	Essential columns / relationships	Validation and persistence invariant
Session (S1)	id UUID PK; userId FK -> User; unique tokenDigest; createdAt; expiresAt; revokedAt (nullable); optional revocationReason for audit (proposal)	Store digest, not raw cookie token. Logout revokes **presented Session only**; proposed credential reset/compromise handling revokes **all** relevant User sessions. No protected request may use a revoked/expired token or inactive User (OD-005).
Slot (S1 fields, S2 lifecycle)	id UUID PK; tutorId FK -> User; startsAt and endsAt TIMESTAMPTZ; lifecycle Offered or Withdrawn; createdAt; withdrawnAt nullable	Interval exactly 60 minutes; immutable Tutor/time/ID; offered Slots of one Tutor never overlap; withdrawn Slot never reactivated under the same ID.
Booking (S1 fields, S2 extension)	id UUID PK; customerId FK -> User; currentSlotId FK -> Slot; startsAt/endsAt current interval snapshot; status Booked or Cancelled; cancellationActor and tutorCancellationReason nullable (S2); timestamps	One active Booking per Slot; one Customer's active windows never overlap; interval copied from locked Slot, never accepted from a client; current Tutor derives from Slot.tutorId.
RescheduleHistory (S2 only)	id UUID PK; bookingId FK -> Booking **UNIQUE**; old/new Slot IDs and Tutor IDs; old/new intervals; changedAt	Successful change appends exactly one immutable record while retaining Booking ID. Rejected change appends none and uses no quota.
Notification (S2 only)	id UUID PK; recipientCustomerId FK -> User; bookingId FK -> Booking; kind TutorCancelled; createdAt; readAt nullable	One relevant private notice per successful Tutor cancellation, persisted in the same transaction; readAt never deletes the notice. Reason may be safely projected from owning Booking rather than duplicated.

- Slot -> Booking is **one-to-many historically**, but **zero-or-one active**. Cancelled Bookings keep their Slot history and no longer occupy it. Slot Offered means **published**, not necessarily free: occupancy is calculated from Booking status Booked.
- Past is a derived display classification for Booked appointments whose **end** is earlier than the evaluation instant; it is **not** a Booking status, and the application must never invent Completed or attendance.
- A Customer cancellation sets Booking Cancelled and leaves its original Slot Offered; another new Booking must still pass Q05 independently. A Tutor cancellation sets Booking Cancelled and original Slot Withdrawn **in one transaction**. Direct withdrawal while an active Booking exists is forbidden.
- On reschedule (S2), retain Booking.id, move currentSlotId and current interval, write history atomically, free the original offered Slot and claim the destination. Rescheduling to a different Tutor is valid when all rules pass. Prior-Tutor historical visibility is **not** assumed (OD-015).
- Optional reporting fields, Tutor profile, teaching subject, room, payment, price or attendance are **not** mandatory and must not be added on invented stakeholder authority.
- FKs ensure stable ownership references; User role cannot be inferred from an arbitrary FK alone, so service authorization additionally validates role/active status. The database user is not granted app-user impersonation rights.

3.3 Native PostgreSQL constraints (migration intent, **not executed SQL**)

Prisma schema alone cannot express the required conditional interval/exclusion guarantees in the chosen design. Part E must keep the following *reviewed migration logic* in a versioned SQL migration, test applying it against a fresh

PostgreSQL 18 database, and ensure Prisma-generated migrations **do not drop** these constraints. Actual column names/types must match the implemented schema before applying the snippets.

~~~sql

-- Requires btree_gist to compare UUID equality inside GiST exclusions.

CREATE EXTENSION IF NOT EXISTS btree_gist;

ALTER TABLE "Slot"

ADD CONSTRAINT slot_exactly_one_hour

CHECK ("endsAt" = "startsAt" + INTERVAL '60 minutes');

ALTER TABLE "Slot"

ADD CONSTRAINT offered_slot_no_overlap_per_tutor

EXCLUDE USING gist (

"tutorId" WITH =,

tstzrange("startsAt", "endsAt", '[)') WITH &&

)

WHERE ("lifecycle" = 'Offered');

-- Both cancelled and rescheduled history may refer to a Slot,

-- but at most one current Booked record may occupy it.

CREATE UNIQUE INDEX booking_one_active_per_slot

ON "Booking" ("currentSlotId")

WHERE "status" = 'Booked';

ALTER TABLE "Booking"

ADD CONSTRAINT booked_customer_no_overlap

EXCLUDE USING gist (

"customerId" WITH =,

tstzrange("startsAt", "endsAt", '[)') WITH &&

)

WHERE ("status" = 'Booked');

-- Protect the duplicated current appointment interval from diverging

-- from the immutable selected Slot, including reschedule updates.

ALTER TABLE "Slot"

ADD CONSTRAINT slot_id_window_unique

UNIQUE ("id", "startsAt", "endsAt");
~~~

ALTER TABLE "Booking"

ADD CONSTRAINT booking_current_slot_window_fk

FOREIGN KEY ("currentSlotId", "startsAt", "endsAt")

REFERENCES "Slot" ("id", "startsAt", "endsAt")

ON UPDATE RESTRICT;

~~~

Migration preconditions: all identifiers not-null where needed; UUID columns really use UUID; timestamps use TIMESTAMPTZ; enums/columns have the exact quoted values above or their implemented equivalents. Add explicit FK/indexes for customerId, tutorId, currentSlotId and history/notice references, and check nonblank required values in the appropriate feature contract. The database exclusion predicates are **only** for currently Offered Slots and **only** for Booked Bookings: past *Booked* still counts as active, whereas withdrawn historical Slots do not block new distinct offers (Q32). Adjacent half-open intervals never conflict.

The preceding constraints directly enforce **same-Tutor offered overlap** (Race A), **single active owner per Slot** (Race B) and **same-Customer active time overlap** (Race C). They do **not** by themselves enforce the cross-table lifecycle invariant:

I-L (Q26/Q27/Q32, FR-033/034, BR-026/032/034): For every committed Booking whose status is Booked, the referenced Slot **must** have lifecycle Offered. Conversely, a committed Withdrawn Slot **must never** have any active Booked Booking. This holds across all application instances, including a direct SQL mutation that bypasses an application service guard. A historical Withdrawn Slot cannot transition back to Offered under the same ID.

Required database enforcement contract (to implement and prove in the Part E migrations, not executable SQL supplied here):

1. Install a PostgreSQL **immediate BEFORE INSERT/UPDATE row trigger on Booking** for changes affecting status, currentSlotId or the interval. When the resulting Booking is Booked, lock the referenced Slot row with SELECT ... FOR UPDATE (within the writer's transaction), then reject unless lifecycle is Offered, the Slot is still eligible, and the immutable Slot interval matches the Booking. For **new Booking INSERT**, this guard also samples the DB-authoritative Q05 clock *after* required locks, as clarified in §§4 and 7.3. The existing unique/exclusion constraints remain in force. The runtime service must acquire the §7.1 locks **before** changing Booking; the trigger is a final DB guard even when a service is bypassed.
2. Install a PostgreSQL **immediate BEFORE UPDATE lifecycle trigger on Slot**. On Offered -> Withdrawn, the updating transaction already holds the Slot row lock; reject if any Booked Booking references it. On Withdrawn -> Offered, reject unconditionally (Q32). Do not permit arbitrary changes to Slot ID/Tutor/interval or DELETE of an occupied Slot. For Tutor cancellation, change the Booking to Cancelled **before** withdrawing its Slot within one atomic transaction, after obtaining all locks in §7.1 order.
3. Both trigger paths must use the same serialized Slot row for the target Slot; a competing Booking/withdrawal writer must wait and then re-read lifecycle/occupancy on a fresh transaction view or abort/retry on Serializable serialization failure. Triggers must throw a non-success error so the entire transaction rolls back, not silently repair partial state. The database account used by the API must not have privilege to disable triggers. An unexpected direct SQL writer may deadlock against the documented service lock order; that attempt must abort/retry, **never commit an invalid lifecycle**.
4. **Implementation gate:** Part E must validate actual PostgreSQL trigger firing order, locking, MVCC visibility and Serializable failure behavior with a disposable real DB. If the proposed immediate trigger/locking protocol cannot demonstrate I-L at commit under all tested interleavings, revise the implementation contract (e.g.,
~~~

additional DB serialization/constraint strategy) **before** accepting the feature. Documentation alone does not prove the triggers safe. Do not defer enforcement as optional S2 work: the Booking guard belongs to S1 and the withdrawal guard must exist before S2 withdrawal is enabled.

Traceable proof: S1 F-S1-04/STS tests direct SQL attempts to insert a Booked Booking against a Withdrawn Slot once the lifecycle exists; S2 F-S2-05 and F-S2-03/STS test direct withdrawal of an occupied Slot and simultaneous Booking-versus-withdrawal; SYS-01 checks the resulting committed Slot/Booking rows, error response and rollback. See the inter-operation cases in §7.5. Any S1-only migration whose Slot enum does not yet expose Withdrawn must record the planned forward-compatible gate, not claim S2 lifecycle was already tested.

4. Time model and business transitions

- **Business timezone:** IANA Asia/Bangkok, UTC+07:00 for all stakeholder-facing date/time calculations and display (BR-029/Q29).
- **Storage/transport:** TIMESTAMPTZ instants in PostgreSQL and RFC 3339 ISO-8601 timestamps with an explicit offset on wire, normalized to UTC Z in JSON responses. Reject timezone-free date-time strings in mutation input. Render with an explicit Asia/Bangkok formatter; browser timezone or clock cannot affect eligibility.
- **Intervals:** half-open [startsAt, endsAt); overlap exactly when a.start < b.end AND b.start < a.end. Exact adjacency is permitted for one Tutor's offers and a Customer's active Bookings (Q06/Q28).
- **Tutor creation:** future 60-minute Slot; do **not** silently apply the **new Booking** 60-minute cutoff to Slot creation; proposed hours, horizon and minute grid stay OD-001..003.
- **New Booking (Q05):** S - T_elig >= **60 min**, equality passes. T_elig is a fresh DB-authoritative instant obtained **inside the transaction after relevant lock/contention waits and immediately before the final guarded write**. It is **not** HTTP arrival time, transaction start time, client time or commit time.
- **Customer cancellation (Q07, S2):** start minus authoritative decision >= **30 min**, equality passes; reopen original Slot but Q05 still applies to later claims.
- **Reschedule (Q10/Q11, S2):** both original appointment and destination start are >= **60 min** away at authoritative decision, equality passes; at most one successful reschedule (Q16).
- **Tutor cancellation (Q18, S2):** start minus authoritative decision >= **60 min**, equality passes; requires meaningful nonblank reason and withdraws Slot.
- **Q30:** status Booked/Cancelled only; Past after interval end is derived, never Completed. How *in-progress* lessons fit the S3 summary is still OD-006.

Q05 contention example: 15:00 Slot, request arrives 13:59:59, but waits for a row lock until the authoritative guarded instant is 14:00:01. The request **fails** (59m59s remaining). If the guarded instant is exactly 14:00:00 and all other checks pass, a commit *after* that instant does not itself invalidate eligibility. Always revalidate upon retry of an aborted transaction; do not reuse an earlier T_elig.

Operational precision (OD-005, F-S1-04): The authoritative Q05 guard is **inside the PostgreSQL Booking INSERT trigger**, after the relevant User/Customer and Slot locking protocol in §7.1 and before the Booking row can be accepted; a prior HTTP/controller check is only advisory. Every valid mutation path must acquire the same conflict-serialization rows so competing Booking, cancellation and withdrawal operations cannot produce a *new* conflict-capable wait after this guard. PostgreSQL unique/exclusion checks can still wait implicitly if some writer bypasses the expected lock protocol. An implementation must not claim success from a T_elig sampled before such an unaccounted wait: its Part E transaction adapter must demonstrate a **no-post-guard-contention invariant** with real DB tests, or explicitly abort and retry the whole transaction with a fresh DB clock on detecting an unaccounted wait. If detection cannot be proven reliably, the design is **blocked for code acceptance** until an alternative DB

guard/serialization strategy is verified. Do not replace this with a blanket commit-time cutoff: SRS Q05 permits a genuinely valid guarded check whose commit happens later. See §7.3 and required barrier case VC/TEST-S1-39 in §7.5.

5. Authorization, authentication and data minimization

5.1 Server-enforced role and record matrix

Legend: **own** means tied to the authenticated principal/actual entity ownership, **no** means forbidden, **public policy TBD** must not be interpreted as permitted anonymous access. The stage column is the proposed delivery stage, not a claim that code exists.

Operation	Anonymous	Customer	Tutor/Staff	Stage
Submit credentials on login screen	login only	login	login	S1
Get current identity and logout	no	own	own	S1
Publish/read Tutor's restricted Slots/schedule	no	no	own Tutor schedule only	S1
Discover narrow availability	**no unless approved**	authenticated, privacy-filtered	no Customer privilege by Tutor role	S1
Book an eligible offered Slot	no	as authenticated Customer	no	S1
Read private Customer Booking list/detail	no	owned Bookings only	no global Customer lookup	S1
Read Tutor's attached Booking schedule	no	no	own authorized Tutor schedule only	S1
Cancel or reschedule Customer Booking	no	owned eligible Booking only	no via Customer route	S2
Tutor-cancel assigned Booking with reason	no	no	currently assigned Tutor only	S2
Withdraw unoccupied future Offered Slot	no	no	owner Tutor, **no** if active Booking	S2
Read private cancellation notice/reason	no	addressed Customer / owned cancelled Booking only	no unrelated record or prior-Tutor privilege	S2
Tutor Summary counts and lists	no	no	own Tutor scope only	S3
Any foreign Customer/foreign Tutor record	no	no	no	all

Every record query is scoped on the server by session principal + actual customerId/Slot.tutorId, including nested detail IDs, list filters, pagination, exports (if ever approved), and error branches. For Tutor reads join the Booking's current Slot to its actual Tutor; do not grant global Customer visibility. For historical cross-Tutor movement, keep OD-015 closed-by-explicit-decision **before** revealing anything to a former Tutor. Frontend hiding of controls cannot substitute for API checks.

5.2 Credential and session contract proposal (OD-005 gate)

1. **Accounts:** pre-provisioned Customer/Tutor accounts for Sprint 1. Validate a canonicalized, uniquely indexed email; use Argon2id with unique salt and configurable reviewed work factors. Never store plaintext passwords, seed shared known production passwords, expose hash fields in JSON or log credentials.
2. **Login:** validate input and account active state, verify Argon2id hash, issue a cryptographically random **at least 256-bit opaque session token** (not a predictable UUID). Persist only a SHA-256 digest with userId, creation, expiration and revocation state. Send raw token only via HttpOnly cookie.
3. **Cookie:** Secure, HttpOnly, SameSite=Lax, Path=/, no Domain in HTTPS production. A non-Secure local-development exception may be used **only** for localhost HTTP and never in production; document the local cookie name/behavior in F-S1-01.
4. **Expiry: OD-005 candidate policy, NOT approved:** eight-hour absolute expiry from createdAt, with no implicit refresh; a protected request checks token digest, expiresAt > server time, revokedAt IS NULL, User.isActive and effective role against persisted state on each request. An expired cookie never restores access, even if the browser retains it.
5. **Revocation and replacement policy (OD-005 proposal; approval required in F-S1-01):** a normal **login** creates one new Session and leaves other valid Sessions unchanged (no hidden rotation); **logout** transactionally revokes only the Session presented by the cookie and acknowledges completion/clears that cookie **after DB commit**. If optional explicit **session rotation** is added later, revoke the old Session and create its replacement in **one DB transaction**, then issue the new cookie only after successful commit; an old token must never work after rotation. A **password/credential change** (not an S1 feature) is proposed to revoke *all* prior Sessions for that User and create one replacement atomically if the authenticated change succeeds. An authorized **compromise response** (not an S1 feature) would revoke *all* Sessions without implicitly creating a new token. **User deactivation** (future administrative action) must deny every token immediately on the next protected request by User.isActive check and should revoke all User Sessions in the same transaction as deactivation. No password-change, compromise or administrative UI/API is authorized by this SDS.
6. **Atomicity/failure semantics:** any failed logout update or optional rotation/change transaction is a non-success, not a claim of revoked/issued state; do not deliver a new session cookie until its persisted record commits. Logout is idempotently safe for a previously revoked presented token (never grants access). Unknown network outcome is reconciled by checking current session validity rather than assuming rollback. Exact TTL, all-session revocation triggers, CSRF-token format and rate limiting remain **OD-005** engineering decisions subject to peer approval.
7. **Browser safeguards:** same-origin production; CSRF token tied to the session plus server Origin/Referer checks for cookie-authenticated mutation routes. Enforce HTTPS and validate reverse-proxy trust configuration. No auth token in browser localStorage or client-controlled role claims.
8. **Failure handling:** use non-enumerating login errors, input size limits and bounded login-attempt protections; specific rate limits/password policy and expiry/refresh decisions require F-S1-01 review under OD-005. Authenticated foreign-record errors disclose no private payload.

Proposed auth negative-test matrix (F-S1-01 STS, VAL-001/002/034/036):

Precondition / action	Expected persisted state and protected API result
Login twice from different browsers (normal login)	Two independent valid Sessions (unless future approved policy changes); logging out one does not revoke the other.

Precondition / action	Expected persisted state and protected API result
Logout with cookie A, then reuse A	Session A revoked in DB after successful logout transaction; stale A denied on /current-user and every protected resource; cookie B from independent login remains valid.
Optional rotation or successful credential change (future)	One atomic replacement and old-token revocation for rotation, or all old Sessions revoked for credential change; every old cookie denied and only committed new cookie accepted. Inject failure and assert no partially delivered replacement.
Authorized compromise revoke-all (future)	All existing Sessions invalid, no fresh Session created implicitly; old cookies denied.
Deactivate User (future) while a session exists	A protected API call made after deactivation denies access even if revokedAt was not yet observed; deactivation and bulk revocation tested atomically when implemented.
Now >= expiresAt, manually replay still-present cookie	401/non-success and no protected fields; subsequent login requires fresh valid credentials, not implicit renewal.
Invalid/unknown credentials, wrong role, forged owner ID, invalid CSRF or revoked Session	Sanitized non-success without protected payload, credential enumeration, session token or stack trace.

These are **planned API and persistence tests**, not executed results. Explicit test fixtures and error status mapping belong to F-S1-01 Feature SDS/STS; the eight-hour expiration, bulk invalidation and future rotation behaviors are proposed OD-005 choices, not confirmed stakeholder policy.

5.3 Data exposure contract

- **Customer availability:** only an approved safe Tutor label/ID, Slot ID and UTC interval, plus agreed availability indication; **never** another Customer's Booking, email/phone, cancellation reason or full restricted schedule.
- **Customer own Booking:** Booking ID, relevant Tutor/Slot/time, status, and only that Customer's approved history/reason. Cross-customer list/detail guesses reveal no data.
- **Tutor schedule:** only owned Slots and permitted Booking fields. Customer identity display remains unapproved; use the minimum necessary representation and obtain approval in F-S1-05 API/UI contracts.
- **Notice (S2):** only the recipient Customer can reread; reason additionally appears in that Customer's cancelled Booking details. Reading must not delete or automatically age-expire it (Q24/25). Data deletion/retention and prior-Tutor history are open OD-008/015.
- **Logs/errors:** redact cookie, token, password/hash, personal Booking and private reason. Emit non-sensitive correlation IDs and structured failure codes only. No raw SQL errors, internal stack traces or secrets in responses.

6. Shared API and UI contracts

6.1 Shared API conventions (not feature-specific endpoint signatures)

- Same-origin HTTPS JSON; path prefix proposed /api/v1. Auth operations conceptually cover login, current-user retrieval and logout; Slot/availability/Booking endpoints and exact URL/method combinations are **deferred to the relevant Part E api-spec.md**.
- JSON keys use lowerCamelCase; IDs use opaque UUID strings; instants use RFC 3339 UTC strings with Z. Pagination/ordering defaults, safe Tutor labels and detailed request/response DTOs are **not frozen** here (OD-004/009).

- Validate path, query and JSON bodies with Zod and server checks (types, length/size, ISO offset, 60-minute arithmetic, state and identity). Reject unknown privileged identity/status fields; construct writes from trusted session and locked DB records. Parameterize all SQL.
- On successful *mutations*, only return confirmed committed outcomes; do not imply a Booking exists before commit. Read results may become stale; a displayed Available marker is not a lease or lock.
- Standard candidate response envelope:

~~~json

{

"data": {

"id": "server-generated-uuid",

"startsAt": "2026-11-08T08:00:00.000Z"

},

"meta": { "requestId": "opaque-correlation-id" }

}

~~~

~~~json

{

"error": {

"code": "SLOT_UNAVAILABLE",

"message": "This appointment is no longer available.",

"requestId": "opaque-correlation-id"

}

}

~~~

- **Proposed status vocabulary:** 400 malformed input; 401 no valid session; 403 wrong role without record detail; 404 missing/foreign record when existence would disclose privacy; 409 occupied/stale overlap or rejected conflict; 422 well-formed but invalid field/business condition; 429 rate limit; 500/503 internal or transient persistence failure, sanitized. Exact endpoint-specific mapping and stable error codes belong to Feature SDS/API Spec and tests. Error messages must not reveal whether a foreign Booking exists.
- Use request IDs for tracing. UTC wire timestamps round-trip to Bangkok displays exactly; server determines time comparisons, not the browser. Do not serialize Prisma objects/columns wholesale without response allowlists.

6.2 Screen inventory and navigation

Screen / state	Role and stage	Minimum behavior
Login / signed-out	Anonymous, S1	Validated login, generic auth failure, keyboard access and session continuity.
Customer availability	Customer, S1	Tutor + time discovery, loading/empty/no-match/error states, eligibility/refresh indication; bookable-only vs disabled items remains OD-004.
Customer Booking confirmation + My Bookings/detail	Customer, S1	Display only committed Bookings after successful write, own list/detail and accurate Booked/Past; refresh preserves data.
Tutor Slot publish and own schedule	Tutor, S1	Single start input with derived 60-min end, validation/errors, Offered/occupied distinction, own attached Bookings.
Customer cancel/reschedule and history	Customer, **S2 proposed**	Cutoffs, one-success quota, retained Booking ID, cross-Tutor selection, no partial confirmation.
Tutor cancellation/Slot withdrawal	Tutor, **S2 proposed**	Current assignment/ownership, nonblank reason, distinct cancelled vs withdrawn consequences.
In-app notices	Customer, **S2 proposed**	Private read/reread without automatic expiry; no broadcast.
Tutor Appointment Summary	Tutor, **S3 proposed**	Matching category counts and lists, correct owner scope; in-progress bucket OD-006.

Shared UI conventions: accessible labeled controls, visible focus, keyboard use, field-level validation plus server error banners, pending/disabled submit state (not a concurrency proof), explicit empty vs no-results states, retry controls for safe reads, confirmation only after committed write, and responsive phone/tablet/desktop layouts. App role navigation is based on current-user API, but API still enforces every permission. Use consistent loading skeletons/spinners, success, stale/conflict, offline, forbidden and not-found states. Avoid silently clearing a form after transient or validation errors; revalidate server-side on resubmit. Proposed performance (p95 <=2.0 s) and keyboard acceptance thresholds are OD-010 and **not approved NFR gates**.

7. Transaction protocol and three race proofs

7.1 Shared mutation invariants

1. **I-A (Q06):** at most one currently Offered Slot for a Tutor overlaps a given offered interval; one-hour duration, same-Tutor adjacency allowed.
2. **I-B (Q01):** at most one current Booked Booking uses any Slot; a failed attempt leaves no orphan reservation or false success.
3. **I-C (Q28):** one Customer has no overlapping current Booked intervals across Tutors; adjacency allowed.
4. **I-T (Q05/Q29):** time and validity are checked at authoritative post-contention T_elig; exact 60:00 is eligible, 59:59 is not.
5. **I-P (atomic persistence):** all accepted changes are committed together; a rejected, aborted or failed write leaves the previous committed state and non-success response. Past Booked stays Booked.

Global lock hierarchy for every domain mutation (SD-07 / OD-005): lock **all affected User principals in ascending UUID order** (including Customer and the currently assigned/selected Tutors), then **all affected Slot rows in ascending UUID order**, then **existing Booking rows in ascending UUID order**. Lock the required principal rows even if the operation seems to need only the Customer or Tutor: this provides a single agreed order across creation, booking, cancellation, reschedule and withdrawal. PostgreSQL Serializable isolation and the constraints/triggers in §3.3 are mandatory backstops, not substitutes for that order.

Operation	User locks first (ascending UUID)	Slot locks next (ascending UUID)	Booking locks last and guarded change
Tutor Slot creation (S1)	Authenticated Tutor	None (new Slot does not yet exist)	None; insert Offered Slot after Tutor lock, validate no overlap at DB constraint
Customer new Booking (S1)	Authenticated Customer **and selected Slot's actual Tutor**	Selected Offered Slot	No existing Booking required for new claim; read active conflicts after locks, trigger-guarded insert
Customer cancellation (S2)	Booking owner Customer **and current Slot's Tutor**	Current Slot	Current Booking; verify owner/status/cutoff; update to Cancelled, leaving Slot Offered
Customer reschedule (S2)	Booking owner Customer, **original Tutor and destination Tutor** (deduplicate/sort)	Original and destination Slots, sorted	Current Booking; validate current assignment and Q10/Q11, update same Booking and unique history atomically
Tutor cancellation (S2)	Current assigned Tutor **and owning Customer**	Current Slot	Current Booking; validate assignment/reason/Q18, set Booking Cancelled **before** withdrawing Slot and inserting private notice in same transaction
Tutor Slot withdrawal (S2)	Owning Tutor	Target Offered Slot	If active Booking discovered, reject; no direct mutation of an occupied Slot, then withdraw it

Non-authoritative discovery pre-read: Customer cancellation, reschedule and Tutor cancellation need the current Booking's Customer/current Slot/Tutor IDs to know which principal and Slot locks to take; booking and reschedule also need the selected destination's real Tutor. First perform an **unlocked, read-only lookup** of Booking/Slot references for lock-set discovery, *not* as an authorization or business-rule decision. Begin (or restart) a Serializable transaction, lock the complete discovered User set and Slot set in the global order, then lock/re-read the Booking and selected Slot(s). Verify that **all** discovered IDs, current assignments/status, relevant owners and intervals are unchanged. If any membership/assignment changed or a relevant row disappeared, abort and retry from a **fresh discovery** with no locks carried over; never add a missing earlier-order User/Slot lock while holding a later-order Booking lock. Only the post-lock state can authorize the actual write. Locking pre-reads are forbidden as the sole proof of current state. Subsequent triggers lock already-held Slot rows, and nonconforming writers must abort on deadlock/serialization/conflict rather than bypass invariants.

Part E lock-order proof obligation: review actual SQL/Prisma query order for **each row of the table**, instrument concurrent transactions that discover changed assignments between pre-read and locked re-read, and demonstrate retries/rollback without partial rows. A missing lock, unconstrained direct SQL writer or unaccounted post-guard wait is a failed proof gate, not an accepted shortcut.

7.2 Tutor Slot creation (Race A; F-S1-02)

1. Authenticate a live Tutor and validate candidate start/derived end from the request (no client tutorId authority).
2. Begin one database transaction (proposed Serializable); lock that Tutor principal row. Recheck active Tutor identity, future time and any *approved* calendar constraints.
3. Insert Offered Slot. PostgreSQL's conditional GiST exclusion rejects a same-Tutor overlapping Offered window even under simultaneous writers. Adjacent windows or same-time offers by **different** Tutors are permitted when otherwise valid.
4. Commit, then return success; on exclusion/serialization conflict, roll back and return a controlled non-success unless a bounded full retry can legitimately succeed. Never update a historical Withdrawn Slot to Offered.

Proof: Q06, FR-006, BR-006/034, NFR-004, F-S1-02, VAL-005, AC-S1-13, VC/TEST-S1-37. Use a synchronized barrier with overlapping starts; inspect committed Slot rows and verify the loser did not create a partial Slot.

7.3 Exclusive Booking (Races B/C and Q05; F-S1-04)

1. Authenticate current Customer and validate request contains a Slot reference, not a spoofable customerId/role/start timestamp.
2. Discover the selected Slot's real Tutor as a **non-authoritative pre-read**. Begin one database transaction with **Serializable isolation** and lock **both Customer and Tutor User rows in ascending UUID order**, followed by the selected Slot row. Revalidate that Slot.tutorId still matches the discovered Tutor and that the Customer remains active; on mismatch abort and restart discovery without adding an out-of-order lock. This serializes same-Customer and same-Tutor write paths under §7.1, not only the selected Slot.
3. Re-read Slot lifecycle Offered, immutable interval, occupancy and the Customer's **all-Tutor** Booked intervals inside the transaction. Compute availability from committed Booking relations, not a stale browser list.
4. Once all conflict-relevant principal/Slot locks are held, perform server-side preliminary validation. For the final authoritative Q05 decision, the **Booking INSERT row trigger** in §3.3 samples PostgreSQL **clock_timestamp() after its required Slot lock**, then evaluates Slot.start - T_elig >= 60 minutes *before accepting the new row*. It uses current locked Offered Slot state and DB-owned interval, not request time or a client field. A preliminary application time check is not T_elig.
5. The shared User/Slot locks and DB trigger prevent ordinary competing writes from introducing a fresh conflict-capable wait *after* T_elig: Race B shares the Slot lock and Race C shares the Customer lock, including with later S2 mutations. If a DB unique/GiST index check nevertheless waits on an unaccounted competing writer, **do not trust the earlier T_elig**. Part E must either prove no such post-guard wait can occur under the actual DB trigger/lock arrangement, or instrument/detect it and abort/retry the complete operation so the new attempt samples a fresh post-contention T_elig. Any attempt that cannot establish this proof is blocked, not marked as a successful Booking. Do not substitute a blanket commit-time time check that would reject an otherwise valid exact-boundary guarded decision.
6. Unique active-slot index blocks a second Customer on the same Slot (B); Customer range exclusion blocks overlapping Booked windows across Tutors (C), including separate application processes. Catch and classify exclusion/unique/serialization errors without treating them as successful claims.
7. Commit the Booking transaction; **only after confirmed commit** send success/Booking ID. A transaction rollback leaves no Booking and does not change occupancy, which is derived from the Booked row.

Proof B: Q01, FR-012, BR-001/034; F-S1-04, VAL-010, AC-S1-25 and VC/TEST-S1-25. **Proof C:** Q28, FR-013, BR-028/034; F-S1-04, VAL-011, AC-S1-26 and VC/TEST-S1-26. **Q05 proof:** FR-011, BR-005, VAL-008/009, AC-S1-35 and VC/TEST-S1-39. Force a **synchronized row-lock wait crossing** the exact 60-minute cutoff and assert the trigger's

T_elig occurs *after* that wait. Include a second fixture for an unexpected **index/constraint wait** after preliminary validation, prove it cannot silently reuse a stale T_elig, and inspect the committed DB state. Include same-Customer adjacent intervals as permitted control cases. These are verification obligations, not claims of observed DB behavior.

7.4 Failure, retry, and later transitions

- **Rollback and retry:** handle known PostgreSQL SQLSTATE 40001 (serialization) and 40P01 (deadlock), including their ORM equivalents (Prisma P2034), by rolling back the **whole** transaction, using bounded jittered retries (**three attempts proposed**), reacquiring locks and **resampling T_elig** every time. A unique violation 23505 or exclusion 23P01 indicating a genuine conflicting offer/Booking is a *business conflict*, not permission to spin until one magically succeeds. Exhausted retries produce sanitized non-success. Do not retry non-idempotent effects outside the transaction.
- **Unknown response after possible commit:** network failure is not evidence of rollback. No blind duplicate success or changed Booking ID. In S1, reconcile through authenticated own-Booking reads and preserve invariants; an optional durable idempotency-key/result registry, payload fingerprint, key lifetime and repeated-response behavior remain **OD-013** to approve in F-S1-04/S2 Feature SDS. Never claim exactly-once delivery without such a contract.
- **Injected DB failure:** fail after validation / between scheduled statements, roll back, verify committed Booking and Slot state unchanged and API does not say success (FR-016/018, BR-034, VAL-014).
- **Stale UI:** an earlier Available card can become occupied, withdrawn or too close to start. Reject gracefully and refresh; frontend reservation indicators do not reserve database rows (FR-009/011).
- **Customer cancellation S2:** discover original Slot/Tutor from Booking only to identify the lock set; lock Customer + Tutor principals (UUID order), original Slot, then Booking. Revalidate ownership/current assignment and Q07 at authoritative transaction decision; set Booking Cancelled atomically. The original Offered Slot becomes unoccupied because occupancy is derived; Q05 still gates any new claim (VAL-015/016).
- **Customer reschedule S2:** discover original and destination Slot/Tutor references as a non-authoritative lock set; lock Customer + both Tutor principals (UUID order), **both** Slots (UUID order), then Booking. Revalidate original assignment, destination ownership, both 60-minute cutoffs and no conflicting other Customer bookings; atomically change currentSlotId + interval and append UNIQUE RescheduleHistory. Keep Booking ID; a failed attempt preserves destination, original and one-success allowance (VAL-017..020). On changed discovered IDs restart the full transaction.
- **Tutor cancellation S2:** discover the current Customer/current Slot only to determine locks; lock both User principals, Slot, then Booking per §7.1 and revalidate currently assigned Tutor, Q18 cutoff and nonblank reason; in one transaction set Booking Cancelled **before** Slot Withdrawn and then persist one private Notification. Failure leaves all three prior states, no notice (VAL-021..024).
- **Tutor withdrawal S2:** lock owning Tutor principal, target Slot, revalidate no active Booking and future Offered status, then withdraw. DB lifecycle trigger independently forbids an occupied withdrawal; no reactivation of historical ID. A new distinct Slot may later overlap that withdrawn historical interval (VAL-025..027).
- **Summary S3:** use a consistent snapshot or equivalent single-query predicate for count and list under the same Tutor/Booking filters; no inferred Completed. In-progress classification is gated (VAL-028/029).

7.5 Minimum real-database verification contract

Case	Real-DB setup / observable committed assertion	Owner
Race A (VAL-005)	Same Tutor submits overlapping Offered Slot inserts concurrently under a barrier; at most one currently Offered overlap persists; a distinct Tutor's same-time Slot and same-Tutor adjacency may succeed.	F-S1-02 SDS/STS
Race B (VAL-010)	Two Customers concurrently book the same valid Slot; exactly one Booked row after both settle; no two success responses or partial state.	F-S1-04 SDS/STS
Race C (VAL-011)	One Customer concurrently claims distinct overlapping Slots from two Tutors; never two overlapping Booked rows; adjacent control case allowed.	F-S1-04 SDS/STS
Cutoff after lock wait (VAL-008/009; VC/TEST-S1-39)	Use a real controlled barrier: start Booking at 60m+ while a competing transaction holds the required Customer/Slot row lock, release after the cutoff, assert the INSERT trigger's T_elig is **after** wait and Booking is rejected; run exact 60:00 control and a forced unexpected index wait case to reject stale-time success or block design acceptance until a proven retry strategy exists. Inspect committed rows and timestamps from the DB, not the request-arrival clock.	F-S1-04 SDS/STS; SYS-01 gate
Persistence fault (VAL-014)	Inject post-validation DB write/commit failure; verify no partial committed Booking, false success or Slot occupancy.	F-S1-04 + SYS-01
Auth/privacy (VAL-002/034/036)	Anonymous, wrong-role, foreign-Booking, foreign-Tutor, client-supplied IDs, revoked session; inspect entire payload, not only UI.	F-S1-01/05 + SYS-01
Durability (VAL-007/031)	Create Slot and Booking through actual UI/API/DB; restart app against same DB; retrieve correct owner-scoped state.	F-S1-02/04/05 + SYS-01
Booking vs Slot withdrawal (S2, Q26/27; VAL-025/026 plus VAL-014)	Start an eligible new Booking and unoccupied-Slot withdrawal concurrently with synchronized barrier; force both winning orders. Final state must be **(Offered + one Booked)** or **(Withdrawn + zero Booked)**, never Withdrawn with a Booked row. Include a direct SQL attempt bypassing the service guard; trigger must reject and rollback without ghost occupancy.	F-S1-04 Booking contract (S1 guard); F-S2-05 withdrawal SDS/STS (S2 execution); SYS-01
Reschedule vs Tutor cancellation (S2, Q12/13/17/19/21; VAL-020/022/023)	One Booking is simultaneously moved to a different Tutor and cancelled by its formerly assigned Tutor. Synchronize both orders. Verify same Booking ID, one-or-zero successful RescheduleHistory rows, correct old/new Slot lifecycle, currently authorized Tutor, and **notice/reason only if Tutor cancellation really committed**. Losing operation must leave no partial history, withdrawal or notice.	F-S2-02 + F-S2-03/04 SDS/STS; SYS-01
Customer cancellation vs new Booking (S2, Q07/08/05; VAL-015/016/010)	Original customer cancels sufficiently far ahead (>60m) while a second customer claims the same original Slot. Force cancellation-first and contender-first interleavings; at most one active Booked occupant, existing Booking becomes Cancelled only when its transaction commits, Slot remains Offered, and new Booking succeeds **only after** released occupancy and an independent Q05 check. No false double-success or partial status.	F-S2-01 + F-S1-04 Booking regression SDS/STS; SYS-01
Later regression (VAL-015..029)	S2 cancellation/reschedule/notification and S3 count/list rules; verify required constraints and no identity/time/privacy regression.	Corresponding S2/S3 SDS/STS

Tests must deliberately synchronize competing transactions, inspect **final committed rows**, include a losing contender and fault rollback, and record database version, setup/seed, command, Git SHA, pass/fail/skip counts and

evidence. Pure mocks, Promise.all without synchronized interleaving, or HTTP-only checks are **insufficient** for the race obligations. These are **planned tests, NOT executed results**.

8. Reproducible local development and future delivery

8.1 Proposed scripts and configuration (not yet present)

Use one npm-workspaces root and two application packages. Proposed scripts to add in Part E, not commands claimed to work today:

~~~text

npm ci # install exact locked project dependency graph

npm run db:up # start local PostgreSQL (Docker Compose or existing service)

npm run db:migrate # local: Prisma migrate dev incl. reviewed SQL constraints

npm run db:seed # idempotent LOCAL/TEST-only Customer/Tutor fixtures

npm run dev # web + API; Vite same-origin /api proxy

npm run typecheck

npm run lint

npm run test:unit

npm run test:api

npm run test:db # real PG + barriers + committed-row assertions

npm run test:e2e # real UI/API/DB flow

npm run build

npm run db:migrate:deploy # later release: reviewed Prisma migrate deploy

~~~

Document and implement each script before presenting it as runnable. Provide README setup prerequisites (Node 24, npm 11, PostgreSQL 18 or agreed compatible version, Docker optional), exact .env.example placeholders, startup/teardown instructions and fresh DB reset procedure **only for disposable development/test DBs**. Never reset a real or shared database. Use separate TEST_DATABASE_URL, migrations and unique test fixtures to prevent contamination. Seed is **idempotent**, uses only fictional records and does not expose known shared/production account credentials. Tests should use isolated DBs and rollback/cleanup of test fixtures.

8.2 Proposed environment variable names (examples, not secrets)

~~~dotenv

NODE_ENV=development

PORT=3000

DATABASE_URL=postgresql://APP_USER:CHANGE_ME@localhost:5432/nuttiew_dev

TEST_DATABASE_URL=postgresql://TEST_USER:CHANGE_ME@localhost:5432/nuttiew_test
~~~

SESSION_COOKIE_NAME=nuttiew_session_dev

SESSION_SECRET=GENERATE_A_STRONG_LOCAL_ONLY_SECRET

TRUST_PROXY=false

WEB_ORIGIN=http://localhost:5173

~~~

All values above are **placeholders**, never deployable credentials. In the proposed opaque-token/digest scheme, a SESSION_SECRET is only required if a separately signed CSRF/session adjunct is approved; do not treat it as a replacement for true random tokens or a reason to store raw sessions. Commit only .env.example and ignore real .env, test output, DB dumps and secrets. Do not place passwords/API keys in sample responses, tests or logs. For deployment use secret management; fail fast when required config is missing. Production cookies require HTTPS, Secure, HttpOnly and a reviewed proxy/host setup.

8.3 Database migration and operational readiness

- Create Prisma 7 schema and adapter configuration, include versioned custom SQL for CHECK, partial unique, GiST exclusion and composite FK. Check extension permissions (btree_gist), upgrade compatibility and migration dry-run on a new DB. Use a single migration authority, not Prisma db push on production.
- Index foreign keys/read paths, including Tutor Slots by owner+startsAt, Booking by customer and current slot, and future Notice recipient/time; verify query plans when data size makes it useful. Avoid storing computed Booked/Past or redundant occupancy counters.
- Preserve existing rows as S2/S3 migrations add lifecycle, history and notice features; use additive/default/backfill strategy, then constraints, never destructive drop-and-recreate. Test up/down or safe forward recovery and backup first; rollback a release by correcting forward schema where unsafe to reverse.
- Separate development/test/prod databases and least-privilege accounts. Production migrations run as privileged release step, API uses narrower runtime credentials. Define backup/restore and secret rotation in Lab 5 operations; no retention or uptime SLA invented at D1.

8.4 Docker/GCP and CI/CD **future design only**

~~~mermaid

flowchart LR

PR["Reviewed PR + quality gates (future)"] --> CI["GitHub Actions build / tests"]

CI --> R["Accepted main release"]

R --> C["Cloud Run: HTTPS web + API container"]

C --> DB[("Cloud SQL for PostgreSQL")]

C --> SM["Secret Manager / service identity"]

~~~

- **Lab 5 target:** build a production image with Node 24, compile React assets, serve the same-origin site and Express API in a Cloud Run service, connect to a supported Cloud SQL PostgreSQL major over an authenticated/private connector, use Secret Manager and service identity. Confirm Cloud SQL major/extension support, SQL connection pooling and migration permissions before implementation.
~~~

- **CI plan:** on each PR run lockfile install, typecheck, lint, build, unit/API tests, and real-DB integration/concurrency suites with an ephemeral PostgreSQL service and migrations; record explicit status. Deploy only reviewed/accepted main releases; enforce branch protection and no secrets in PR logs.
- **Scale:** Cloud Run instances are stateless and may overlap; PostgreSQL unique/exclusion and serializable transaction invariants must hold **across instances**, not only one Node process. Session state remains in DB, never a single-process memory map. Cap DB pool size for serverless instance multiplication.
- **Current evidence:** no app image, deployed Cloud Run, Cloud SQL, GitHub Actions quality gate or successful execution was created by Issue #11. The course's supplied Lecture 11 material frames Docker/CI/CD/GCP as later Lab 5 work, not an assertion of delivery.

9. Requirements-to-design-to-verification traceability

Design responsibility	Requirement / feature IDs (authoritative in SRS and inventory)	Planned checks and downstream contract
Auth, session, role/owner boundaries	FR-001..004; BR-002/033; NFR-001/002/015; F-S1-01	VAL-001/002/034/036; F-S1-01 Feature SDS/STS, session expiry, CSRF, bad roles/ownership
Offered 60-minute Slot / Tutor ownership	FR-005..007; BR-003/004/006/029/035; F-S1-02	VAL-003/004/005; AC-S1-13; VC/TEST-S1-37; migration constraint and Race A
Availability and safe Customer projections	FR-008/009; NFR-007; F-S1-03	VAL-006/009/036; stale/empty/privacy/refresh UI and API
Exclusive Booking and time/concurrency	FR-010..013/018; BR-001/005/028/034; NFR-004/005/006/008; F-S1-04	VAL-007..011/014/030; AC-S1-25/26/35; VC/TEST-S1-25/26/39; Races B/C, T_elig, retry
Persisted private Booking and correct status	FR-014..017/019; BR-030; NFR-003/007; F-S1-05	VAL-012/013/031/036; restart, owner scope, Past not Completed
Cross-cutting system ownership	FR-018/019; BR-029/033/034; NFR-003..008/011/012/013/015; SYS-01	VAL-014/031/034/035/036; migrations, safe error, CI/GCP future plan
Customer cancellation	FR-020/021; BR-007/008; F-S2-01 **proposed**	VAL-015/016; Q05 remains independent after reopen
Cross-Tutor one-success reschedule	FR-022..027; BR-009..016; F-S2-02 **proposed**	VAL-017..020; same Booking ID, at most one history, atomic cross-Slot movement
Tutor cancellation and withdrawal	FR-028..030/033/034; BR-017..020/026/027/032; F-S2-03/05 **proposed**	VAL-021/022/025..027; no occupied withdrawal, reason and distinct ID
Private notice and cancellation reason	FR-031/032; BR-021..025; NFR-014; F-S2-04 **proposed**	VAL-023/024/036; read/reread, no age expiry, data minimization
Tutor-only summary	FR-035/036; BR-030/031; NFR-016; F-S3-01 **proposed**	VAL-028/029/036; consistent counts/lists, in-progress decision gate

Coverage boundary: All stakeholder decisions Q01–Q32 are represented through BR-001..032 with extra BR-033..035 for instructor/security/integrity, and FR-001..036 / NFR-001..016 remain controlled by SRS. The detailed ID-to-feature/VAL crosswalk is in traceability. This SDS adds design mappings and **does not** redefine or renumber any source requirement. VAL, AC and VC/TEST references above are **planned evidence**, not passed tests. Feature-specific exact test lists and acceptance results must be established in each Part E STS.

10. Outstanding gates, review checklist and next authorized work

Gate	Required disposition before the indicated step
OD-001/002/003	Decide Tutor operating hours/days, maximum horizon and start-minute grid **before F-S1-02 final contract**; do not fabricate restrictions.
OD-004	Approve availability display, safe Tutor labels, field allowlists, sorting/filtering and list behavior **before F-S1-03/05 API/UI contracts**.
OD-005	Peer-approve stack integration, proposed eight-hour Session TTL/CSRF policy, specific **current-only logout vs all-session credential/compromise revocation**, atomic rotation, precise API errors, DB lifecycle triggers, lock order, post-guard wait treatment and failure handling **before S1 code**.
OD-006	Classify in-progress appointments for Upcoming/Past summary without creating Completed state **before S3 summary contract**.
OD-007	Q32 already **prohibits** reactivation of withdrawn historical Slot; any exception needs *new* stakeholder authority, not a default.
OD-008/009	Privacy retention/deletion and summary count/list snapshot/pagination **before corresponding S2/S3 contracts**.
OD-010	Proposed keyboard/p95 thresholds and DB race stress sample sizes need approved methods/fixtures; not mandatory until approved.
OD-011/012	Final instructor Master document and formal Theme 1 eligibility **still unverified**, blocking official sign-off; this design may only be reviewed as a draft.
OD-013	Retry idempotency-key shape/window and unknown-commit reconciliation **before Booking/Reschedule Feature SDS/STS**.
OD-014/015	Meaningful Tutor reason validation and previous-Tutor history visibility **before corresponding S2 design contracts**.
Issue #12	Sprint 2/3 assignment and feasible capacity remain proposed pending peer-reviewed three-sprint plan.

Issue #11 review checklist (independent @Chxtamos review required):

1. Confirm the real repo has no implementation and that this PR changes **only** docs/system-sds.md.
2. Challenge proposed Node/React/Vite/Express/Prisma/Postgres versions and Prisma 7 adapter/migration details; verify reproducible future commands are clearly **not yet executable**.
3. Validate ERD cardinalities, no redundant writable Tutor schedule or occupied flag, immutable 60-minute Slot, FKs, conditional indexes/exclusions and S2 history/notice compatibility.
4. Confirm all three race invariants with DB-executed planned test proof, post-lock Q05 clock semantics, equality/adjoining windows, atomic rollback and bounded retry contract.
5. Confirm anonymous/Customer/Tutor role and **record** enforcement, cookie/token hygiene, CSRF protection, privacy-safe response allowlists and error discipline.
6. Confirm required Q07–Q32 later behavior is represented *without* prematurely exposing Sprint 2/3 endpoints, and OD-001..015 / Master/Theme blockers remain visible.
7. Check source links, consistent IDs, no fabricated test/deployment/approval claims and a substantive GitHub review. An AI self-check is not a teammate approval.

Exit / handoff: After a documentation-only diff check and this Issue's scoped review, open a PR from the Issue branch to sprint1, request @Chxtamos and **leave it open**. Only a real teammate's review and an explicitly authorized later merge can satisfy the full Issue DoD. Issue #12 can use this draft for feasibility but cannot claim it is already signed off. Part E should author **versioned feature contracts first**, then implement/test the S1 slice on their own Issue branches.

11. References and provenance

- Product authority: Whole-product SRS, Sprint 1 baseline, Feature inventory, Traceability, AGENTS.md, Issue #11.
- Instructor materials cited by the SRS: Group Work Specification v1, **marked draft**, issued 6 October 2026; Deliverable 1 v1 for 8 November 2026. **Authoritative final Master and Theme allocation not verified** (SRS OD-011/012).
- Version support: Node.js releases, Vite supported releases; npm registry version metadata examined 3 November 2026. These justify *proposed* targets, not installed project libraries.
- PostgreSQL 18 CREATE TABLE / exclusion constraints and range types.
- Prisma 7 transaction isolation and retry; implementation must validate compatibility with the **chosen** Prisma 7 adapter and API.
- No test execution, generated migration, package installation or cloud deployment was performed **as part of authoring this specification**.

Part D: Feasible Three-Sprint Delivery Plan

> ***Status: PROPOSED — Issue #12 / Deliverable 1 Part D.*** *This plan is not a record of feature completion, executed tests, instructor authorization, or accepted release. The team must peer-review dates, capacity and Sprint 2/3 allocations. Product rules Q01–Q32 are controlled by SRS; Sprint 1 identities by requirements; assignments by Feature Inventory, traceability, and architecture by System SDS.*

1. Document control, authority, scope

Item	Plan
Issue	#12 — D1-04 Part D
Owner / peer reviewer	@Chxtamos / @Tanaboonnnnn (independent human review)
Product / people	NutTiew one-to-one tutoring appointments; two students
Integration / release	Issue `docs/` *or* `feature/` branch → reviewed PR into `sprint1` → separate reviewed release PR into `main`
Mandatory Sprint 1 checkpoint	**D1: 8 November 2026, 23:59 Asia/Bangkok**
Later checkpoints stated by Issue #12	**D2: 29 November 2026** (Sprint 2 and evidence of Sprint 3 progress); **completion: 13 December 2026** (Sprint 3)

Item	Plan
Source limitation	Reviewer-cited Group Work Specification v1, Deliverable 2 v1 and Final Delivery v1 inform these Lab, D2 and final checkpoints. The authoritative final Master and official Theme allocation remain unverified (OD-011/012).
Scope	Schedule, responsibilities, interdependencies, test/review outcomes, risks and fallback; **no app implementation, no simulated test pass, no direct edits to `main` / `sprint1`**

Baseline: At planning time `sprint1` contains `AGENTS.md`, `README.md`, `docs/requirements.md`, `docs/srs.md`, `docs/features.md`, `docs/traceability.md`, and `docs/system-sds.md`; no application scaffold is established. A documentation merge is not a working app or a passing test. The team must build a genuine UI → API → durable DB journey in Sprint 1. The concrete stack in the System SDS is **proposed**, not installed/approved: React/Vite, Express/TypeScript/Node, PostgreSQL/Prisma. The Part E feature contracts must validate integration feasibility before writing code.

2. Sprint goals and non-negotiable scope

Sprint	Product scope (stable IDs)	Objective accepted outcome	Planned verification / release
S1 — D1	**F-S1-01** Authentication; **F-S1-02** Tutor Slots; **F-S1-03** Availability; **F-S1-04** exclusive Booking; **F-S1-05** protected Booking/Tutor reads; **SYS-01** integrity, privacy, persistence and evidence	Real Customer/Tutor login, logout and current identity; backend role/record checks; future single 60-minute Tutor offers; customer discovery, eligible booking, durable own records; Q28 cross-Tutor overlap prevented; all three DB races and Bangkok clock boundary handled; UI/API/DB function end-to-end	VAL-001..014 (especially **Race A VAL-005, Race B VAL-010, Race C VAL-011**), VAL-030/031/034/036 as applicable; AC-S1-01..35 and VC/TEST-S1-01..39 (real PASS/FAIL/SKIP recorded only upon execution); review/merge PR `sprint1 → main`; D1 evidence and submission
S2 - proposed D2 with Lab 5-7	**F-S2-01** cancellation/reopen, **F-S2-02** single reschedule/history, **F-S2-03** Tutor cancellation, **F-S2-04** private notice, **F-S2-05** Slot withdrawal, and SYS-01 regression	Q07-Q27/Q32, ownership and atomic persistence must work in tested candidate	S2 VAL-015..027 and cross-operation race evidence, peer-reviewed SDS/STS before code; Lab 5-7 evidence; D2 integrated reviewed main/GCP release also includes one implemented/tested S3 workflow
S3 - D2 tested increment and mandatory Final completion	**F-S3-01** Tutor-authorized summary: D2 minimum Past Booked count/list, then **Upcoming Booked and Cancelled counts + matching lists** mandatory for Final	By 25 Nov test Past Booked in UI/API/DB; by **30 Nov** complete all three owner-filtered categories with consistent count/list, approved OD-006 in-progress rule, independent review and deployed regression; Final 13 Dec acceptance	Real DB **VAL-028**, **VAL-029**, **VAL-036** fixtures, unauthorized-role/foreign-Tutor negatives, versioned PR/SHA and CI/GCP deployment; no category considered optional polish

Mandatory S1 boundary cannot be traded away: real credentials/session; own roles and record-level checks; exactly 60-minute Slot publishing; Customer availability; Booking with 60-minute cutoff and exclusive real-DB guarantees; Customer/Tutor private reads; persistence across refresh/restart; denied invalid/past/occupied/overlap requests; authenticated end-to-end UI/API/DB; negative and synchronized real-DB tests for Race A/B/C; accepted

release on `main`. Demo-only mocks, memory-only records, UI-only blocking, a PR without a release, or tests described but not run do **not** satisfy this scope.

3. Feature dependencies, owners and verification handoffs

Ownership plan: Owner is accountable for getting a change reviewed and verifiable, not sole author of all code. @Chxtamos leads Part D and existing Issues #13/#15/#17; @Tanaboonnnnn leads existing Issues #14/#16/#18. The team coordinates shared architecture and migrations; no Issue assignment changes are made by this plan. These are **planning assignments requiring team agreement**, not a reassignment of existing GitHub Issues. The author of each PR must have the **other human teammate** review. Any actual feature-Issue owner/reviewer already assigned by GitHub prevails until explicitly updated.

Work package	Depends on	Proposed accountable driver / independent reviewer	Exit evidence (not yet executed)
A / B / C baseline	Issue #9 SRS, #10 Feature Inventory, #11 System SDS	Issue-specific existing assignees; both check consistency	Document references and reviewed PRs integrated in `sprint1`; technical choices and OD gates still identified
Shared project scaffold + database (SYS-01)	reviewed SD-01..12 / OD-005; environment and schema/migration decisions	@Tanaboonnnnn / @Chxtamos	Runnable reproducible local install, migrations/seed and data persistence; secrets excluded
F-S1-01 (#13)	System SDS; own **Feature SDS + UI/API/data contracts + STS reviewed before code**	@Chxtamos / @Tanaboonnnnn (existing Issue owner/reviewer)	VAL-001/002/034/036; actual login/logout/role/session tests
F-S1-02 (#14)	F-S1-01; same Part E contract gate; DB exclusion constraint strategy	@Tanaboonnnnn / @Chxtamos (existing Issue owner/reviewer)	VAL-003..005; real-DB overlapping offer Race A and negative cases
F-S1-03 (#15)	F-S1-02, authenticated API; OD-004 safe availability fields	@Chxtamos / @Tanaboonnnnn (existing Issue owner/reviewer)	VAL-006/009/036; stale/too-soon/occupied privacy-safe responses
F-S1-04 (#16)	F-S1-01/02/03; DB uniqueness/exclusion/trigger and OD-005/013 guards	@Tanaboonnnnn / @Chxtamos (existing Issue owner/reviewer)	VAL-007..011/014/030; Race B/C, Q05 wait crossing and rollback/duplicate safety
F-S1-05 (#17)	F-S1-01/04; approved response allowlist	@Chxtamos / @Tanaboonnnnn (existing Issue owner/reviewer)	VAL-012/013/031/036; own Customer/Tutor reads and persistence
F-S2-01/02	F-S1-04/05; S2 Part E contracts and Q07–Q16; OD-013	Team to assign/peer review before S2	VAL-015..020, 030; correct cancelled/reopened or one-history reschedule state
F-S2-03/04/05	F-S1-02/04; cancellation/notice/withdrawal integrity; OD-008/014/015	Team to assign/peer review before S2	VAL-021..027, 036 and Booking-vs-withdraw / reschedule-vs-Tutor-cancel race

Work package	Depends on	Proposed accountable driver / independent reviewer	Exit evidence (not yet executed)
F-S3-01 - full Final scope	F-S1-05, Booked/Cancelled persisted records and S2 lifecycle; OD-006 in-progress classification and OD-009 query snapshot gate	@Chxtamos implementation/test lead; @Tanaboonnnnn independent reviewer (planning assignment)	Past Booked implemented/tested by 25 Nov for D2; prepare reviewed SDS/STS and fixtures for **Upcoming Booked and Cancelled** by 25 Nov, implement/test them on **30 Nov** (counts + matching lists), VAL-028/029/036, regression, PR integration and GCP redeploy before exams; full scope mandatory for Final

Contract-before-code sequence for each Feature: source SRS FR/BR/NFR + accepted AC/Q → versioned Feature SDS (`specification.md` , applicable `ui-spec.md` / `api-spec.md` , data/transaction contract) → STS (`tests.md` , named failing/negative cases, evidence criteria) → *independent PR review* → feature code + tests → actual build/unit/API/DB/E2E results → reviewed feature PR to `sprint1` . A stub file or unreviewed spec does not open the implementation gate. SYS-01's migration/locking/Q05 design requires independent real PostgreSQL proof before Booking claims completion.

4. Sequence, checkpoints and integration strategy

Dates below are **planning allocations**, not claims that tasks were performed or promises of completion. Work is highly compressed: use checkpoints as stop/go decisions and escalate capacity risk, not as permission to skip mandatory acceptance.

Date/window (ICT)	Planned step	Exit / escalation
3 Nov	Review merged Parts A/B/C, approve feasibility/pending OD-005, author/review Part D; list per-feature Issues/contracts; test local Node/Postgres compatibility	Traceability/stack gaps owned; if local DB unavailable, escalate immediately rather than marking setup done
4 Nov	Review System SDS security/schema details and Part E specs/STS for F-S1-01 and F-S1-02; prepare scaffold/migration/seed, auth/slot test fixtures	Contracts reviewed **before code**, migration applies on clean local test DB, no secrets
5 Nov	Complete auth and Tutor Slot vertical slice; real DB and Race A; prepare F-S1-03/04 contract reviews	Negative role/overlap tests with actual committed state; ownership and Q05 blocking issues escalated
6 Nov	Availability + Booking implementation, Q05 guard, Race B/C, fail/duplicate handling, protected reads contract/code	Real DB barriers and persisted rows, no second success; any unproven constraint is a release blocker
7 Nov	End-to-end UI/API/DB journeys, security/private read checks, restart durability, real test evidence; review feature PRs then integrate `sprint1`	All S1 AC/VC mapped to observed pass/fail/skip; blockers fixed, never silently waived

Date/window (ICT)	Planned step	Exit / escalation
8 Nov before 23:59	Issue #18 (@Tanaboonnnnn owner / @Chxtamos reviewer) independent integration review, separately reviewed `sprint1 → main` release, versioned evidence/submission package: whole-product Parts A–D, per-feature Part E SDS/STS, Part F source/test logs and release SHA, and required D1 PDF/report per authoritative course instructions	Only claim D1 acceptance if main contains the working slice and actual tests/review/release evidence; instructor/Theme gates remain explicit
9-11 Nov - S2 and Lab 5 setup	Both review S2 feature SDS/STS before code. @Tanaboonnnnn leads Docker/GCP/Cloud SQL/secrets; @Chxtamos leads CI and S1 regression planning	Reviewed contracts, migration/seed setup and CI plan; reserve **at least 50% of combined planned capacity** for Lab 5 to 15 Nov; available hours remain unknown
12-15 Nov - Lab 5 due 15 Nov	Both: Docker, CI/CD, GCP Cloud Run with durable Cloud SQL; @Tanaboonnnnn deployment driver and @Chxtamos test/peer-review driver	Version/commit/image SHA, CI run URL/status, GCP URL/version, secret checks, post-deploy auth/Booking and DB restart persistence evidence. Lab 5 due 15 Nov, after D1 but mandatory for D2
16-19 Nov - S2 and Lab 6 setup	Both implement reviewed F-S2-01..05 in dependency order; @Chxtamos prepares cross-team UAT scenarios/defect log and @Tanaboonnnnn deployed candidate/fixes	S2 VAL-015..027/DB race and rollback proof as ready; reserve **at least one-third of combined planned capacity** for Lab 6/UAT/retests
20-22 Nov - Lab 6 due 22 Nov	Both run cross-team UAT; @Chxtamos coordinates scenario/evidence/defect log, @Tanaboonnnnn triages repairs and re-tests	Dated UAT outcomes, defect IDs/severity/owners, linked repair PRs and re-test results; feed residual defects into D2 regression
23-25 Nov - D2 S3 working increment plus full-category preparation	@Chxtamos obtains independent peer review of the **full F-S3-01 SDS/STS before code**, covering all three category predicates, same-time snapshot, OD-006 and fixtures. Implement real Tutor-only DB-backed Past Booked count/list via UI/API and prepare shared count/list query/UI and tests for Upcoming and Cancelled. @Tanaboonnnnn reviews	By 25 Nov Past Booked **implemented and tested** for D2, with real DB VAL-028/029/036 and source SHA; complete category test specification and prerequisites for mandatory Upcoming+Cancelled by 30 Nov. Prototype-only does not satisfy D2
26-28 Nov - Lab 7 and D2 candidate	@Tanaboonnnnn leads Lab 7 TA-approved change request, impact and updated reviewed contract, red-green regression, CI/GCP redeploy, five date-stamped sourced metrics and short retrospective; @Chxtamos leads S1/S2/S3 regression and D2 PDF; both review integration/release PR and UAT fixes	By 28 Nov tagged main/GCP candidate with CI run/status, SHA, URL/version, DB durability and S1/S2 + tested S3 Past Booked, plus Lab 7 evidence: TA approval reference, contract impact, red/green test logs, redeploy proof, five dated sourced measurements with units, short retro. Missing approvals/evidence = BLOCKED
29 Nov - D2 and Lab 7 due	Both verify main/GCP candidate and submit D2 self-contained PDF via LEB2; @Tanaboonnnnn checks release and Lab 7 change/metrics/retro, @Chxtamos PDF/evidence/receipt	Integrated main/GCP candidate with tested S1/S2 and **at least one tested S3 Past Booked workflow**, CI/post-deploy persistence and regression, UAT retests and Lab 5-7 evidence. Missing gate = NOT MET; Upcoming+Cancelled remain **mandatory Final**, scheduled 30 Nov

Date/window (ICT)	Planned step	Exit / escalation
30 Nov - mandatory F-S3-01 completion and release freeze	@Chxtamos implements **Upcoming Booked and Cancelled counts + matching lists** in authorized UI/API/DB based on already-reviewed full F-S3-01 SDS/STS and reusable fixtures; @Tanaboonnnnn independently reviews actual tests/PR. Both integrate into sprint1, independently review sprint1-to-main release, run regression and CI/GCP redeploy; draft final PDF/video script	**By 30 Nov** all **three mandatory FR-035 categories** implemented/tested and deployed: Upcoming/Past/Cancelled fixtures, count=list matching owner/time snapshot, wrong-role/foreign-Tutor denials, approved OD-006 classification/no Completed state, VAL-028/029/036 real DB results, peer review, SHA/CI/GCP and post-deploy persistence/regression. **Critical one-day capacity risk**: reusable query/UI and all-category contract/tests ready by 25 Nov; escalate if infeasible rather than silently defer
1-11 Dec - final exams and release monitoring only	Protect exam time: no new core S3 implementation. @Chxtamos final PDF/video assembly, @Tanaboonnnnn security/release checks and low-risk regression	Full three-category Summary already implemented, tested, reviewed and deployed by 30 Nov; remaining mandatory gaps or unresolved OD-006 explicitly block Final rather than become optional refinements
12-13 Dec - final due 13 Dec	Both verify deployed accepted release with **Upcoming Booked, Past Booked, Cancelled counts and matching lists**, replay real-DB VAL-028/029/036, authorization and time classifications, submit final PDF plus demo video with both members explaining	Full S3 scope, security/regression, release SHA, CI/GCP redeploy proof and submission receipt. A missing mandatory category means Final NOT MET, not last-day implementation

Integration cadence: no feature PR before its reviewed contracts; PRs are independently reviewed (no self-approval), and only accepted feature branches land on `sprint1`. After final S1 verification, open a separate `sprint1 → main` release PR and review it. Avoid simultaneous merge conflicts by naming file/feature ownership and sequencing schema migrations before dependent services. GitHub Project #6 advances `Backlog → Specified → Started → PR Review → Fixing → Done` based on verified work, not calendar dates.

5. Definition of Done and objective evidence

Gate	S1 acceptance and measured evidence	Outcome if absent
Source/contract	Part A/B/C references and applicable **peer-reviewed Part E SDS/STS before implementation**, including stable IDs	Contract/implementation gate **BLOCKED**
Working path	Customer/Tutor UI → authenticated API → durable relational DB, real login/logout/current identity and persisted own records after restart	**NOT DONE** if mock/in-memory/UI-only
Domain	Exactly 60-minute Slots, no same-Tutor active overlap; valid/invalid/occupied/too-soon cutoffs; one Active Booking per Slot; no cross-Tutor Customer overlap	**NOT DONE** if invariant unproven
Security	Backend role + record authorization, sanitized error/data allowlists, credentials hashed, no secrets committed	**NOT DONE** on unauthorized read/write
Race / rollback	Synchronized *real DB* Races A/B/C, Q05 post-wait boundary, rejected writes and injected rollback, final committed rows inspected	**NOT DONE** if HTTP-only/mock-only

Gate	S1 acceptance and measured evidence	Outcome if absent
Tests	VAL-001..014 and S1-applicable VAL-030/031/034/036; AC-S1-01..35 / VC/TEST-S1-01..39 have actual command, setup, SHA and PASS/FAIL/SKIP records	No manufactured PASS; unresolved required FAIL/NOT RUN blocks release
Integration / delivery	Peer-reviewed feature PRs into `sprint1`; independently reviewed `sprint1 → main` PR; release SHA and D1 artifact/evidence by deadline	Staging/PR alone **does not count as accepted release**

D2 acceptance gate (after D1): Peer-reviewed Part E SDS/STS must precede all S2/S3 code. By 29 Nov produce tested S1+S2 AND at least one **implemented/tested S3** rule in a reviewed integrated **main** release candidate deployed on **GCP via Lab 5 CI/CD**. Record version/tag, SHA, CI run/status, GCP URL/version, post-deploy DB persistence, S1/S2/S3 regression and authorization/negative tests. Lab 6 UAT defects/re-tests and Lab 7 maintenance/metrics feed this evidence. Submit a self-contained **D2 PDF via LEB2**. By 13 Dec provide final PDF and demo video with BOTH students explaining; reserve exams 1-11 Dec. Do not claim these plans are executed tests or deployments; not required at D1. **Separate Final F-S3-01 gate:** D2 Past Booked is only a minimum slice. Complete Upcoming Booked and Cancelled plus Past Booked counts/lists, approved OD-006, real-DB VAL-028/029/036, review, integration, CI/GCP redeploy by 30 Nov; Final 13 Dec requires full summary, not optional enhancements.

6. Capacity, risks, gates and controlled fallback

Two-person feasibility: D1 leaves roughly five calendar days from 3 Nov; after D1, Lab 5/6/7 overlap with mandatory S2 and at least one tested S3 rule before D2. Allocate approximately half of combined planned capacity to Lab 5 through 15 Nov, one-third to Lab 6 through 22 Nov, prioritize Lab 7/main/GCP/PDF on 26-29 Nov and prepare final artifacts before 1-11 Dec exams. Actual student hours are UNKNOWN; these fractions are planning safeguards, not capacity proof. Both students peer-review opposite authored PRs. If core correctness/review/release gates fail, explicitly report NOT MET instead of silently reducing mandatory scope. The 30 Nov full-S3 completion/review/deploy is a one-day critical-path risk; prepare approved contracts, reusable UI/API/DB and fixtures by 25 Nov, record remaining work and escalate lack of capacity instead of claiming acceptance.

Risk / open gate	Owner / checkpoint	Containment and defensible fallback
OD-011/012: final instructor Master and formal Theme eligibility unverified	@Tanaboonnnnn obtains instructor/TA evidence; @Chxtamos compares before formal D1 sign-off	Present drafts as provisional, record source/version/delta; **do not** assert instructor sign-off
OD-005: proposed stack, session, DB triggers/locking and Q05 post-contention proof not yet accepted/executed	@Tanaboonnnnn design lead + @Chxtamos review, before Part E implementation	Probe real DB early; choose reviewed simpler implementation only if it still proves Race A/B/C and Q05; **never** remove DB integrity checks
OD-001..004: Tutor hours/horizon/grid, availability safe fields unresolved	Product decision owner/team before F-S1-02/03 final contracts	Implement only confirmed constraints; defer optional filtering and non-approved input restrictions, not mandatory Slot/browse outcomes
OD-013: duplicate/unknown-response Booking retry contract	F-S1-04 owner with peer review before Booking SDS/STS sign-off	Preserve at-most-one and reconcile with authorized own reads while token/replay protocol remains explicitly proposed; don't claim exactly-once response

Risk / open gate	Owner / checkpoint	Containment and defensible fallback
OD-006/008/009/014/015: in-progress summary, retention, reporting snapshot, meaningful reason, prior-Tutor privacy	Relevant S2/S3 feature owner and stakeholder/team before affected contract	Mark blocking decisions and do not invent product rules; no unauthorized historical visibility
Missing local DB/toolchain or incompatible Postgres extension/ORM migration	Shared SYS-01 owner, setup checkpoint	Prioritize reproducible dev DB and constraints, temporarily replace an unworkable ORM detail **via reviewed design delta**, not with memory-only or unguarded writes
Late failed Race A/B/C, Q05, auth, persistence, or release checks	Both people, S1 test/release gates	Stop false acceptance, record FAIL/NOT RUN and remediate smallest cause; escalate deadline impact. **Do not quietly cut mandatory S1 feature**
Reviewer unavailable/merge queue and limited two-person capacity	Each PR author requests other teammate promptly; daily check-in	Keep PRs small, parallelize independent reviewable contracts, capture unresolved blockers; no self-approve or skip release PR
Missing Lab 5/6/7 evidence, UAT re-tests, or D2 main/GCP candidate	@Tanaboonnnnn deployment and Lab 5/7, @Chxtamos Lab 6/UAT/regression	Reserve Lab capacity and capture exact failed gates; no false D2 deployment or passed-test claims
Missing full FR-035 category set or exam capacity	@Chxtamos implementation/tests, @Tanaboonnnnn independent reviewer/redeploy; all categories due 30 Nov	Deliver Past Booked for D2 25 Nov, prepare full SDS/STS/tests beforehand; Upcoming+Cancelled implementation, regression, review and GCP redeploy on 30 Nov. Never call mandatory categories optional polish
Optional UI polish, benchmarks/accessibility thresholds not approved	Owner TBD / OD-010	Defer nonessential polish and unapproved thresholds after mandatory S1 correctness and tested end-to-end flow; document what remains

Fallback hierarchy: (1) resolve source/data/security blockers; (2) protect mandatory S1 real UI/API/durable DB and Race A/B/C; (3) protect D2 tested S2 features, one implemented/tested S3 rule, Lab 5-7 and deployed main/GCP candidate; (4) simplify ONLY optional UI polish/refinements with peer/team approval; (5) if a required checkpoint fails, state NOT MET and preserve failing evidence rather than asserting acceptance. **FR-035 Upcoming/Past/Cancelled are three mandatory Final categories and cannot be deferred as optional UI polish.**

7. Coverage and approval checklist

- **S1 features:** F-S1-01..05 + SYS-01, all mandatory Sprint 1 acceptance/test IDs `AC-S1-01..35`, `VC/TEST-S1-01..39`, Q01/Q02/Q03/Q04/Q05/Q06/Q28/Q29/Q30 as applicable; planned VAL-001..014, VAL-030/031/034/036.
- **S2 proposed:** F-S2-01..05 and VAL-015..027, VAL-030/036; S1 authorization/time/atomicity regression; Q07..Q27/Q32 and relevant privacy rules.
- **S3 proposed: F-S3-01 Past Booked** implemented/tested for D2 minimum by 25 Nov, then **Upcoming Booked and Cancelled counts + matching lists** implemented/tested, peer-reviewed, regression checked and deployed by **30 Nov**, before exam period. Real DB **VAL-028**, **VAL-029**, **VAL-036**, Tutor ownership, consistent state/time and OD-006 approval gate; all three mandatory for Final.

- **System NFR:** NFR-001..008/011/012/014/015/016 mapped to sprint features; NFR-009/010 proposed OD-010 thresholds, not approved. NFR-013 requires **Lab 5 Docker/CI/GCP by 15 Nov** and a **main/GCP deployed candidate by D2 29 Nov**, NOT by D1; Lab 6 UAT/retests due 22 Nov and Lab 7 maintenance/metrics due 29 Nov. D2 PDF via LEB2, final PDF and both-student demo video due 13 Dec according to reviewer-cited v1 handouts.
- **Explicit remaining gates:** OD-001..015 tracked in SRS; Issue #12 planning review does not close them automatically, does not approve new product rules and does not certify instructor/Theme eligibility.
- **Approval:** The two students must review and accept this allocation as a plan. @Tanaboonnnnn supplies substantive peer review on the Issue #12 PR into `sprint1`; @Chxtamos cannot self-approve or self-merge. The actual accepted D1 code/release and test evidence belong to later feature/integration Issues, not this Part D document.

8. References

- Issue #12 — Part D plan
- Whole-product SRS, especially §§3, 10, 13, 15
- Sprint 1 requirements and AC/VC IDs
- Feature inventory and cross-sprint traceability
- System SDS, especially §§1, 3, 5, 7–10
- AGENTS.md: local issue branch, review, validation and acceptance gates

PR #24 source provenance: This revision follows reviewer citations of group_work_specs_v1.pdf section 4, project_deliverable_2_v1.pdf sections 2/3.3/3.5, and project_final_delivery_v1.pdf. The complete handouts were not independently opened for this edit; final instructor Master and Theme sign-off remain open (OD-011/012).

Final F-S3-01 acceptance boundary: The D2 Past Booked count/list is only a partial milestone. Final demands DB-derived owner-filtered counts **and corresponding lists** for Upcoming Booked, Past Booked and Cancelled. Complete the remaining two on 30 Nov, test all three with VAL-028/029/036 against real DB fixtures and wrong-role/foreign-record negatives, uphold same time/visibility snapshot and explicit OD-006 policy; peer-reviewed feature PR to sprint1, reviewed release to main, CI/GCP post-deploy regression. If missing, Final is NOT MET.

Lab 7 v1 proof obligation (per second review): TA-approved change request with source/approval reference -> impact analysis and reviewed updated contract -> failing-then-passing regression evidence -> CI/CD redeploy with runtime SHA/URL -> **five dated metrics** with units and sources -> brief team retrospective. No fabricated TA approval or metrics.

Part E: Sprint 1 Feature Specifications & Software Test Specifications

F-S1-01 Authentication & Session Management

> ***Part E contract; not implemented or runtime-tested.*** *Issue #13, owner @Chxtamos, reviewer @Tanaboonnnnn. Decision approval from PR #25 Conversation #6624817784:* ***OD-005-A/B/C/E and Auth UI direction APPROVED; OD-005-D APPROVED (PR #25 reviewer comment #6625521193)*** *reviewed and accepted in PR*

> *#25 comment #6625521193. The reviewed and approved Part E PR #25 was merged into `sprint1` before Part F implementation. Instructor-final Master/Theme gates remain separate.*

Authority and scope

Follow Sprint 1 requirements FR-S1-01..04, AC-S1-01..07, BR-S1-04/16/17/20, NFR-S1-01/02/07/08 and VC-01..07/31/35; whole-product SRS FR-001..004, BR-002/033, VAL-001/002/034/036; System SDS SD-09 and section 5; Feature Inventory; three-sprint plan. Tutor and Staff are one business role. This feature owns **login, current trusted identity, logout, sessions, and reusable server access guards**; Slot/Booking persistence and actual row-level proofs depend on Issues #14–17.

Proposed architecture and decisions (OD-005)

Single-origin React/Vite client and Express/TypeScript backend with durable PostgreSQL User and Session records (Prisma adapter/SQL migration details to verify before code). Credentials are Argon2id salted hashes. Valid login obtains 32 random CSPRNG bytes; the opaque cookie contains the raw token while the database stores **only** a unique SHA-256 token digest. Set cookie **after** Session insert commit. Client role, claimed owner IDs, headers or query parameters never grant authority.

Topic	Proposed Part F behavior	Review decision
Cookie	`nuttiew_session` ; `HttpOnly; Secure; SameSite=Lax; Path=/` ; no Domain; localhost HTTP only uses `nuttiew_session_dev` with Secure=false	Production HTTPS, proxy setup, allowed origins
Lifetime	**Eight-hour absolute** lifetime from DB creation; no rolling renewal; check `expiresAt > serverNow` , `revokedAt IS NULL` , active User and role on every request	**OD-005-A APPROVED as decision; implementation/tests NOT RUN** (PR #25 comment #6624817784)
Login	Existing Customer/Tutor accounts only, normalized unique email, generic error for unknown/wrong/inactive, no new cookie on failure; separate logins create independent sessions	Hash cost, rate limiting, input bounds, seed policy
Logout	CSRF-protected POST; atomically revoke **presented session only**; send 204 and expire cookie **after DB commit**; replay old cookie denied; independent other session stays valid	**OD-005-B APPROVED as decision; implementation/tests NOT RUN**
CSRF	Approved Session-bound HMAC token with same-origin Origin/Referer rules and read-only token bootstrap; no cross-origin credentialed CORS; matched on unsafe requests	**OD-005-C APPROVED as decision; implementation/tests NOT RUN**
Error/privacy	Uniform invalid-login result; no email enumeration, raw secrets, stack/SQL error, foreign resource details; no session token in JSON/localStorage/logs	Exact status/code response schema in API contract
Future	Password reset, role switching, rotation/revoke-all administration and S2/S3 operations not implemented	Separate approved feature contract

If Session insert or logout revocation fails, **do not claim success**. An expired/revoked token is never implicitly refreshed. Each protected request loads a live Session and active User from persistent DB; after restart the same valid cookie continues until actual expiry. Session identity must derive from the database, not the client.

Server-side permission boundary

Action	Anonymous	Customer	Tutor	Record-level predicate
Login	Credential exchange	Allowed	Allowed	Valid existing active account
Own identity/logout	401	Own session	Own session	Valid unexpired/unrevoked Session joined to active User
Tutor Slot create/read	401	403	Own schedule only	Create `tutorId` from principal; read SQL where `Slot.tutorId = principal.id`
Customer Booking create/read	401	Own only	403/general reads denied	`customerId = principal.id` from session, not request
Tutor Booking/schedule read	401	403	Own only	Derive Tutor from persisted Slot and filter by principal
Foreign record	401	No protected data	No protected data	Privacy-safe 404 for foreign/missing ID

`requireSession`, `requireRole`, `requireOwnedResource` and owner-filtered DB queries are interface intentions; their actual domain integrations require Issues #14–17. Hidden buttons, forged `role`, `customerId` or `tutorId` cannot replace backend checks. Avoid existence leaks via foreign-record responses.

Part E → Part F gate

OD-005 decision sheet — A/B/C/D/E approved decisions; Part F tests tracked separately

The explicit human decision is recorded in PR #25 Conversation comment **#6624817784**: **OD-005-A/B/C/E and Auth UI direction APPROVED**, **OD-005-D APPROVED (PR #25 reviewer comment #6625521193)**. The updated in-flight reservation tradeoff was expressly approved by @Tanaboonnnnn in PR #25 comment #6625521193. **Approval of an engineering decision is not proof of a passing implementation**; Part E was independently reviewed and merged into `sprint1`; Part F acceptance and tests remain separately reviewable. Instructor-final Master/Theme gates remain separate. Detailed protocols: API, Data, STS.

Decision	Concrete proposed value/behavior	Approver / gate
OD-005-A Session TTL	Absolute **28,800 seconds (8 hours)**, measured from persisted `createdAt`, no sliding refresh; strict `expiresAt > DB/server now`, `revokedAt IS NULL` and `User.isActive` for every protected call; cookie Max-Age **<= 28800**	**APPROVED decision** by @Tanaboonnnnn, comment #6624817784; Part F tests NOT RUN
OD-005-B Logout	**Current presented Session only**, DB revocation commit **before** 204/clear-cookie, captured-cookie replay 401; another Session B remains usable; DB write fault must not be reported as success	**APPROVED decision** by @Tanaboonnnnn, comment #6624817784; Part F tests NOT RUN

Decision	Concrete proposed value/behavior	Approver / gate
OD-005-C CSRF and origin	**Session-bound HMAC CSRF (approved in PR Conversation comment 6624817784):** create and persist a nonsecret 32-byte `csrfNonce` once at login; derive a stable MAC from managed server HMAC key + Session ID + nonce using the canonical expression **outside this GFM table** in API/Data. Repeated read-only `GET /auth/csrf` returns the same MAC without DB mutations; multiple tabs work. Unsafe methods constant-time verify against the live Session, and A's token fails for B; logout/expiry revokes it. No per-GET rotation. Same-origin Origin/Referer fallback and cross-site safeguards remain as documented; managed versioned keys require secure overlap and retirement	**APPROVED by @Tanaboonnnnn in PR Conversation comment 6624817784**; implement/test in Part F, AUTH-13/17/18/21
OD-005-D Rate limit	**Reviewer-requested revision, APPROVED design in PR #25 reviewer comment #6625521193:** 15-minute PostgreSQL-backed HMAC-keyed account and trusted-IP buckets. Per account allow **5 failed credential attempts/15min** (successful logins do not increase failure count); per trusted IP allow **20 total login attempts/15min** (success and failure both counted). Before Argon2, reserve one IP attempt and one **account in-flight permit** atomically under row locks, but do **not** increment account failure count until the credential result is known. On failed credential validation commit one account failure and release its permit; on successful validation release the permit **without incrementing failures**. Enforce the account failure quota against **failed + in-flight reservations** so simultaneous attempts across instances cannot bypass five. Do not hold DB row locks during Argon2. A rejected attempt returns generic 429 and never creates a Session. Fixed UTC 15-minute windows, managed HMAC key, trusted proxy allowlist, fail-closed DB errors and nonenumerating responses remain required. See Data contract for transaction boundaries, window rollover and crash-recovery policy	@Tanaboonnnnn requested **5 failed-only/account + 20 total/IP** in PR #25 Conversation comment 6624817784; **OD-005-D APPROVED (PR #25 reviewer comment #6625521193)**, revised atomic permit protocol and all-valid saturation tradeoff expressly approved in PR #25 comment #6625521193; implementation verification tracked in AUTH-20/22
OD-005-E Input bounds	JSON request body **<= 4 KiB**; email **3–254 Unicode code points** after trimming, normalized lowercase and valid email syntax; password **1–128 UTF-8 bytes**, no trimming or Unicode normalization of secret; strict only `email` and `password` keys; malformed/oversized → 400/413 and no DB Session insert. Avoid timing-dependent account enumeration (dummy Argon2 verification for unknown account)	**APPROVED decision** by @Tanaboonnnnn, comment #6624817784; Part F tests NOT RUN

Pre-code acceptance record (PR #25 Conversation comment 6624817784, 4 Nov 2026): @Chxtamos = proposal owner; @Tanaboonnnnn confirmed **OD-005-A (8h absolute TTL), B (current-session logout), C (HMAC CSRF/Origin), E (input bounds) and Auth UI direction APPROVED** in that comment, and **OD-005-D APPROVED (PR #25 reviewer comment #6625521193)** (failed-only account threshold, total trusted-IP threshold). This document reflects those stated decisions, not an implementation/test pass. **The revised OD-005-D permit protocol was expressly approved by @Tanaboonnnnn in PR #25 comment #6625521193 and Part E was merged into `sprint1`.** This approval is a design decision, not Part F verification or a finding that AUTH-01..23 all pass. Source baseline remains SD-09, FR-S1-01..04 and OD-005. If browser/CI clients lack acceptable Origin/Referer for unsafe requests, reject rather than bypass security.

Contract links: API, UI, persistent data, STS/tests. Human teammate must approve session TTL, CSRF, logout scope, rate limits, response schemas and the documents before coding. Later Part F work starts on a fresh branch from reviewed `sprint1`, first records a failing test where feasible, implements genuine UI→API→PostgreSQL, and publishes real test logs and a separately reviewed code PR. This document has **NOT RUN** status for every app/DB test and does **not** close Issue #13.

> ***Approval-state update (2026-11-04):*** *@Tanaboonnnnn expressly approved OD-005-D, including the temporary sixth-correct-login 429 tradeoff, in PR #25 comment #6625521193, with follow-up review confirmation in PR #25 review #5765005104. The approved Part E contract was merged into sprint1. This corrects historical pending-status text only; implementation and the AUTH-01..23 tests are independently tracked in Part F verification ledger.*

F-S1-02 Tutor Slot Availability & Scheduling

> ***UX-only amendment proposed 2026-11-05 (owner-directed, peer acceptance*
>
> *pending):** Replace only the Tutor screen's former narrow form/list*
>
> *presentation with a NutTiew navy/orange 24-hour client-side calendar plus*
>
> *complete private chronological agenda. See dated UX decision,*
>
> *new UI contract, and UX-R1…UX-R6 STS.*
>
> ***Unchanged:*** *Auth/Customer visual design, Tutor role/owner/session/CSRF,*
>
> *exactly 60-minute future Offered Slot semantics, PostgreSQL race protection,*
>
> *strict POST + full-list GET contract, DTO fields, Asia/Bangkok timestamps,*
>
> *Option A no hour/day/horizon/grid constraints, safe uncertain-write*
>
> *reconciliation, and denial of cross-Tutor private data. Calendar day*
>
> *navigation is a pure read-only **client-side projection**, never a business*
>
> *rule or a new GET filter. This amendment has **not** yet received*
>
> *independent peer approval; the baseline Part E history below is preserved.*
>
> ***Mandatory sequential amendment gate (new UI direction):*** *this*
>
> *specification/UX decision/STS update is **Part E only**. Obtain*
>
> *@Chxtamos peer acceptance and merge this docs-only amendment into*

> `sprint1` *before opening a separate Part F Dashboard code PR from the*
>
> *updated base. This preserves the original Issue #14 two-PR rule.*
>
> ***Additional UX-R5 obligations:*** *initial/retry GET 503 must not*
>
> *assert an empty schedule; unknown count remains unknown until 200.*
>
> *On Logout click, hide account identity and all private Slots*
>
> *immediately and suspend protected interactions, while retaining the*
>
> *previous Tutor ID* ***only internally*** *for uncertain Session recheck.*
>
> *A confirmed Logout 204 or* `/auth/me` *401 finalizes signed-out.*
>
> *Only a fresh same-Tutor* `/auth/me` *200 **followed by fresh own-list*
>
> *GET 200** may restore the Dashboard and actions; otherwise remain*
>
> *hidden/blocked. Owner-selected 768px two-day / 1280px three-day /*
>
> *mobile agenda design, full-own-list summary and WCAG 2.2 AA target*
>
> *are detailed in dated UX decision.*
>
> *See UI contract and*
>
> *UX-R5-GET / UX-R5-LOGOUT STS. No backend/API/DB changes.*
>
> ***DOCS-ONLY NEW DASHBOARD CONTRACT / AWAITING PEER ACCEPTANCE.*** *Issue #14, owner @Tanaboonnnnn, reviewer @Chxtamos.* ***Historical initial Part E baseline:*** `sprint1` `6fd3931` *(PR #25/#26), from before Slot implementation.* ***Current PR #30 base:*** `sprint1` `ed451be2ca3e366bdfc1900f4c4697aa7e50b6a0` *, with the previously reviewed and merged Slot feature from PR #27/#28 already implemented and tested. This amended UI contract itself neither runs nor approves new Dashboard implementation; its review/merge precedes the new Part F UI code-only PR.*

Sources and traceability

Authority: Sprint 1 requirements Q02/Q03/Q04/Q06/Q29, FR-S1-04..07/18/19, BR-S1-02..06/11/12/17/18/20/21, AC-S1-08..14, VC/TEST-S1-08..14/37; SRS FR-004..007, BR-002/003/004/006/029/033/034/035 and OD-001..005/011/012; System SDS §§3.3/4/7.2; Feature Inventory; Traceability; Auth Part E and merged PR #26; AGENTS.

The Tutor (=Staff) owns their schedule. A Slot is one explicitly dated 60-minute `Offered` interval; Tutor Schedule is an owner-filtered read projection, **not** another mutable table. Publication state does not imply unoccupied after Booking exists.

Scope

In Part F, an authenticated active Tutor creates exactly one valid **future** 60-minute Slot for **their own** identity and reads persisted own Slots on refresh/restart. The Sprint 1 API surface is **POST /api/v1/tutor/slots** and **GET /api/v1/tutor/slots** only: no individual-detail GET, pagination or filters. Any query parameter, including `?tutorId=other`, is rejected, not used to choose an owner. Reads use authenticated `principal.userId`, ordered by `startsAt,id` ascending, with the fixed safe DTO in HTTP contract. Reject malformed/past requests, wrong role/owner, conflicting same-Tutor offers and simultaneous overlapping creates. Adjacent same-Tutor Slots and identical hours from distinct Tutors are permitted. Use Asia/Bangkok business time.

Out of scope: Customer availability #15, Booking and Q05 60-minute new-Booking cutoff #16, protected Booking views #17, release #18, bulk/recurring slots, edit/delete/withdraw, cancellation, notifications, summary and payments. Future `Withdrawn` compatibility is not permission to implement Sprint 2.

Invariants and user journey

1. Tutor logs in using existing Auth, opens My Availability and sees only own committed Slots.
2. Tutor chooses Bangkok calendar date and **any minute** (`HH:mm`, e.g. 13:17); UI derives end = start + 60m. API accepts strict RFC3339 instants with explicit offset/Z and **zero seconds + zero fractional seconds only** (optional 1–3 all-zero fractional digits). Reject nonzero seconds/fractions without rounding; this transport precision does **not** add an hourly/quarter-hour start grid. Server ignores any client role or owner.
3. API checks DB-backed Session/Tutor role, Origin and HMAC CSRF. Transaction locks User principal and rechecks active Tutor and future time **after contention** using DB clock; inserts `Offered` Slot under `principal.userId`.
4. PostgreSQL CHECK enforces exactly 60m; conditional GiST EXCLUDE prevents two currently `Offered` Slots of the same Tutor overlapping. A versioned **database trigger** rejects normal SQL UPDATE/DELETE/TRUNCATE in Sprint 1 and direct INSERT into non-`Offered` lifecycle. COMMIT before 201.
5. Rejected mutation rolls back and does not change existing Slot rows. GET returns owner-filtered durable data.

Use half-open intervals `[start,end)`: overlap iff `a.start < b.end AND b.start < a.end`. 13:00–14:00 + 13:30–14:30 conflict; 13:00–14:00 + 14:00–15:00 allowed. Two Tutors can each offer 13:00–14:00.

SLOT-I1: exactly 60m and immutable identity/owner/interval, enforced against ordinary direct SQL by the Sprint 1 trigger (all UPDATE/DELETE/TRUNCATE rejected). **I2:** no overlapping currently Offered Slots per Tutor, even under Race A. **I3:** active Tutor-only identity from Session. **I4:** strictly future by authoritative post-lock DB time; no Q05 Booking cutoff on Slot creation. **I5:** no partial writes/false success; restart durability. **I6:** UTC storage and Bangkok display. **I7:** no Withdrawn insertion/transition in Sprint 1; later approved Sprint 2 transition is one-way `Offered ->`

`Withdrawn`, never `Withdrawn -> Offered` on an old ID, with separately verified migration and tests. Privileged DDL/superuser tampering is outside the ordinary DML invariant and must be controlled by DB privileges.

Original Slot AC mapping — historical Part E verification plan

The AC-to-VC mapping below was written as the **original Slot Part E test plan**, **before the Slot feature was implemented.** It is not a statement that these tests remain unexecuted.** The merged Slot Part F work (PR #28) already has recorded real API/PostgreSQL/browser executions, including failures, reruns, exact commands and remaining limitations in the Slot Part F verification ledger. Consult that ledger and the relevant GitHub CI run for actual outcomes at their respective commit SHAs; this historical table is a traceability map, not a live PASS/FAIL dashboard.

The **new Tutor Calendar Dashboard amendment** and its `UX-R1…UX-R6`, `UX-R5-GET-01/02` and `UX-R5-LOGOUT-01/02` acceptance checks are separate **planned Part E requirements** in the amended STS. This docs-only PR neither implements nor executes those new Dashboard/Logout checks; subsequent Part F code and independent peer review remain necessary. Human WCAG 2.2 AA signoff is likewise **NOT RUN**.

AC	Expected	Test
AC-S1-08	One future owned 60m Slot persisted/read on refresh	VC-S1-08/14
AC-S1-09	Same-Tutor positive overlap rejected	VC-S1-09
AC-S1-10	Same-Tutor adjacency accepted	VC-S1-10
AC-S1-11	Different Tutors same hour accepted	VC-S1-11
AC-S1-12	Invalid/past input rejected without mutation	VC-S1-12
AC-S1-13	Race A: never two overlapping committed Offered rows	VC-S1-37
AC-S1-14	Browser timezone cannot change Bangkok appointment	VC-S1-13

Related product validations: VAL-002/003/004/005/012/013/031/036. Cross-feature Auth cases AUTH-07/08/09/16 become testable via real Slot routes in Part F.

Decision record — scope owner direction and outstanding approvals

Recorded 2026-11-04 (Asia/Bangkok). The Issue #14 requester/owner explicitly selected **Option A** for the **Sprint 1 implementation scope** in the project conversation. This is **owner direction**, not independent stakeholder/instructor approval and not proof of 24/7 Tutor availability. Peer reviewer @Chxtamos must explicitly accept/reject this scoped no-extra-restriction decision in GitHub; stakeholder policy remains unresolved until a separate approval or requirements revision.

Decision	Sprint 1 include/exclude decision from owner	Approval status / future change gate
OD-001 / TBD-S1-01 working days/hours/holidays	**EXCLUDE** any extra hours, weekday or holiday restriction; include strictly future, valid 60m Slot rule only.	Owner chose A 2026-11-04; **peer review pending**; no 24/7 stakeholder promise. New restriction requires reviewed Q/FR/BR/AC/VC update.
OD-002 / TBD-S1-02 maximum advance horizon	**EXCLUDE** a new 7/14/30-day or other business maximum; include only confirmed future-time check.	Owner chose A 2026-11-04; **peer review pending**; stakeholder maximum policy still unresolved.
OD-003 / TBD-S1-03 start-minute grid	**EXCLUDE** :00-only, quarter-hour and any other start grid; **include** every `HH:mm` minute as valid if the Slot otherwise meets rules.	Owner chose A 2026-11-04; **peer review pending**; minute-level **transport precision** (zero seconds/fractions) is a separate, proposed engineering validation, not a business grid.
OD-004 / TBD-S1-04 Tutor read interface	**PROPOSE** POST+own-list GET only, no detail GET or list filtering/pagination in Sprint 1; reject all query params, order `startsAt ASC,id ASC`, allowlist `id,startsAt,endsAt,lifecycle,occupancy`, empty array allowed.	Proposed engineering contract **pending @Chxtamos review**; Customer discovery #15 has separate interface.
OD-005 / TBD-S1-05 transaction/error/security	**PROPOSE** `SERIALIZABLE` + Tutor User lock, DB CHECK/GiST + Sprint 1 immutability/lifecycle trigger, bounded transient retries, shared Auth CSRF/Origin and error envelope.	Proposed engineering contract **pending @Chxtamos review**; actual migrations and race tests are Part F only.
OD-011/012 final Master/Theme 1	No additional claim.	Final instructor/TA specification and formal theme assignment **unverified**; must not be treated as sign-off.

Changes after this decision: additions to working hours, horizon or minute grid need a dated stakeholder/team rule, updated requirement IDs and fresh peer review; neither a form default nor an API validator may silently introduce them.

Definition of Done / two-PR gate

Part E: five cross-linked versioned docs (UI, HTTP, data, STS, this SDS) with decisions and Race A proof plan. Human @Chxtamos review + approved documentation PR merged into `sprint1` before feature code.

Part F: separate feature branch from latest `sprint1`; TDD RED→GREEN, real UI→Express→PostgreSQL, native constraint/transaction, negative auth/privacy, synchronized Race A, restart and fault tests, actual command/result/SHA evidence and peer-reviewed code PR into `sprint1`. No fabricated PASS and no direct main/sprint1 pushes. `sprint1→main` release belongs to #18.

Shared Booking Data Foundation

> ***PROPOSED CONTRACT — awaiting human peer review.*** *Issue #33. Contract owner: @Chxtamos. Required peer reviewer / F-S1-04 owner: @Tanaboonnnnn. This Part E change is documentation only. It does not add a Prisma model, migration, endpoint, UI, fixture, or test implementation; it does not claim that any database test has run.*

1. Purpose and authority

Define one shared, durable PostgreSQL/Prisma Booking representation for:

- #15 — F-S1-03 Customer Availability, which reads persisted Bookings to exclude occupied Slots and the authenticated Customer's overlapping appointments.
- #16 — F-S1-04 Exclusive Booking, which owns Booking creation and the application transaction/lock/retry protocol. The shared database guard trigger is owned by #33 Part F, not duplicated in #16.

The approved Part E contract for #15 selected Route B: this shared foundation must be reviewed and merged separately before either feature implements Booking-dependent behavior. This document is the proposed contract for that review; it is not itself approval.

Source hierarchy:

1. Sprint 1 requirements: Q01, Q05, Q28, Q30; FR-S1-10..13; BR-S1-08..10, BR-S1-13, BR-S1-19; AC-S1-19, AC-S1-25, AC-S1-26, AC-S1-35; NFR-S1-03..05 and NFR-S1-12.
2. System SDS: §§3.2–3.3 (entities and native PostgreSQL constraints), §4 (time/state semantics), §§7.1 and 7.3 (lock/transaction responsibilities), §7.5 (real-database verification).
3. #15 accepted Feature SDS and data contract and data spec, merged by PR #32.
4. #16 issue scope. Its own Part E contract must still define the Booking API/transaction and OD-013 retry behavior; this foundation does not pre-empt those choices.

2. Verified baseline at the Part E branch point

This contract branch is based on `sprint1` commit `98d984169fff6b8ec0ff467c15abb441ca5cadd7` (PR #32 merge).

- `apps/api/prisma/schema.prisma` contains `User`, `Session`, `AuthAttemptBucket`, `AuthAttemptReservation`, and `Slot`; there is no `Booking` model.
- Existing migrations are `20261104000000_auth` and `20261105000000_tutor_slots`; neither creates a Booking table.
- The Auth migration installs `pgcrypto`. The Tutor Slots migration installs `btree_gist`, creates the immutable Sprint 1 Slot table, and enforces same-Tutor Offered-Slot non-overlap.
- `Slot` currently has UUID `id` and `tutorId`, `startsAt`/`endsAt` as `TIMESTAMPTZ(6)`, `lifecycle` defaulting to `Offered`, `createdAt`, and nullable `withdrawnAt`. Sprint 1's Slot triggers reject ordinary updates/deletes and

`TRUNCATE`; the current migration does not enable a Withdrawn lifecycle transition.

- `User.role` is persisted as text with the existing Customer/Tutor constraint. A foreign key to `User` alone does not prove that the referenced account has the Customer role or is active; the application must check both using the authenticated principal.
- The System SDS targets PostgreSQL 18.x. No database migration or PostgreSQL compatibility test is executed by this documentation-only PR; the actual database version and `btree_gist` privileges must be recorded during Part F.

Do not edit, squash, replace, or regenerate the existing Auth/Slot migrations as part of this foundation.

3. Proposed shared data contract

The canonical field list, relation semantics, SQL constraints, and Prisma mapping are in data-spec.md. The core decisions proposed for peer acceptance are:

ID	Proposed contract	Rationale / trace
BDF-D01	`Booking.id` is a server-generated UUID primary key and an **application-level immutable identity**. PostgreSQL enforces primary-key uniqueness and non-nullability but the primary key alone does not reject an ID-changing `UPDATE`. Sprint 1's append-only guard separately rejects Booking `UPDATE` / `DELETE` / `TRUNCATE` as lifecycle boundaries; this is not a dedicated ID-immutability guarantee or ID-specific trigger.	Stable identity for persistence and later authorized retrieval; FR-S1-10, FR-S1-14.
BDF-D02	`customerId` is a required FK to `User.id`; delete/update is restricted. The service additionally verifies `role = Customer` and `isActive = true` from the authenticated Session.	Preserve ownership and do not trust client identity; FR-S1-04/10, BR-S1-13.
BDF-D03	`currentSlotId` is a required FK to the selected `Slot`. The current Tutor is derived from `Slot.tutorId`; Booking does not duplicate `tutorId`.	Avoid two mutable sources of Tutor ownership; System SDS §3.2.
BDF-D04	Persist `startsAt` and `endsAt` as `TIMESTAMPTZ(6)` snapshots copied from the selected Slot, never accepted from the client. A composite FK `(currentSlotId, startsAt, endsAt) → Slot(id, startsAt, endsAt)` enforces that the snapshot matches the immutable Slot.	Required by System SDS §3.3 and #15 data-spec; prevents a Booking interval drifting away from its Slot.
BDF-D05	`status` is text constrained to exactly `Booked` or `Cancelled`; new Sprint 1 Booking writes begin as `Booked`. Only `Booked` is active/occupying. `Cancelled` is retained for the shared state model and isolated DB tests; no cancellation workflow is added in Sprint 1.	Q30, BR-S1-08/09/10. `Past` is derived display classification, not a status.
BDF-D06	Intervals are valid only when `startsAt < endsAt` and use half-open `[start,end)` semantics.	BR-S1-09/10; adjacent appointments are allowed.
BDF-D07	Parent deletion and primary-key mutation are restricted for both Customer and Slot references.	Preserve Booking history and stable references; no deletion/retention policy is invented.
BDF-D08	PostgreSQL partial unique and exclusion constraints are the final integrity boundary for active Slot exclusivity and Customer overlap.	FR-S1-12/13, BR-S1-08/09/19, NFR-S1-04.

ID	Proposed contract	Rationale / trace
BDF-D09	Add a forward-only migration; current baseline has no Booking rows, so no Booking backfill is required. Existing Auth/Slot data and constraints must remain unchanged.	Safe migration from the verified `sprint1` baseline.
BDF-D10	Store `createdAt` and `updatedAt` as `TIMESTAMPTZ(6)`. `createdAt` is DB-defaulted; Prisma `@updatedAt` maintains `updatedAt` for application updates. These are metadata, not booking eligibility clocks.	Consistent with the System SDS entity model; Q05 continues to use its separate authoritative `T_elig`.
BDF-D11	**#33 Part F owns one versioned `booking_guard_s1()` function and its two PostgreSQL trigger registrations** in the shared Booking migration (remediated in Issue #39): a row-level `BEFORE INSERT OR UPDATE OR DELETE` trigger and a statement-level `BEFORE TRUNCATE` trigger. INSERT enforces the System SDS User → Slot lock hierarchy at the database level by acquiring `User(customerId) FOR UPDATE` before locking `Slot` and before index insertion in `BEFORE ROW` trigger, eliminating direct-SQL GiST exclusion index contention, reverse wait, and `40P01` deadlock for concurrent application transactions; it then applies the Offered-Slot/Q05 guard after the Slot lock; every UPDATE/DELETE/TRUNCATE is rejected with SQLSTATE `0A000`. **#16 owns the application transaction adapter**, including the System SDS User → Slot → Booking lock order, Serializable transaction and no-post-guard-contention proof or whole-transaction retry. #16 must not create a duplicate Booking guard.	System SDS §§3.3, 7.1 and 7.3; BR-S1-07/13/18/19; AC-S1-25/26/35; VC/TEST-S1-25/26/39; Issue #39.
BDF-D12	**Sprint 1 Booking is append-only after INSERT:** no row `UPDATE`, `DELETE`, or table `TRUNCATE`. #33 Part F enforces this with the row-level and statement-level guards in BDF-D11, following the existing Slot migration pattern. Deployment must separate the application runtime role from the migration/table-owner role; runtime is non-owner/non-superuser, has no `UPDATE` / `DELETE` / `TRUNCATE` or DDL/trigger-management privileges, and cannot bypass triggers through replication-role settings. No routine application/admin deletion exception is part of Sprint 1. BDF-24..26 verify the runtime role, both destructive operations, and final committed occupancy.	Preserve committed Booking history and derived Slot occupancy; prevent direct-SQL deletion from releasing a Slot without an approved lifecycle action.

All BDF-D01..D12 entries are **proposals awaiting human review**, not stakeholder decisions or accepted implementation facts. BDF-D11 resolves trigger ownership; BDF-D12 makes the Sprint 1 append-only/role boundary explicit. Both must be accepted by the consuming feature owners before any migration is authored.

4. Integrity and responsibility boundaries

4.1 Database-owned invariants

The database must reject:

- missing or invalid Customer/Slot references;
- a non-positive Booking interval or a snapshot that differs from its referenced Slot;
- an unsupported Booking status;
- a second `Booked` row for the same `currentSlotId`;
- any positive-duration overlap between `Booked` intervals belonging to the same `customerId`, including across different Tutors;
- every Booking `UPDATE` or `DELETE` in Sprint 1, and every Booking-table `TRUNCATE`, including direct SQL.

`Cancelled` rows do not occupy a Slot and do not participate in the Customer-overlap exclusion. A `Booked` row remains Active after its end time; elapsed time does not cancel or release it.

4.2 Application and transaction responsibilities

- #16 derives `customerId` from the live authenticated Session, reads the selected Slot and its actual Tutor from PostgreSQL, copies the persisted Slot interval, and sets the initial status to `Booked`. Client-supplied Customer/Tutor IDs, status, interval, or cutoff timestamps are not authoritative.
- The database FK does not enforce `User.role` or `isActive`; #16 must validate those within its agreed transaction/locking protocol.
- The unique and exclusion constraints protect committed state even when concurrent requests arrive through separate API processes. Application error mapping must treat constraint/serialization conflicts as non-success and must never report a Booking before commit.
- **#33 Part F owns the database guard artifact.** Its forward-only migration installs one `booking_guard_s1()` function with a row-level `BEFORE INSERT OR UPDATE OR DELETE` trigger and a statement-level `BEFORE TRUNCATE` trigger, following the existing Slot migration's row/statement guard pattern. The function rejects every `UPDATE` and `DELETE` at entry with SQLSTATE `0A000`, including `Cancelled → Booked`, `Booked → Cancelled`, moves and metadata updates; the statement trigger rejects every `TRUNCATE` with the same SQLSTATE. For a `Booked` INSERT, the function first acquires `User(customerId) FOR UPDATE` in `BEFORE ROW` trigger (enforcing the System SDS User → Slot lock hierarchy for direct-SQL writers before tuple insertion into unique or GiST exclusion indexes, preventing reverse wait and `40P01` deadlocks), then locks and re-reads the referenced Slot and rejects a missing or non-`Offered` Slot; it samples PostgreSQL `clock_timestamp()` only after acquiring both locks and enforces Q05 (`startsAt - T_elig >= 60 minutes`). The composite FK remains the final interval-snapshot equality constraint. The app runtime role must be separate from the migration/table owner, non-owner/non-superuser, lack UPDATE/DELETE/TRUNCATE and DDL/trigger-management privileges, and have no trigger-bypass capability. No Booking API or application service is added to #33.
- **#16 owns application transaction coordination, not a second copy of the trigger.** Its Part E contract must specify the System SDS global lock order: all affected User rows (Customer and selected Slot's actual Tutor) in ascending UUID order, then all affected Slot rows in ascending UUID order, then existing Booking rows in ascending UUID order; use Serializable isolation as specified. The service must acquire the Slot lock before the guarded INSERT so the trigger re-locks an already-held row. #16 must prove no conflict-capable unique/exclusion wait occurs after `T_elig`; if it cannot prove that invariant, it must abort/retry the entire transaction and sample a fresh DB clock. The trigger and indexes are database backstops, not substitutes for the application lock protocol.
- `Booking.id` immutability remains an application-level identity invariant: #16 generates it server-side and any future supported update path must not accept a replacement ID. The PostgreSQL primary key alone is not an immutability guard. Sprint 1's blanket Booking mutation prohibition (UPDATE/DELETE/TRUNCATE) is a separate lifecycle rule, not a dedicated ID-immutability trigger or ID-specific DB test.
- **Sprint 1 Booking rows are append-only:** the database rejects UPDATE/DELETE/TRUNCATE, while the application runtime role is not permitted to UPDATE/DELETE/TRUNCATE or alter/disable the guards. The migration/table-owner role is separate and is not used by API runtime processes.
- #15 is read-only: it consumes `status = Booked`, `currentSlotId`, and the persisted interval for availability predicates. It must not create/update Booking records or add `Slot.isBooked`.

4.3 Explicit exclusions

No Booking HTTP route/controller/service, UI, private Booking retrieval, cancellation/reschedule operation, Booking deletion/truncation workflow, `RescheduleHistory`, `Notification`, cancellation actor/reason, idempotency registry, payment, attendance, `Completed` state, or Slot withdrawal workflow is included. OD-013 retry-response semantics remain owned by #16. Issue #15's OD-002 60-day availability horizon is not a Booking column or a change to Q05.

5. Migration and compatibility plan

Part F of #33 may begin only after the Part E contract is accepted by both consuming feature owners **and** the #16 Part E transaction contract has been reviewed so the trigger and application use one agreed lock protocol.

1. Accept this Part E contract with both #15 and #16 feature owners.
2. Complete and peer-review #16 Part E's application transaction contract, including the §7.1 User → Slot → Booking lock order, Serializable behavior, retry semantics and the real-DB no-post-guard-contention proof strategy. This is a design dependency, not permission to implement the Booking API early.
3. Start from the then-current remote `sprint1`; re-check the schema/migration baseline. Add a new timestamped Prisma migration and matching model/relations; do not rewrite or regenerate existing Auth/Slot migrations.
4. In that **#33 Part F migration**, create the shared Booking table/constraints and the `booking_guard_s1()` function with row-level INSERT/UPDATE/DELETE and statement-level TRUNCATE trigger registrations described in BDF-D11/D12 and data-spec.md §7. Provision a separate non-owner application runtime role with no UPDATE/DELETE/TRUNCATE or DDL/trigger-management privileges; do not create a duplicate Booking guard in #16.
5. Confirm `btree_gist` is installed and usable by the migration role on the actual target PostgreSQL version. The current Slot migration already installs it; any repeated extension statement must be idempotent and must not drop the extension.
6. Run **BDF-01..BDF-22 and BDF-24..BDF-26 as the #33 pre-merge foundation proof gate** on real PostgreSQL, including fresh/upgrade migration tests, direct-SQL Offered/UPDATE/DELETE/TRUNCATE-guard tests, Q05 boundary and post-lock wait tests, synchronized DB-level race tests, runtime-role privilege checks, and inspection of final committed rows. Record PostgreSQL version, extension version/availability, exact commands, source SHA, and PASS/FAIL/SKIP/BLOCKED results. **BDF-23 is not part of this pre-merge gate** because it requires the complete #16 application transaction adapter.
7. Review and merge the #33 Part F migration into `sprint1` only after BDF-01..BDF-22 and BDF-24..BDF-26 pass; record its exact merged schema SHA in Issues #15 and #16. Only then may #15/#16 implement Booking-dependent application behavior against that accepted SHA.
8. After the merged schema SHA exists and the #16 Part F transaction adapter is implemented, #16 runs **BDF-23 as the joint post-merge integration gate** using the actual application adapter and real PostgreSQL barriers. Record the evidence in #16 and cross-link it from #33; do not claim BDF-23 PASS before this point. BDF-23 does not block the #33 migration PR from merging.
9. The complementary Slot lifecycle trigger for `Offered → Withdrawn` / no reactivation is a separate Sprint 2 migration and **must exist before any Sprint 2 withdrawal workflow is enabled**; it is not part of this Sprint 1 Booking foundation.

6. Peer-review checklist and open integration gate

The required reviewer @Tanaboonnnnn is also the provisional owner of #16, so this review must explicitly confirm that the shared fields/constraints satisfy both #15 and #16. Please review:

- [ ] BDF-D01..D12: field list, status semantics, interval snapshot, timestamps, ID-immutability boundary, trigger ownership, append-only DELETE/TRUNCATE guard and no duplicated Tutor ownership.
- [ ] Both FK delete/update policies and the composite Slot-window FK.
- [ ] Partial unique index and GiST exclusion semantics, including concurrent writes and adjacent intervals.
- [ ] `btree_gist` availability/permissions on the actual target PostgreSQL deployment.
- [ ] BDF-D11/D12: #33 Part F owns the shared guard function, row/statement triggers and append-only policy; #16 owns the application lock/transaction/retry adapter. Confirm the exact merge sequence and no duplicate guard is planned.
- [ ] #16 Part E records the System SDS User → Slot → Booking lock order and no-post-guard-contention / whole-transaction retry strategy before #33 Part F migration implementation.
- [ ] #33 Part F passes BDF-01..BDF-22 and BDF-24..BDF-26 before migration merge, including Offered/Q05, UPDATE/DELETE/TRUNCATE guards, `Cancelled → Booked`, Q05 60:00/59:59, post-lock cutoff crossing and runtime-role privilege boundary.
- [ ] #16 Part F owns BDF-23 after the #33 schema SHA is merged; this joint adapter proof is cross-linked from #33 and is not a pre-merge blocker for the #33 migration PR.
- [ ] No accidental Sprint 2 workflow, API/UI, `Slot.isBooked`, or OD-013 retry decision.

P1 resolution proposed: #33 Part F owns the one Booking guard function plus row-level INSERT/UPDATE/DELETE and statement-level TRUNCATE trigger registrations; it must pass BDF-01..BDF-22 and BDF-24..BDF-26 before its migration PR merges. The row/statement guards reject UPDATE/DELETE/TRUNCATE, while the separate non-owner app runtime role has no destructive DML or trigger/DDL bypass privileges. BDF-24/25 prove that committed Booking rows and derived occupancy survive attempted DELETE/TRUNCATE; BDF-26 proves the runtime-role boundary. #16 Part E/F owns the application lock order, transaction adapter and no-post-guard-contention / full-retry proof; #16 runs BDF-23 only after the #33 schema SHA is merged. The order is #34 Part E acceptance → #16 Part E acceptance → #33 Part F migration + BDF-01..BDF-22 and BDF-24..BDF-26 proof/merge → #15/#16 application implementation → #16 BDF-23 joint integration proof. BDF-23 is not a prerequisite for the #33 migration PR merge. This remains a proposed contract pending human acceptance; no implementation or test result is claimed here.

7. Traceability

Foundation invariant	Requirements / tests
One active Booking per Slot	FR-S1-12, BR-S1-08/19, AC-S1-25, BDF-10/11
One Customer cannot overlap active intervals across Tutors	FR-S1-13, BR-S1-09/10/19, AC-S1-26, BDF-12/13/14
Slot interval snapshot and valid references	FR-S1-10/16, System SDS §3.3, BDF-05..09
Cancelled is non-occupying; Past is not a state or completion	Q30, BR-S1-14, BR-S1-22, BDF-04/15
#33 pre-merge DB durability, concurrency and append-only evidence	NFR-S1-03/04/05/12, BDF-01..22 and BDF-24..26

Foundation invariant	Requirements / tests
#16 post-merge application/DB contention integration	System SDS §§7.1/7.3, BDF-23 (after #33 schema SHA)
Availability read predicates	#15 AVA-02, AVA-15, AVA-16, AVA-17 after the merged schema SHA is recorded

8. Part E Definition of Done

- [ ] The required human peer reviewer has reviewed and accepted the common data shape and invariants for both #15 and #16.
- [ ] BDF-D11 trigger ownership, BDF-D12 append-only/role boundary, merge order, lock-order dependency and real-PostgreSQL proof gates are explicitly accepted by both feature owners.
- [ ] Any review changes are incorporated into the contract documents and the final accepted decisions are recorded in the PR.
- [ ] Part F migration work remains a separate reviewed change; no migration or implementation result is claimed by this Part E PR.

Overall Issue #33 remains open until its Part F migration and real-PostgreSQL verification acceptance criteria are completed, reviewed, merged, and the exact schema SHA is published to #15 and #16.

F-S1-03 Customer Availability Browse & Filter

> ***Part E documentation contract only.*** *Issue #15; provisional owner @Chxtamos; independent peer reviewer @Tanaboonnnnn. Decision states below reflect the peer-review decision record in PR #32 comment #6683929084. These are engineering/design decisions, not new stakeholder business rules. This change does not implement UI/API code, add a migration, execute tests or close the issue.*

1. Authority and scope

Sources: Sprint 1 requirements (FR-S1-08/09/13/18, AC-S1-15..18, BR-S1-06/07/09/10/11/12/15/17/20/21, NFR-S1-01/07/08/09/10/12, Q28), SRS, System SDS, Feature Inventory, Traceability, AGENTS.md, accepted Auth contract and Tutor Slot contract.

Outcome: an authenticated Customer discovers a real eligible Tutor Slot, identifies the Tutor using an approved public display name when its data gate is cleared (otherwise an opaque Tutor reference), sees Bangkok start/end time, and selects that offer without seeing another Customer's private Booking data.

In scope: Customer-only read access to current Offered Slots; Customer-specific bookability projection; safe Tutor/Slot references; a conditional Tutor public-display-name data gate; UTC API and Asia/Bangkok UI time; privacy allowlist; loading/empty/error/retry/session-change states; planned API, DB, browser, timezone and privacy tests.

Out of scope: Booking create/confirm/history/detail (#16/#17); Tutor Slot management/dashboard (#14); public/anonymous discovery; any unapproved Tutor profile/name/email/phone or Customer identity; subject, rating, price, location, messaging, payments, notifications, cancellation/reschedule, recurring Slots; new Tutor hours, weekdays, holidays, maximum horizon or start-minute grid; any mutable Slot.isBooked flag or Booking schema owned by #15.

Part E is documentation only. Part F must be a separate code-only branch/PR after this contract is peer-accepted.

2. Dependencies and verified repository facts

Issue #13 Auth and Issue #14 Tutor Slots/Dashboard are closed. PR #31 is merged into sprint1. This branch is based on sprint1 SHA 551a9469e3d3a7e8e3ae004a382862c4f3e87e0e.

Selected sequencing route — B: a separately scoped shared data foundation. At this base, `apps/api/prisma/schema.prisma` contains User, Session, AuthAttemptBucket, AuthAttemptReservation and Slot, but no Booking model/table. `apps/api/src/slots.ts` currently projects Tutor own-list occupancy as Unoccupied because #16 has not introduced Booking; that projection is not a Customer-availability occupancy source.

The team selected a separate Issue/PR for the shared Booking data foundation, with schema, migration, ownership and sequencing reviewed before either feature relies on it. The minimum persisted fields needed by this contract are `id`, `customerId`, `currentSlotId`, `startsAt`, `endsAt` and `status` (`Booked` / `Cancelled`); `currentSlotId` is the occupancy relation and the persisted Booking interval is the Customer-overlap source. Booking mutation remains owned by #16 and must not move into #15.

Foundation tracking (not yet created): proposed implementation owner @Chxtamos; peer reviewer @Tanaboonnnnn; dependency links #15 and #16; exact foundation Issue/PR URL and reviewed migration/schema SHA are **TBD** until that separate work is created and accepted. This PR does not create the Issue/PR or approve a migration. Until the shared foundation is reviewed, merged and its exact SHA recorded against the Part F branch, occupancy-dependent Part F work is a hard **STOP GATE**. Do not invent `Slot.isBooked`, assume all Slots are unoccupied, or create a partial Booking schema under #15.

3. Actors and journey

Actor	Result
Anonymous	401; no offer data
Authenticated Customer	200 safe availability projection
Authenticated Tutor	403; no Customer availability payload
Server	Derives Customer identity from live Session; derives eligibility from persisted Slot/Booking and database time

1. Customer opens the availability screen.
2. UI verifies GET /api/v1/auth/me and requires trusted role Customer.
3. UI calls the Customer availability GET with the same-origin HttpOnly Session cookie.
4. Server enforces Session and Customer role, reads eligible offers and serializes only the approved allowlist.
5. UI displays an approved Tutor public display name only after the separate data-approval gate; otherwise it displays the opaque Tutor reference. It also displays Bangkok start/end. Selecting a Slot changes transient UI state only; it is not a Booking or reservation.
6. Later #16 receives only the selected Slot ID and independently rechecks offer state, occupancy, Q05 and all Booking rules in its authoritative transaction. A prior availability response is never a lock, lease or guarantee.

4. Eligibility and time

For one read, `T_view` is one database-authoritative instant sampled for the availability query. Under the confirmed Customer-specific bookable-only policy, include a Slot only when:

1. lifecycle is Offered;
2. no active Booking with status Booked references that Slot;
3. startsAt - T_view is at least 60 minutes (60:00 included; 59:59 excluded);
4. no Active Booking owned by the authenticated Customer overlaps this Slot, even when the existing Booking belongs to a different Tutor; and
5. the persisted Slot interval and Tutor ownership remain valid under the accepted Slot contract.

Customer-specific overlap predicate (BR-S1-09/10, Q28): derive the owner only from `principal.userId` supplied by the live Session. Exclude a candidate Slot when an existing Booking has `customerId = principal.userId`, `status = Booked`, and its persisted interval overlaps the candidate using half-open intervals: `booking.startsAt < slot.endsAt AND slot.startsAt < booking.endsAt`. A Cancelled Booking does not conflict; exact adjacency is allowed. This is an eligibility predicate only: the query may test existence but must not return or disclose any matching Booking or Customer data. The same Customer's overlapping Booking on another Tutor must make the candidate unavailable to that Customer; another Customer's Booking must not affect this Customer's overlap predicate.

T_view is an indicative read timestamp, **not** #16's transactional T_elig. Booking T_elig must be sampled by the authoritative Booking transaction after relevant contention waits, immediately before the guarded write. The availability UI must never imply a displayed Slot is reserved or guaranteed to remain bookable.

PostgreSQL stores TIMESTAMPTZ; API returns RFC 3339 UTC instants ending Z; UI formats explicitly with Asia/Bangkok regardless of device timezone. Never use browser time or a client timestamp for eligibility. OD-002 (maximum advance horizon) remains OPEN: this contract does not choose an upper bound and does not claim an approved unlimited horizon. Resolve OD-002 before Part F; do not silently add a horizon, hours, weekday, holiday or minute-grid policy.

A Slot can become occupied or cross Q05 after T_view. If #16 later rejects a stale selection, UI shows non-success and refreshes; #15 does not create a fake Booking endpoint.

5. Peer-review decision record

The following states record the decisions in PR #32 comment #6683929084. “Confirmed” means the team engineering/design choice recorded by peer review; it does not claim a new stakeholder business rule or implementation/test completion.

ID	Decision / contract	Status
OD-AV-01 Display	Customer-specific bookable-only: return/display only Slots that pass current Slot offer, occupancy, Q05 and the authenticated Customer's BR-S1-09/10 overlap rules at `T_view`.	**CONFIRMED design choice**; not a Booking guarantee.
OD-AV-02 Tutor identity	Desired UI identity is an approved Tutor public display name. Do not read/add/publish a name until its source, owner/consent, field, migration and allowlist are approved. Until then use opaque `tutorRef`.	**CONDITIONAL DATA-APPROVAL GATE**.

ID	Decision / contract	Status
OD-AV-03 List	No filters or pagination in Sprint 1; stable order `startsAt ASC → tutorRef ASC → slotId ASC`.	**CONFIRMED technical constraint**; not an unlimited-horizon decision.
OD-AV-04 Clock	One PostgreSQL `T_view` per read; `meta.evaluatedAt` is present for both populated and empty success responses.	**CONFIRMED**; not a substitute for #16 `T_elig`.
OD-AV-05 Occupancy	Exclude a Slot through active `Booking.status = Booked` and `Booking.currentSlotId = Slot.id`; never store duplicate `Slot.isBooked`. Customer overlap is a separate owner-derived interval predicate.	**CONFIRMED invariant**; schema-dependent Part F STOP GATE.
OD-AV-06 Error/privacy	Reuse existing API/session security, Customer role, session binding, request ID/error envelope, `Cache-Control: no-store`, and distinguish error from empty.	**CONFIRMED**.
OD-AV-07 Performance	Record p95 under a reproducible Part F workload; ≤2.0s remains a proposed reference only.	**NON-BLOCKING MEASUREMENT**; no pass/fail threshold approved.
OD-AV-08 Visual	Customer UI remains light/readable but shares NutTiew brand, typography, related colors/accents, spacing, components, focus and navigation patterns with Tutor Dashboard. Role-specific layouts are allowed within one design system.	**CONFIRMED design direction**.
OD-002 Horizon	No maximum advance horizon, working hours, weekday, holiday or minute-grid rule is selected.	**OPEN**; resolve before Part F.
#15 ↔ #16 data foundation	Use a separately scoped shared Booking data-foundation Issue/PR (route B); record owner, reviewer, dependency links and exact accepted schema SHA.	**SELECTED; NOT CREATED**. Part F STOP GATE remains.
NFR-S1-09 accessibility	Plan keyboard, focus, announcements and responsive checks; collect actual evidence in Part F.	**TEST PLAN ACCEPTED**; no WCAG 2.2 AA or 44px conformance claim.

Conditional Tutor public-display-name gate

- **Proposed source:** an explicit public display name supplied/maintained by the Tutor; never derive it from `User.email`, login credentials or a guessed profile field.
- **Proposed field/type:** nullable `User.tutorDisplayName` (`String?` / PostgreSQL `TEXT`), used only for Tutor accounts. This is a candidate contract, not an approved schema change.
- **Data owner and permission:** the Tutor is the source/data owner and must explicitly opt in to customer-facing display. The product/stakeholder owner must record approval for publication; @Chxtamos owns this feature contract and @Tanaboonnnnn is the peer reviewer. Record the actual approving stakeholder and consent rule before migration.
- **Migration/seed:** only a separate reviewed forward-only migration after the data gate is accepted; no default, no backfill from email, and existing Tutors remain `NULL`. Seed only clearly test-only synthetic values in isolated test fixtures; never present fixture names as real Tutor identity.
- **API/UI allowlist:** until the gate is cleared, omit `tutorDisplayName` and show `tutorRef`. After approval, add only the approved nullable field to the response allowlist and render it only when present; never add email, phone or other profile fields.

- **Privacy evidence:** planned AVA-18 verifies no name is inferred from email, no unapproved field is returned, and—only after approval—the approved display field is the sole additional Tutor identity field. AVA-05 continues to inspect the full response allowlist.

6. Acceptance and traceability

Source	F-S1-03 outcome	Planned STS
FR-S1-08 / AC-S1-15	Customer identifies a specific Tutor using approved display name after its gate, otherwise opaque reference, plus Slot start/end	AVA-01, AVA-05, AVA-18
FR-S1-09 / AC-S1-16	Anything shown as bookable is current, unoccupied, outside Q05 cutoff and non-overlapping for this Customer	AVA-02, AVA-03, AVA-15, AVA-16, AVA-17
AC-S1-17	Stale offer is revalidated by #16; no false Booking success	AVA-11
AC-S1-18 / BR-S1-12	Bangkok time meaning is independent of device locale	AVA-04
BR-S1-06/07/08/09/10/11/15/17/20/21	Distinct Tutor offers, Slot occupancy, Q05/future-time eligibility, Customer-specific non-overlap and adjacency, role and privacy	AVA-02/03/05/06/07/15/16/17
FR-S1-18	Failed/unauthorized reads communicate non-success without private disclosure or false availability	AVA-05/06/10
NFR-S1-01/08	Deny anonymous/wrong role; no secret or private Booking leakage	AVA-05/06/12
NFR-S1-07/12	Reproducible evidence, stable IDs and reviewed PR	Part F ledger/PR
NFR-S1-09	Keyboard, focus, announcements and responsive behavior are planned for manual/browser verification	AVA-13
NFR-S1-10	Record p95 and workload evidence; ≤2.0s is non-blocking and not an approved threshold	AVA-14
OD-AV-08	Customer and Tutor screens share NutTiew brand, typography, spacing, colors/accents, components, focus and navigation patterns with role-specific layouts	AVA-19

Whole-product trace anchors: FR-008/009, NFR-007/009/010, VAL-006/009/033/036, VC-S1-13/TEST-S1-13, VC-S1-15/TEST-S1-15, VC-S1-22/TEST-S1-22 and VC-S1-36/TEST-S1-36. These are planned links, not test results.

7. Definition of Done

Part E

- [ ] Five cross-linked documents exist: Feature SDS, UI spec, API spec, data spec and STS.
- [ ] FR-S1-08/09 and AC-S1-15..18 map to explicit rules, response fields, UI states and tests.
- [ ] PR #32 peer decisions are recorded with explicit CONFIRMED / CONDITIONAL / OPEN / STOP GATE states; no engineering choice is mislabeled as stakeholder business approval.

- [ ] Customer-specific bookable-only predicate includes same-Customer cross-Tutor overlap and half-open adjacency; owner comes only from the live Session.
- [ ] Empty success response always contains DB `meta.evaluatedAt` and `Cache-Control: no-store`; query returns one metadata row even when there are no offers.
- [ ] Tutor public display name remains behind its source/consent/schema/migration/allowlist gate; no email-derived or invented production name is exposed.
- [ ] Response allowlist excludes Customer identity/Booking data, credentials, Session fields and unrestricted Tutor fields.
- [ ] Shared data-foundation route B is recorded with proposed owner/reviewer/dependencies; exact Issue/PR and schema SHA remain pending, so Part F is blocked until accepted. No fake occupancy flag is added.
- [ ] Markdown links/structure and git diff --check pass.
- [ ] PR contains only the five F-S1-03 Markdown files, targets sprint1, links #15 and requests @Tanaboonnnnn.
- [ ] PR stays open for independent human review; no self-approval or self-merge.

Part F — separate implementation PR

- [ ] Start from updated sprint1 after Part E acceptance and the separately reviewed/merged shared Booking data foundation; record its exact schema SHA.
- [ ] Implement Customer-only UI → Express API → PostgreSQL read projection from real Slot and Booking rows.
- [ ] Verify occupied exclusion, Customer-specific cross-Tutor overlap and adjacency, Q05 boundary, approved Tutor-name allowlist gate, Bangkok rendering, auth/role denial, empty/error/retry and session-change privacy.
- [ ] Run keyboard/focus/announcement/responsive checks and record evidence; do not claim WCAG 2.2 AA or a 44px target pass without the corresponding assessment.
- [ ] Record real commands/results, DB/migration, source SHA and hosted CI.
- [ ] Open separate code-only PR into sprint1 and obtain peer review.

Verification boundary: this Part E change is documentation only. No build, API test, migration, Booking query, browser E2E, performance benchmark or accessibility audit is claimed as run or passed.

F-S1-04 Customer Exclusive Booking & Concurrency Protection

> ***Documentation contract only; not implemented, executed or peer-approved yet.*** *Issue #16; owner @Chxtamos; independent reviewer @Tanaboonnnnn. This Part E records the user's Sprint 1 Booking decision for OD-013 and selects the PostgreSQL transaction design for review.*

1. Authority and baseline

Sources: Sprint 1 requirements (FR-S1-10..13, 16, 18..19; BR-S1-01, 07..13, 18..21; NFR-S1-01, 03..08, 11..12; AC-S1-19..29 and AC-S1-35; VC/TEST-S1-16..27, 33, 38, 39), SRS (Q01/Q02/Q05/Q28..Q30, J-03, OD-013), System SDS (§§3.2–3.3, 6, 7.1, 7.3–7.5), Feature Inventory, and the merged #33 Foundation SDS, data contract and BDF STS.

Accepted dependencies: Auth #13, Tutor Slots #14, Customer Availability #15.

Verified branch point: `sprint1` at `ea36ef6fd3ea7e2c2582489d1326adbd335452ee`. PR #34 is merged at this commit. It accepts #33 **Part E documentation only**, not a Booking schema/migration SHA. #33 Part F must merge and publish its exact schema SHA before #16 Part F implements Booking-dependent code.

Ownership: #33 owns the canonical Booking model, migration, constraints, one `booking_guard_s1()` trigger and runtime-role boundary. #16 owns the Booking API/application transaction adapter and post-merge BDF-23. #15 remains read-only; #17 owns protected Booking retrieval. #16 must not duplicate #33's model, migration or trigger.

2. Outcome and journey

An authenticated Customer requests one selected Slot. The server derives Customer identity from the live Session, actual Tutor and interval from the persisted Slot, revalidates eligibility under the transaction protocol, and commits one `Booked` row. A new Booking is confirmed only after PostgreSQL acknowledges COMMIT.

1. Customer selects an offer in #15; selection is transient UI state, not a reservation.
2. Customer confirms one selected Slot; the request contains only `slotId`.
3. API authenticates a live Customer Session and derives owner from `principal.userId`.
4. Transaction discovers the actual Tutor, acquires all affected User rows in ascending UUID order and then all affected Slot rows in ascending UUID order, locks and revalidates the authenticated Customer's current Session on the same connection, and only then reads/replays or inserts Booking. After a recognized unique/exclusion failure and ROLLBACK, a fresh READ COMMITTED reconciliation revalidates the current User's active Customer role, then the exact Session, before any Booking read.
5. New row is inserted through the shared #33 guard; Q05 is decided using DB `T_elig` after the Slot lock.
6. Only after COMMIT does API return 201. A repeated same-Customer/same-Slot request returns 200 and the original Booking ID without another INSERT.
7. Invalid, occupied, overlapping, too-soon, unauthorized or failed attempts never produce false success or partial Booking.

3. Scope

In scope: Customer-only Booking creation; request/response/error contract; trusted owner derivation; canonical #33 data mapping; PostgreSQL SERIALIZABLE and the User → Slot → Booking domain lock order, with the authenticated Customer Session as an auth sub-lock after User/Slot locks and before Booking access; bounded full-transaction retry; Q05 and no-post-guard-contention proof; natural-key replay; confirmation/pending/conflict/uncertain UI states; planned STS mapped to existing AC/VC IDs.

Out of scope: #33 schema/model/migration/trigger implementation; #15 availability reads; #17 protected Booking list/detail; cancellation, reschedule, withdrawal, notices, payment, attendance, `Completed` or S2/S3 behavior; any Idempotency-Key, registry table, payload fingerprint, replay TTL/window column, new Booking column or new natural-key DB constraint.

4. Invariants

Invariant	F-S1-04 contract
Ownership	`customerId = principal.userId` from live active Customer Session; never trust client owner/role.

Invariant	F-S1-04 contract
User authorization	Booking belongs to the current active User only while `User.isActive=true` and `User.role='Customer'`. After post-ROLLBACK, revalidate the latest User row from the original `principal.userId` before Session or Booking access; missing/inactive → 401, active wrong role → 403, no Booking DTO.
Session validity	HTTP `requireSession` is preliminary only. Lock `principal.sessionId` on the SERIALIZABLE mutation connection after User and Slot lock waits; recheck `revokedAt IS NULL` and `expiresAt > clock_timestamp()` before replay/INSERT. After a recognized `23505` / `23P01` ROLLBACK, a fresh READ COMMITTED reconciliation locks/revalidates current User first, then the same Session before any Booking read/200/409; invalid Session returns 401 with no DTO.
Tutor / Slot	`currentSlotId` is selected persisted Slot. Tutor derives through `Slot.tutorId`; Booking does not duplicate `tutorId`.
Interval	Copy persisted Slot `startsAt` / `endsAt`; never accept either timestamp or duration from client.
State	New Sprint 1 Booking status is `Booked`; `Past` is display-only and does not release occupancy.
Exclusivity	At most one Active (`Booked`) row per Slot.
Customer overlap	No positive-duration overlapping Active Bookings for one Customer across Tutors; half-open `[start,end)` means adjacency is allowed.
Q05	At authoritative DB `T_elig`, `Slot.startsAt - T_elig >= 60 minutes`; exact 60:00 passes, 59:59 fails.
Atomicity	No success before COMMIT; rejected/aborted attempt leaves no partial Booking or phantom occupancy.
Lifecycle	Sprint 1 Booking is append-only; this feature performs INSERT only.

5. Decision record — OD-013, Sprint 1 Booking only

USER-APPROVED — 7 November 2026: use **Natural-key idempotency without an Idempotency-Key**. The existing active Booking pair `(authenticated customerId, slotId)` identifies a repeated request:

- First successful creation: **201 Created** with the committed Booking ID.
- Same authenticated Customer submits the same Slot again after a successful commit: **200 OK** with the **original Booking ID**; do not insert a second row.
- Different Customer attempts a Slot already occupied by another Customer: **409 Conflict**, without disclosing the other Customer or Booking.
- Same Customer requests a different Slot that overlaps an existing Active Booking: **409 Conflict**.
- If the first response is lost or COMMIT outcome is unknown, retry the **same POST with the same** `slotId`. If the original row committed, reconcile it and return its original ID.

The pair is an application-level lookup/reconciliation key, **not** a new persisted key or database unique constraint. No key format, registry table, fingerprint or replay TTL is added. The committed #33 Booking row is the durable source of truth. A matching row qualifies for replay only while its status is `Booked`; future cancellation/rebooking behavior is outside this Sprint 1 contract.

This resolves the **Booking-create portion** of SRS OD-013 for F-S1-04. OD-013 remains open for future S2 reschedule/cancel operations until those features have their own reviewed contracts. The decision is recorded in Issue #16.

Replay remains valid after later Tutor account changes: if the same-pair `Booked` row is already committed, an active Customer with a live Session still receives 200 and the original Booking ID even if that Slot's Tutor is subsequently deactivated or changes away from role `Tutor`. Current Tutor `role='Tutor'` / `isActive=true` eligibility is enforced only when attempting a **new INSERT**. An ineligible Tutor makes a new claim return generic 409 `SLOT_UNAVAILABLE`, without disclosing Tutor identity/status; it does not revoke or hide an existing Booking replay.

6. Engineering selections for peer review

- PostgreSQL **SERIALIZABLE** for every Booking mutation attempt.
- Preserve the System SDS **domain** lock order: all affected User rows in ascending UUID order → all affected Slot rows in ascending UUID order → existing Booking rows in ascending UUID order only where needed. After all User and Slot locks, lock only the current Customer `Session` row (`principal.sessionId`) as an authentication sub-lock before any Booking read/lock; this does not reverse the domain order. Hold it through COMMIT. No path may lock Session and then request User, Slot or Booking locks. Existing F-S1-02 takes User → Session but creates a new Slot row without acquiring an existing Slot row lock, so it does not invert this row-lock order. A new Booking INSERT has no pre-existing Booking row to lock.
- Retry the whole transaction for SQLSTATE `40001`, `40P01` or ORM-equivalent `P2034`; maximum **three total mutation attempts**, with fresh discovery/locks and fresh `T_elig` on every new INSERT attempt.
- `23505` / `23P01` are not blind mutation retries. Only structured tuples `23505 / booking_one_active_per_slot` and `23P01 / booked_customer_no_overlap` enter reconciliation; unknown/missing/mismatched tuples fail closed as 500 `INTERNAL_ERROR` without Booking reads. After ROLLBACK, a fresh READ COMMITTED connection locks/revalidates current User (`isActive`, `role='Customer'`) first, then the exact Session (`userId`, `revokedAt`, DB-clock `expiresAt`) before any Booking read. Missing/inactive User → 401; active wrong role → 403; invalid Session → 401; DB validation unavailable → 503. Only a currently active Customer with a live Session may receive 200 original ID for a same-pair committed row, or the cause-specific 409 if no same-pair row exists.
- Revalidate the live Session on the same SERIALIZABLE connection **after all User and Slot lock waits**: lock `principal.sessionId` with `FOR UPDATE`; verify `userId = principal.userId`, `revokedAt IS NULL` and `expiresAt > clock_timestamp()` before replay/INSERT. A revocation committed during either lock wait is observed after the wait or causes `40001` and a fresh transaction; expiry during a wait fails the DB-clock check. Never return 200 replay or 201 from an invalid Session. A missing exact Session row/owner mismatch at the transactional lock returns 401 immediately; only a PostgreSQL `40001` caused by a concurrent row change/stale snapshot is retried. After Customer/Session authorization, same-pair replay is checked before current Tutor eligibility; an inactive/non-Tutor account rejects only a new claim with 409 `SLOT_UNAVAILABLE`.
- Reuse Auth OD-005-C: obtain the stable CSRF token from `GET /api/v1/auth/csrf`, then call `GET /api/v1/auth/me` again and compare the returned `X-NutTiew-Session-Binding` and identity with the initial result; the CSRF response itself contains only `csrfToken` and is not a binding source. If they differ, discard the token and restart bootstrap. Require `X-NutTiew-Expected-Session-Binding` on the Booking POST; a Session switch after the final recheck must fail before mutation as `SESSION_BINDING_MISMATCH` or `CSRF_DENIED`, then reset bootstrap. The UI must discard late responses after its auth/session epoch changes, including a different Session for the same User.
- #33 trigger uses PostgreSQL `clock_timestamp()` after its Slot lock. Application/browser time, HTTP arrival, transaction-start `now()`, #15 `T_view` and commit time are not authoritative. Non-Offered and Q05 trigger rejections have distinct stable SQLSTATE/constraint pairs: `P0B01 / booking_slot_not_offered` and `P0B02 / booking_q05_min_notice` respectively; #33 Part F must implement and publish this dependency.

- BDF-23 must prove no conflict-capable unique/exclusion wait can occur after `T_elig`, or prove the complete transaction aborts/retries with fresh locks and DB time. A stale-time INSERT that commits after an unaccounted post-guard wait fails the design gate.

These are engineering selections pending independent @Tanaboonnnnn review and real-PostgreSQL proof, not executed results or new stakeholder business rules.

7. Acceptance and traceability

Existing criterion	Contract interpretation	Planned STS
AC-S1-19	One eligible request commits one `Booked` row with authenticated Customer, actual Slot/Tutor relationship and copied interval.	BOOK-01
AC-S1-20 and AC-S1-21	Exact 60:00 passes; 59:59 fails at trigger `T_elig`.	BOOK-02/03
AC-S1-22	Another Customer cannot claim an occupied Slot; no private owner data is returned.	BOOK-04
AC-S1-23 and AC-S1-24	Positive same-Customer overlap across Tutors is denied; adjacency is allowed.	BOOK-05/06
AC-S1-25 and AC-S1-26	Race B (two Customers/one Slot) and Race C (one Customer/two overlapping Tutors) have separate barriers and final-row assertions.	BOOK-10/11
AC-S1-27 / VC-S1-33	Stale/invalid selection and persistence failure never produce phantom success or inconsistent occupancy.	BOOK-07/08/12/21/26/27
AC-S1-28	Customer/Tutor identity is derived from Session/Slot, not request fields.	BOOK-09
BR-S1-13 / OD-005-A/B/C	Current active Customer User and Session remain authorized after User/Slot waits and are revalidated again after ROLLBACK before reconciliation; Session-bound CSRF and binding prevent stale-session mutation or late-response disclosure.	BOOK-26..30
AC-S1-29 / VC-S1-38	Same-pair replay returns 200 and same Booking ID only for a currently active Customer with a live Session; post-ROLLBACK reconciliation returns 401/403 for invalid current User authorization and 401 for revoked/expired Session. Unknown constraint tuples never produce replay.	BOOK-13..16, BOOK-30
AC-S1-35 / VC-S1-39	Request arriving before cutoff but waiting until after cutoff is rejected by post-lock DB `T_elig`.	BOOK-17/19

Related requirements: FR-S1-10..13, 16, 18..19; BR-S1-01, 07..13, 18..21; NFR-S1-01, 03..08, 11..12; Q01/Q02/Q05/Q28/Q29/Q30; VAL-007..011/014/030. Tests are planned / NOT RUN in Part E.

8. Definition of Done

Part E — specification-only PR

- [ ] Feature SDS, UI, API, data, transaction and STS documents are cross-linked and consistent.

- [ ] User-approved OD-013 Sprint 1 Booking decision is recorded without closing future S2 retry decisions.
- [ ] PostgreSQL SERIALIZABLE, User → Slot → Session(auth sub-lock) → Booking acquisition, bounded whole-transaction retry and Q05 authority are explicit; after post-ROLLBACK, current User authorization is revalidated before Session, and both are revalidated on a fresh READ COMMITTED connection before Booking reads/200/409.
- [ ] Auth CSRF is acquired through the existing endpoint, tied to the current Session binding, and stale responses are ignored after logout/account/session switch.
- [ ] Non-Offered and Q05 trigger failures have distinct, stable #33 SQLSTATE/constraint mappings and separate STS assertions; unique/exclusion reconciliation allowlists only the exact canonical SQLSTATE/constraint pairs and fails closed for unknown constraints.
- [ ] Same-pair `Booked` replay is checked before occupied/Q05 rejection; returns original ID without INSERT.
- [ ] No-post-guard-contention / BDF-23 is a hard proof gate and is not claimed to have passed.
- [ ] AC-S1-19..29/35 and VC/TEST-S1-16..27/33/38/39 are traceable to planned cases.
- [ ] No Prisma schema, migration, API implementation, UI implementation or executable test is added.
- [ ] Markdown links/structure/IDs and `git diff --check` pass.
- [ ] PR targets `sprint1`, links #16, requests @Tanaboonnnnn and stays open for independent human review.

Part F — separate implementation PR

Only after Part E acceptance and #33 Part F schema merge: consume exact schema SHA; implement Customer POST/transaction adapter against the one canonical #33 model/guard; TDD authorization/replay/conflict/Q05/Race B/C/rollback; run BDF-23 with real PostgreSQL; record commands, environment, schema/source SHA and actual results; open a separate reviewed code PR into `sprint1`.

Verification boundary: Part E is documentation only. No build, migration, application test, API call, browser test or BDF case is claimed as executed.

F-S1-05 Customer Private Booking Retrieval & Tutor Schedule View

> ***Documentation contract only; not implemented, executed, or peer-approved yet.***

> *Issue #17; provisional lead @Chxtamos; independent peer reviewer @Tanaboonnnnn.*

> *This Part E document specifies the data allowlists, authorization boundaries, UI/API contracts, and Software Test Specification (STS) for Sprint 1 Booking retrieval and Tutor schedule inspection. This change does not implement UI/API code, add a migration, execute tests, or close the issue.*

---

1. Authority, Baseline, and Mission

1.1 Source Hierarchy

This specification derives from and complies with:

1. **Sprint 1 Requirements:**

- Functional requirements: `FR-S1-04`, `FR-S1-07`, `FR-S1-14`, `FR-S1-15`, `FR-S1-16`, `FR-S1-17`, `FR-S1-18`, `FR-S1-19`.
- Business rules: `BR-S1-01`, `BR-S1-02` (60m duration), `BR-S1-03` (manual offer), `BR-S1-12` (Asia/Bangkok timezone), `BR-S1-14`, `BR-S1-15`, `BR-S1-16`, `BR-S1-17`, `BR-S1-18`, `BR-S1-22`.
- Non-functional requirements: `NFR-S1-01` (Access isolation), `NFR-S1-02` (Credential protection), `NFR-S1-03` (Persistent correctness), `NFR-S1-06` (Time-boundary correctness), `NFR-S1-07` (Reproducible verification), `NFR-S1-08` (No secret leakage), `NFR-S1-09` (Usability proposal — keyboard & visible focus), `NFR-S1-12` (Traceable change & review).
- Acceptance criteria: `AC-S1-30`, `AC-S1-31`, `AC-S1-32`, `AC-S1-33`, `AC-S1-34`.
- Planned validation anchors: `VC/TEST-S1-28`, `VC/TEST-S1-29`, `VC/TEST-S1-30`, `VC/TEST-S1-31`, `VC/TEST-S1-32`.
- Direct stakeholder decisions: `Q01` (Single booking), `Q02` (Role authorization), `Q03` (Fixed 60-minute Slot duration), `Q04` (Manual individual Slot offers, no recurrence), `Q05` (Cutoff lead time), `Q28` (Overlap rules), `Q29` (Single Asia/Bangkok business timezone), `Q30` (Booked vs Past status, never Completed in S1).

1. **Whole-product SRS:** System actors, user journeys `J-01` (Auth), `J-02` (Tutor publishing), `J-03` (Customer booking), `J-04` (Customer booking review), `J-05` (Tutor schedule review).
2. **System SDS:** §§3.2–3.3 (Data entity relations), §4 (API conventions and error envelopes), §5 (Role & record level authorization), §6 (Timezone handling in UTC on wire and Asia/Bangkok on display).
3. **Accepted Preceding Contracts:**

- Auth F-S1-01: Session cookie, identity, role guard, rate limiting, and CSRF token.
- Tutor Availability F-S1-02: Owned 60-minute Slots, `startsAt` / `endsAt`, `lifecycle = 'Offered'`.
- Customer Availability Discovery F-S1-03: Bookable Slot filtering, `T_view` evaluation, opaque Tutor references.
- Booking Data Foundation D1-08A/B: Canonical `Booking` table, `booking_guard_s1()` trigger, GiST exclusion constraints, and pre-index `User` lock (`da17acf`).
- Exclusive Booking F-S1-04: SERIALIZABLE adapter, natural-key replay, committed `Booked` status.

1.2 Repository Baseline

- Integration base: `origin/sprint1` at commit `ed78bbad9da8c828e9b0bd1c79ea8f68f553c9b1`, containing all merged foundations:
- Auth implementation (PR #26)
- Tutor Slots & Dashboard (PR #28, PR #31)
- Shared Booking Data Foundation (PR #36) & Remediation (PR #40)
- Customer Availability Discovery (PR #37)
- Customer Exclusive Booking & BDF-23 (PR #38)

---

2. Mission and Core Outcomes

2.1 The Two Primary User Outcomes

1. **Customer-Private Booking Review (`FR-S1-14` , `AC-S1-30` , `AC-S1-31`):**

An authenticated Customer can retrieve a complete list of their **own** committed Bookings and open individual Booking details after browser refresh or application restart. The details display Booking ID, Slot ID, Tutor reference/identity, appointment interval in Asia/Bangkok time, and business status (`Booked` or time-derived `Past`). No unauthorized Customer or anonymous caller can read or discover any private Booking payload.

1. **Authorized Tutor Schedule Inspection (`FR-S1-07` , `FR-S1-15` , `AC-S1-32` , `AC-S1-33`):**

An authenticated Tutor can inspect the collection of Slots and associated Bookings on their **own** authorized schedule. The Tutor schedule view projects each Slot's occupancy state (`Unoccupied` vs `Occupied`) and lists active Bookings assigned to their schedule without leaking other Tutors' restricted schedule records or foreign Customer data. For privacy and data minimization, Customer identity on the Tutor schedule is represented by a pseudonymous truncated reference (`customerRef: "CUST-" + customerId.slice(0, 8)`), omitting personal identifiers (name, email, phone) and isolating customer UUIDs from the Tutor wire DTO.

2.2 Time-Derived Classification: "Past" is NOT "Completed" (`FR-S1-17` , `BR-S1-14/22` , `AC-S1-34` , `Q30`)

- In Sprint 1, the database business status of an active appointment is always `'Booked'` (or `'Cancelled'` in future sprints).
- When the appointment window has elapsed relative to the single statement evaluation timestamp (`endsAt <= meta.evaluatedAt`), the UI and API classify the presentation as `Past` .
- **Strict Invariant:** An elapsed appointment **MUST NOT** be automatically updated to `'Completed'` , marked as attended, canceled, or released back to the bookable pool. The persisted database row remains `status = 'Booked'` , and the Slot remains occupied.

---

3. Boundaries and Scope

3.1 In Scope for Sprint 1 (F-S1-05)

- **Customer Endpoints:**
- `GET /api/v1/customer/bookings` : Returns all Bookings belonging strictly to `principal.userId` .
- `GET /api/v1/customer/bookings/:id` : Returns single Booking detail if owned by `principal.userId` ; returns `404 BOOKING_NOT_FOUND` if non-existent or owned by another user.
- **Tutor Endpoints:**
- `GET /api/v1/tutor/slots` : Updated to project dynamic occupancy (`Occupied` if an active `Booked` row exists on that Slot, else `Unoccupied`).
- `GET /api/v1/tutor/bookings` : Returns all active Bookings scheduled on Slots owned by `principal.userId` .
- **Backend Record-Level Security:**
- All ownership filters are strictly bound to `principal.userId` from the authenticated session; never trust client-supplied IDs, query parameters, or route tampering.
- Fail closed on unauthorized access: anonymous calls return `401 UNAUTHENTICATED` ; role mismatches return `403 FORBIDDEN` ; foreign record queries return `404 BOOKING_NOT_FOUND` (preventing ID enumeration).
- **Time Handling:**
- Wire timestamps: Strict ISO 8601 / RFC 3339 UTC strings ending in `Z` with milliseconds (e.g., `YYYY-MM-DDTHH:mm:ss.sssZ`).

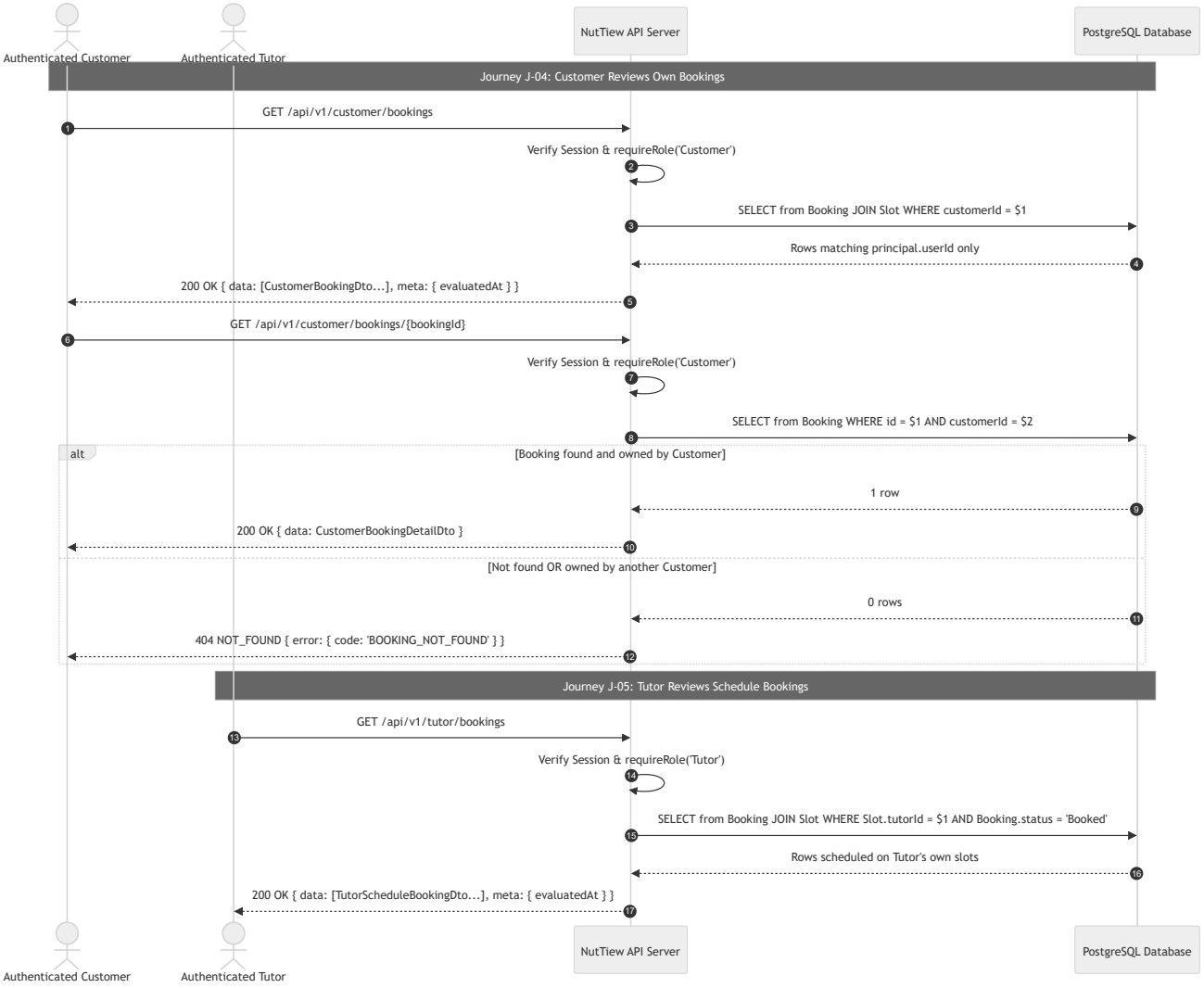
- Evaluation timestamp: API returns `meta.evaluatedAt` representing server-authoritative time used for the `displayStatus` derivation.
- UI Presentation: Formatted strictly in `Asia/Bangkok` timezone (UTC+7) regardless of local device timezone.
- **Durable Persistence Proof:**
- Data retrieval queries committed rows from PostgreSQL database tables (`Booking` , `Slot` , `User`).
- Persistence holds across app restart and browser reloads.

3.2 Explicitly Out of Scope for Sprint 1

- **No Mutation:** F-S1-05 is strictly a read-only retrieval feature; it performs zero database `INSERT` , `UPDATE` , `DELETE` , or schema DDL.
- **No Sprint 2/3 Capabilities:**
- Customer cancellation (`Q07–Q08`) or rescheduling (`Q09–Q16`).
- Tutor withdrawal reasons, cancellations, or slot modifications (`Q17–Q20` , `Q26–Q27` , `Q32`).
- In-app notification center or email delivery (`Q21–Q25`).
- Tutor appointment summary dashboard with attendance tracking (`Q31`).
- Review, rating, messaging, payments, or attendance logging.
- **No Unapproved Query Parameters:** No filtering, search, pagination, date-range bounding, or custom sorting is approved for Sprint 1. Requests with unexpected query parameters fail with `400 INVALID_INPUT` .

---

4. User Journeys and Actors



5. Architectural Invariants and Decisions

Decision / Invariant ID	Summary	Rationale & Enforcement
INV-RET-01: Session-Bound Ownership	All read queries filter strictly by `principal.userId` extracted from the server-validated session.	Client cannot forge or query other users' data. URL tampering produces `404` or `403`.
INV-RET-02: Safe Enumeration Refusal (404 instead of 403)	If a Customer requests `/api/v1/customer/bookings/:id` for an ID that exists but belongs to someone else, return `404 BOOKING_NOT_FOUND`.	Returning `403 FORBIDDEN` confirms the ID exists in the system (information leakage). `404` prevents ID brute-forcing.
INV-RET-03: No Phantom Completion	Elapsed appointments (`endsAt <= meta.evaluatedAt` , using statement snapshot) have `displayStatus = 'Past'` , while `status = 'Booked'` .	Adheres strictly to `Q30` , `FR-S1-17` , and `BR-S1-22` . Sprint 1 does not implement attendance or completion.

Decision / Invariant ID	Summary	Rationale & Enforcement
INV-RET-04: Dynamic Slot Occupancy	`listOwnSlots` determines `occupancy` via an active `Booked` record matching `Booking.currentSlotId = Slot.id`.	Delivers `FR-S1-07` without adding a mutable `Slot.isBooked` column, preserving single-source-of-truth normalization.
INV-RET-05: Strict UTC Wire Normalization & Bangkok Presentation	Timestamps returned by the API are normalized to UTC with trailing `Z` on the wire, while UI presentation formats strictly in Asia/Bangkok time.	Satisfies `BR-S1-12`, `Q29`, and `NFR-S1-06`; eliminates ambiguity caused by database server or runtime timezone settings.
INV-RET-06: Strict Query Allowlist	Query strings are forbidden (`Object.keys(req.query).length === 0`).	Prevents SQL injection, parameter pollution, and unapproved filtering features (`NFR-S1-08`).
INV-RET-07: Minimal Payload Privacy	Responses exclude password hashes, CSRF nonces, session digests, and unapproved contact data.	Strict DTO allowlists satisfy `NFR-S1-01` and `NFR-S1-08`.
INV-RET-08: Pseudonymous Customer Reference	`customerRef: "CUST-" + customerId.slice(0, 8)` is a truncated pseudonymous identifier, not an irreversible anonymization.	Provides data minimization for Tutor schedule display by withholding customer name, email, and phone, while maintaining an opaque operational reference.

6. Acceptance Criteria and Traceability Matrix

Requirement ID	Acceptance Criteria	Business Rule	Verification Anchor	Description
`FR-S1-14`, `FR-S1-16`	**AC-S1-30**	`BR-S1-01`, `BR-S1-15`	`VC/TEST-S1-28`	Customer retrieves own list/detail after refresh/restart with exact Booking ID, Tutor, Bangkok interval, and status.
`FR-S1-04`, `FR-S1-14`	**AC-S1-31**	`BR-S1-15`, `BR-S1-18`	`VC/TEST-S1-29`	Customer B attempts to view Customer A's Booking ID; API returns safe `404 BOOKING_NOT_FOUND` with zero data leakage.
`FR-S1-07`, `FR-S1-15`	**AC-S1-32**	`BR-S1-16`	`VC/TEST-S1-30`	Tutor views Bookings on own schedule; occupied slots display `Occupied`; only assigned Bookings are visible.
`FR-S1-04`, `FR-S1-15`	**AC-S1-33**	`BR-S1-16`, `BR-S1-18`	`VC/TEST-S1-31`	Tutor B attempts to read Tutor A's schedule/bookings; access denied, zero foreign records disclosed.
`FR-S1-17`	**AC-S1-34**	`BR-S1-14`, `BR-S1-22`	`VC/TEST-S1-32`	An elapsed appointment displays as `Past`, but persisted business state remains `Booked`, never `Completed`.

7. Definition of Done (DoD)

Part E — Specification Stage (Current PR)

- [ ] Complete `specification.md`, `api-spec.md`, `ui-spec.md`, `data-spec.md`, and `tests.md` authored under `docs/features/F-S1-05/`.
- [ ] Invariants, request/response DTO schemas, and error codes strictly mapped to requirements and existing architecture.
- [ ] No application code, migrations, or tests implemented in this documentation PR.
- [ ] Peer review requested from @Tanaboonnnnn and approved before branching Part F.

Part F — Implementation Stage (Subsequent Work)

- [ ] Backend route handlers, services, and queries implemented for Customer bookings and Tutor schedule views.
- [ ] Tutor own-slots list updated to project dynamic occupancy from committed `Booking` rows.
- [ ] Customer and Tutor UI components connected to live API endpoints.
- [ ] STS test suite `RET-01..RET-17` executed with real PostgreSQL and Playwright browser, achieving 100% PASS.

Part F: Sprint 1 Implementation, Verification & Release Evidence

1. Truthful Automated Test Execution Summary

Automated testing was executed directly on PR #43 HEAD (`e591f72`) against real PostgreSQL 17.2 and Microsoft Edge / Chromium headless browsers. All test results reported below are 100% verified through executed test runs and verified GitHub Actions CI workflows:

Test Suite Category	Test Execution Command	Observed Result	Passed	Failed	Skipped	Distinct Total
Pure Domain Unit & Contract Tests	`npm test -w @nuttiew/api`	**PASS**	29	0	0	**29**
Real PostgreSQL DB Integration Tests	`npm run test:db -w @nuttiew/api`	**PASS**	106	0	0	**106**
Browser End-to-End Tests (Suite)	`npx playwright test`	**PASS**	64	0	0	**64**
TypeScript Static Typecheck	`npm run typecheck --workspaces`	**PASS**	0 errors	-	-	**Clean**
Production Production Build	`npm run build --workspaces`	**PASS**	Clean bundle	-	-	**Clean**

$$\text{Total Distinct Automated Tests: } 29 \text{ (Unit)} + 106 \text{ (DB)} + 64 \text{ (E2E)} = \mathbf{199 \text{ Distinct Tests (100\% Pass Rate, 0 Failures)}}$$

> ***Accounting Note on Test Count:*** *The full browser test suite of 64 tests already includes the comprehensive Sprint 1 End-to-End Domain Journey test (`e2e/sprint1.journey.spec.ts`) as test [39/64]. Therefore, the total count of distinct automated tests is exactly **199 distinct tests** (29 + 106 + 64), avoiding any double-counting of standalone invocations.*

---

2. Complete Stakeholder Acceptance Criteria Traceability Matrix (AC-S1-01..35 → VC/TEST-S1-01..39)

Every stakeholder-accepted requirement from `docs/requirements.md` and `docs/traceability.md` maps to an executed automated test with observed pass results:

AC ID	Stakeholder Requirement & Scenario	Verification ID	Test File & Executed Suite	Observed Result
AC-S1-01	Valid Customer credentials authenticate as Customer role	`VC-01/03`	`apps/api/test/auth.db.test.ts`	**PASS**
AC-S1-02	Valid Tutor credentials authenticate as Tutor role	`VC-01/03`	`apps/api/test/auth.db.test.ts`	**PASS**
AC-S1-03	Invalid password or unknown credentials return generic 401	`VC-02`	`apps/api/test/auth.db.test.ts`	**PASS**
AC-S1-04	Logout invalidates session in DB; reuse of old access is rejected	`VC-04`	`apps/api/test/auth.extended.db.test.ts`	**PASS**
AC-S1-05	Unauthenticated request to protected endpoints rejected	`VC-05`	`apps/api/test/auth.db.test.ts`	**PASS**
AC-S1-06	Authenticated Customer forging Tutor slot request is denied	`VC-06`	`apps/api/test/guards.db.test.ts`	**PASS**
AC-S1-07	Tutor A cannot inspect or mutate Tutor B's private schedule	`VC-07/31`	`apps/api/test/guards.db.test.ts`	**PASS**
AC-S1-08	Tutor creates 60-minute future slot; persisted on own schedule	`VC-08/14`	`apps/api/test/slots.db.test.ts`	**PASS**
AC-S1-09	Same Tutor creating overlapping slot is rejected (GiST exclusion)	`VC-09`	`apps/api/test/slots.race.db.test.ts`	**PASS**

AC ID	Stakeholder Requirement & Scenario	Verification ID	Test File & Executed Suite	Observed Result
AC-S1-10	Same Tutor creating exactly adjacent 60-minute slot is permitted	`VC-10`	`apps/api/test/slots.db.test.ts`	**PASS**
AC-S1-11	Different Tutors independently offering same appointment time permitted	`VC-11`	`apps/api/test/slots.db.test.ts`	**PASS**
AC-S1-12	Past or malformed start date/time rejected without persistence	`VC-12`	`apps/api/test/slots.db.test.ts`	**PASS**
AC-S1-13	Race A: Concurrent overlapping slot creation by same Tutor serializes to 1 commit	`VC-37 / TEST-S1-37`	`apps/api/test/slots.race.db.test.ts`	**PASS**
AC-S1-14	Non-Bangkok browser timezone displays correct Bangkok appointment hours	`VC-13`	`e2e/slots.spec.ts`	**PASS**
AC-S1-15	Customer browses eligible offered slots with Tutor ref and Bangkok time	`VC-15`	`apps/api/test/availability.db.test.ts`	**PASS**
AC-S1-16	Occupied slots and slots within Q05 cutoff excluded from bookable list	`VC-15/22`	`apps/api/test/availability.db.test.ts`	**PASS**
AC-S1-17	Customer submitting on stale offer rechecks eligibility; rejected if taken	`VC-22`	`e2e/booking.spec.ts`	**PASS**
AC-S1-18	Device in non-Bangkok locale does not alter Bangkok schedule semantics	`VC-13/15`	`e2e/availability.spec.ts`	**PASS**
AC-S1-19	Customer books eligible offered slot; commits Booked row	`VC-16`	`apps/api/test/bookings.db.test.ts`	**PASS**
AC-S1-20	Slot starts 15:00; request at exactly 14:00:00 (60:00 cutoff) accepted	`VC-17`	`apps/api/test/bookings.db.test.ts`	**PASS**
AC-S1-21	Slot starts 15:00; request at 14:00:01 (59:59 cutoff) rejected with 422	`VC-18`	`apps/api/test/bookings.db.test.ts`	**PASS**
AC-S1-22	Customer B attempting to book slot already held by Customer A rejected (409)	`VC-19`	`apps/api/test/bookings.db.test.ts`	**PASS**

AC ID	Stakeholder Requirement & Scenario	Verification ID	Test File & Executed Suite	Observed Result
AC-S1-23	Customer holding Booking with Tutor A cannot book overlapping slot with Tutor B	`VC-20`	`apps/api/test/bookings.db.test.ts`	**PASS**
AC-S1-24	Customer booking adjacent intervals across different tutors permitted	`VC-21`	`apps/api/test/bookings.db.test.ts`	**PASS**
AC-S1-25	Race B: Two customers concurrently requesting same slot serialize to at most 1 commit	`VC-25 / TEST-S1-25`	`apps/api/test/bookings.db.test.ts`	**PASS**
AC-S1-26	Race C: Customer concurrently submitting overlapping slots across tutors serializes	`VC-26 / TEST-S1-26`	`apps/api/test/bookings.db.test.ts`	**PASS**
AC-S1-27	Injected database fault during booking rolls back transaction cleanly without phantom row	`VC-22/27/33`	`apps/api/test/booking.foundation.db.test.ts`	**PASS**
AC-S1-28	Body manipulation to forge customerId rejected; owner derived from session	`VC-24`	`apps/api/test/bookings.db.test.ts`	**PASS**
AC-S1-29	In-flight / double-click retry preserves single-booking invariant (200 replay)	`VC-38 / TEST-S1-38`	`apps/api/test/bookings.db.test.ts`	**PASS**
AC-S1-30	Customer retrieves persisted private bookings list across page reload	`VC-28`	`apps/api/test/retrieval.db.test.ts`	**PASS**
AC-S1-31	Cross-customer probe returns safe 404 BOOKING_NOT_FOUND (no enumeration)	`VC-29`	`apps/api/test/retrieval.db.test.ts`	**PASS**
AC-S1-32	Tutor retrieves own schedule bookings; displays pseudonymous customerRef	`VC-30`	`apps/api/test/retrieval.db.test.ts`	**PASS**
AC-S1-33	Cross-tutor schedule lookup returns safe 403 / empty without disclosing records	`VC-31`	`apps/api/test/retrieval.db.test.ts`	**PASS**
AC-S1-34	Past booking interval shows status Booked with displayStatus Past (no Completed claim)	`VC-32`	`apps/api/test/retrieval.db.test.ts`	**PASS**
AC-S1-35	Request arrives pre-cutoff (13:59:59) but waits until post-cutoff (14:00:01) -> rejected	`VC-39 / TEST-S1-39`	`apps/api/test/bookings.db.test.ts`	**PASS**

3. Concurrency Invariants & Real Database Race Verification

The NutTiew platform implements rigorous concurrency protection across three distinct race conditions on real PostgreSQL:

3.1 Race A: Concurrent Slot Creation by Same Tutor (SLOT-10 / SQLSTATE 23P01)

- **Problem:** A tutor submits two rapid or parallel requests to create overlapping availability windows.
- **Enforcement Mechanism:** PostgreSQL `btree_gist` exclusion constraint:

```
ALTER TABLE "Slot" ADD CONSTRAINT offered_slot_no_overlap_per_tutor
  EXCLUDE USING gist (
    "tutorId" WITH =,
    tstzrange("startsAt", "endsAt", '[)') WITH &&
  ) WHERE ("lifecycle" = 'Offered');
```

- **Observed Execution Log (`apps/api/test/slots.race.db.test.ts`):**

```
RACE_A_OBSERVED {"first":"A","holderPid":34916,"aPid":37672,"bPid":26196,"statuses":[201,409],"committed":[
RACE_A_DIRECT_SQL_OBSERVED {"aPid":34916,"bPid":23272,"loserSQLSTATE":"23P01"}
```

Exactly one slot commits (`201 Created`); the losing transaction is blocked by GiST and aborted by PostgreSQL with `SQLSTATE 23P01` (`exclusion_violation`), which the API translates to safe `409 Conflict`.

3.2 Race B: Concurrent Booking on the Same Offered Slot (BOOK-10 / SLOT_ALREADY_BOOKED)

- **Problem:** Customer 1 and Customer 2 concurrently attempt to book the exact same offered slot under an atomic synchronization barrier.
- **Enforcement Mechanism:** Pessimistic row locking with `SELECT ... FOR UPDATE` on the `Slot` record inside an atomic database transaction.
- **Observed Execution Log (`apps/api/test/bookings.db.test.ts`):**

```
BOOK10_RACE_B_EVIDENCE {"slotId":"bfd3a9a6-94cb-4619-b97e-47c7fcbdf805","winnerPid":7968,"waiterPid":17456,
```

The winner acquires the lock, validates eligibility, and commits `201 Created`. The waiting backend is released only after commit, observes `Slot.lifecycle` is no longer `Offered`, and safely fails with `409 Conflict` (`SLOT_ALREADY_BOOKED`).

3.3 Race C: Concurrent Overlapping Bookings Across Tutors by Same Customer (BOOK-11)

- **Problem:** A customer concurrently books two distinct tutors whose offered time intervals overlap.
- **Enforcement Mechanism:** Canonical lock ordering (Option 1) acquiring `User(customerId) FOR UPDATE` in `booking_guard_s1()` before locking `Slot`, backed by exclusion constraint `booked_customer_no_overlap`.
- **Observed Execution Log (`apps/api/test/bookings.db.test.ts`):**

Under 10 parallel attempts across independent connection pools, exactly one booking commits, and all 9 competing attempts receive `409 Conflict` (`CUSTOMER_TIME_OVERLAP`). Zero overlapping appointments committed.

4. Required Concrete Test Code Excerpts (Instructor §4.2)

4.1 Domain-Rule Test Excerpt: Q05 60-Minute Cutoff Post-Lock Drift (`BOOK-17`)

This test proves that if an HTTP request reaches the server before cutoff (e.g. 60:01 before start) but waits on a concurrency lock until the cutoff is crossed (e.g. 59:59 before start), the transaction evaluates authoritative `clock_timestamp()` *after* acquiring the lock and rejects the booking:

```
// apps/api/test/bookings.db.test.ts (lines 855-895)
it('BOOK-17 enforces Q05 at post-wait DB T_elig when HTTP arrives before cutoff and lock wait crosses cutoff'
  const tempCustomerEmail = `book-c17-${marker}@example.test`;
  const tempCustomerId = await createUser(tempCustomerEmail, 'Customer');
  const tempCustomerAuth = await loginBundle(tempCustomerEmail, tempCustomerId);
  const tempTutor = await createUser(`book-t17-${marker}@example.test`, 'Tutor');
  const nowRes = await ownerPool.query<{ now: Date }>('SELECT clock_timestamp() AS now');

  // Slot starts in exactly 60m + 1.8s (eligible at arrival, ineligible after 2.1s lock wait)
  const slot = await createSlot(
    tempTutor,
    new Date(nowRes.rows[0].now.getTime() + 60 * 60_000 + 1_800),
  );

  const holder = await ownerPool.connect();
  try {
    await holder.query('BEGIN');
    await holder.query('SELECT "id" FROM "Slot" WHERE "id"=$1 FOR UPDATE', [slot.id]);

    // Launch booking request in parallel; it will block waiting for the Slot lock
    const pendingBooking = createCustomerBooking(
      runtimePool,
      { userId: tempCustomerAuth.userId, sessionId: tempCustomerAuth.sessionId },
      slot.id,
    );

    // Hold lock until the database clock crosses the 60-minute cutoff
    await new Promise(resolve => setTimeout(resolve, 2_100));
    await holder.query('ROLLBACK'); // Release lock

    // The booking attempt must be rejected with 422 BOOKING_NOT_ELIGIBLE
    await expect(pendingBooking).rejects.toMatchObject({
      statusCode: 422,
      code: 'BOOKING_NOT_ELIGIBLE',
    });
  } finally {
    holder.release();
  }
});
```

4.2 Authorization Test Excerpt: Cross-Customer Safe 404 & Schedule Isolation (`RET-03`)

This test verifies that if Customer B attempts to probe or retrieve Customer A's private booking by guessing its UUID, the server responds with HTTP `404 BOOKING_NOT_FOUND` rather than 403, preventing ID enumeration and private appointment leakage:

```
// apps/api/test/retrieval.db.test.ts (lines 214-224)
it('RET-03: Cross-Customer probe returns safe 404 BOOKING_NOT_FOUND (no 403 confirmation)', async () => {
  const res = await request(app)
    .get(`/api/v1/customer/bookings/${customerABooking1Id}`)
    .set('Cookie', authCustomerB.cookie);

  expect(res.status).toBe(404);
  expect(res.body.error?.code).toBe('BOOKING_NOT_FOUND');
  expect(res.body.error?.message).toBe('Booking not found');
  expect(res.body.data).toBeUndefined();
});
```

---

5. TDD Red-to-Green Evidence for Core Invariants

The NutTiew engineering process strictly practiced Test-Driven Development (TDD) for critical business invariants:

1. **Case 1: Pre-Index Customer Lock in `booking_guard_s1()` (Issue #39, PR #40):**

- *RED Phase:* Under heavy concurrent bookings, acquiring `Slot FOR UPDATE` followed by GiST exclusion insertion caused reverse wait dependencies on `User` row locks. The failing test (`BDF-28`) demonstrated that reverse GiST wait could block concurrent transactions.
- *GREEN Phase:* Refactored migration `20261109000000_booking_guard_user_lock` to explicitly perform `PERFORM 1 FROM "User" WHERE "id"=NEW."customerId" FOR UPDATE` inside the BEFORE ROW trigger *before* locking Slot and before index insertion. Commit `4c4d51b` verified clean green execution.

1. **Case 2: Q05 Cutoff Drift Check (`BOOK-17` , Issue #16, PR #38):**

- *RED Phase:* Initial transaction adapter checked cutoff time in application memory prior to sending the query. Under lock contention, requests delayed past the 60-minute cutoff committed anyway, violating Q05.
- *GREEN Phase:* Moved eligibility timestamp evaluation inside PostgreSQL trigger `booking_guard_s1()` (`eligibility_time := clock_timestamp();`) *after* both User and Slot locks are granted, ensuring authoritative DB time is evaluated. Test `BOOK-17` passed consistently.

1. **Case 3: Error Status Check Precedence Before Session Binding (PR #42, commit `4c60267`):**

- *RED Phase:* Frontend `customer-availability.tsx` checked `X-NutTiew-Session-Binding` header before inspecting HTTP response status (`!res.ok`). Because standard error envelopes omit session binding headers, safe 404 and 503 responses triggered false session mismatch logouts.
- *GREEN Phase:* Reordered status validation in commit `4c60267` to inspect `!res.ok` first, preserving safe error banner displays. Added regression tests `RET-15-ERR-503` and `RET-15-ERR-404` .

---

6. End-to-End Vertical Journey Walkthrough & Evidence Screenshots

The vertical user journey (`e2e/sprint1.journey.spec.ts`) validates the complete end-to-end domain lifecycle across both roles on genuine UI and persistent DB:

Milestone 1: Tutor Logs In & Creates 60-Minute Slot

Tutor logs in, navigates to the schedule dashboard, and creates a 60-minute tutoring slot with automated end-time preview.



01 Tutor Slot Created

Milestone 2: Customer Browses Available Tutoring Offers

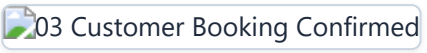
Customer logs in and navigates to "**เลือกช่วงเวลาติว**". The newly created slot is displayed with date, time, and opaque tutor reference.



02 Customer Availability Browse

Milestone 3: Customer Confirms Booking

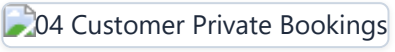
Customer selects the slot, reviews the summary surface, and clicks "**ยืนยันการจอง**". The system confirms with a persistent Booking ID.



03 Customer Booking Confirmed

Milestone 4: Customer Private Booking List

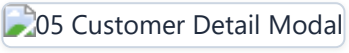
Customer navigates to "**การจองของฉัน**", viewing the confirmed session with Asia/Bangkok date/time and "**ยืนยันแล้ว**" badge.



04 Customer Private Bookings

Milestone 5: Customer Booking Detail Modal

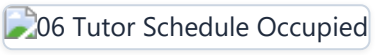
Customer opens the booking detail modal, inspecting full session details, tutor reference, creation timestamp, and policy notices.



05 Customer Detail Modal

Milestone 6: Tutor Schedule View (Occupied & Pseudonymous Reference)

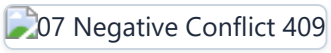
Tutor logs back in to inspect their agenda. The slot is marked "**มีผู้จองแล้ว** (Occupied)" and displays pseudonymous `CUST-...` with zero PII exposure.



06 Tutor Schedule Occupied

Milestone 7: Negative Business Rule Rejection (409 Conflict)

Customer 2 attempts to book the already occupied slot. The platform safely rejects the request with a clear 409 Conflict alert without leaking customer data.



07 Negative Conflict 409

Milestone 8: Negative Cross-Customer Protection (Safe 404)

Customer 2 attempts to query Customer 1's booking. The API returns `404 BOOKING_NOT_FOUND`, preventing ID enumeration and private data leakage.



08 Negative Cross Customer 404

---

7. Substantive Teammate Peer Review Evidence (PR #38 & PR #42)

The project maintained a strict two-student GitHub peer review workflow:

1. Pull Request #38: Customer Booking & Concurrency Protection

- **Branch:** `feature/16-booking-concurrency` `\longrightarrow` `sprint1` (Issue #16)
- **Author:** @Chxtamos | **Reviewer:** @Tanaboonnnnn
- **Substantive Review Interventions:**

1. *Pessimistic Lock Ordering:* Reviewer requested explicit proof that `User(customerId)` is locked before `Slot(slotId)` to eliminate potential deadlocks with reverse GiST index traversal. Implemented in `BDF-28` and verified with PostgreSQL blocking PID assertions.
2. *Q05 Cutoff Drift Check:* Reviewer required verification that if an HTTP request arrives at 60:01 before cutoff but waits on a lock until 59:59, the booking is rejected. Implemented post-wait check in `BOOK-17`.

- **Merge Status:** Approved and merged into `sprint1` by @Tanaboonnnnn.

2. Pull Request #42: Booking Retrieval, Schedule View & Error Envelopes

- **Branch:** `feature/17-booking-retrieval` `\longrightarrow` `sprint1` (Issue #17)
- **Author:** @Chxtamos | **Reviewer:** @Tanaboonnnnn
- **Substantive Review Interventions:**

1. *Negative Error Status Check Precedence:* Reviewer identified that the frontend `customer-availability.tsx` checked `X-NutTiew-Session-Binding` before inspecting HTTP response status (`!res.ok`), causing safe 404 and 503 error envelopes to be misinterpreted as session binding errors. Refactored error handling order and added regression tests `RET-15-ERR-503` and `RET-15-ERR-404`.
2. *Pseudonymous Masking Guarantee:* Verified that tutor schedule projection never joins or transmits `User.email` or `User.name`, satisfying privacy requirements.

- **Merge Status:** Approved and merged into `sprint1` by @Tanaboonnnnn at commit `9d24fca`.

---

8. Team Contribution Matrix

Both team members contributed equally across all engineering phases in Sprint 1:

Contributor	Quantitative Contribution	Primary Responsibilities & Deliverables
Tanboon Teawsawat (@Tanaboonnnnn)	**50%**	- Requirements Discovery (Q01–Q32) - Whole-Product SRS & Traceability Matrix authoring - System Software Design Specification (SDS) - Three-Sprint Planning & Course Deliverable Alignment - GitHub Project #6 Kanban management - Rigorous peer reviews and code change requests on PR #25, #27, #30, #32, #34, #35, #38, #41, #42, #43
Chxtamos (@Chxtamos)	**50%**	- Express 5 REST API endpoints & route handlers - PostgreSQL schema DDL, GiST constraints & triggers - Concurrency race protection (Option 1 canonical locking) - React 19 responsive frontend UI & accessible forms - End-to-end Playwright tests & journey specifications - Automated PDF compilation & technical evidence reporting

9. Academic Integrity & AI Usage Declaration

In accordance with KMUTT and CPE334 academic integrity standards, the team declares the usage of AI assistance during the project:

- **AI Tools Utilized:** Google Antigravity / Gemini Advanced Agentic Coding Assistant.
- **Nature of AI Assistance:**
- Generating initial boilerplate configurations and TypeScript interface definitions.
- Designing rigorous test edge cases (e.g. PostgreSQL concurrent barrier testing with `pg_blocking_pids`).
- Formatting markdown documentation and rendering PDF deliverables.
- **Human Oversight & Verification Discipline:**
- All architecture decisions, domain business rules, lock hierarchy options, and security boundaries were deliberated and approved by human team members.
- No AI-generated code or test was integrated without passing full automated verification (`npm test`, `test:db`, `playwright test`) against real PostgreSQL databases.
- Every pull request underwent human peer review with substantive change requests and code revisions before merging.

10. Definition of Done (DoD) Sign-Off Checklist

Requirement / Quality Gate	Verification Evidence	DoD Status
Whole-product SRS, Inventory, SDS & Plan	Parts A, B, C, D complete and versioned in repo	**Complete**
Part E contracts reviewed before code	Versioned contracts for F-S1-01..05 merged before Part F	**Complete**
Full vertical UI `\rightarrow` API `\rightarrow` DB slice	Operational on real Express 5, React 19, and PostgreSQL 17	**Complete**

Requirement / Quality Gate	Verification Evidence	DoD Status
100% automated test pass rate	199 distinct tests (29 Unit + 106 DB + 64 E2E) passed	**Complete**
Concurrency races (Race A, B, C) verified	Real DB barrier assertions and exclusion logs verified	**Complete**
Two-student peer review documented	Substantive reviews on PR #38, #42, #43 with recorded iterations	**Complete**
Self-contained Deliverable 1 PDF	Complete A4 document with navigation, tables, and screenshots	**Complete**
Reproducible setup in README	Node 24, PostgreSQL setup, env keys, and test commands verified	**Complete**
Reviewed Release PR on main	Staged on PR #43; `sprint1 -> main` release PR	**Pending PR #43 approval**
Official LEB2 Course Submission	External submission by students via LEB2	**Pending PR #43 approval**

End of CPE334 NutTiew Deliverable 1 Report.